

Principles of Cybersecurity in the Age of Autonomous AI

A Pedagogical Introduction to Agentic Threats,
Financial Risk, and Governance-First Defense

Alejandro Reynoso

August 15, 2026

Book Purpose

This book has one primary objective: to give Master of Finance students and financial professionals a rigorous, practical, and safe understanding of cybersecurity as a source of operational and financial risk.

It is not a book about becoming a hacker. It is not a manual for unauthorized access, exploitation, persistence, credential theft, or destructive activity. The book deliberately avoids operational attack instructions and instead concentrates on the mechanisms that matter for decision-makers: what an adversary is trying to achieve, what a defensive platform can observe, how technical events become financial losses, and how institutions should design controls, governance, resilience, and recovery.

The intended reader may work in investment banking, asset management, commercial banking, market infrastructure, payments, trading, risk management, consulting, regulation, audit, or corporate finance. In each of these activities, cybersecurity now affects the reliability of the financial operating model.

A modern financial institution is fundamentally an information-processing institution. Payments depend on identities and instructions. Trading depends on connectivity, market data, permissions, and execution systems. Asset management depends on positions, prices, models, and custody interfaces. Exchanges depend on matching, participant access, surveillance, and market-data distribution. Risk management depends on trustworthy data and systems. If those informational foundations fail, a financially sound strategy can still produce a loss.

The book therefore treats cybersecurity as a branch of operational risk with direct consequences for market risk, liquidity risk, credit risk, model risk, legal exposure, conduct, reputation, and business continuity.

The pedagogical principle is:

Understand the Mechanism → Recognize the Risk → Design the Control → Govern the Response.
(1)

A second objective is to prepare readers for a rapidly changing threat environment driven by artificial intelligence. The AI perspective is integrated from the opening chapter through the concluding playbook. Each chapter considers how advanced models, tool-using agents, autonomous workflows, and coordinated multi-agent systems affect the subject at hand through changes in speed, persistence, scale, parallelism, authority, and analytical capacity. The discussion also considers how the AI systems themselves must be secured and how the same capabilities can strengthen defense.

The book does not assume that AI will automatically defeat strong security. Rather, it asks a more practical question:

How does the combination of model capability, tool access, autonomy, permissions, memory, and coordination alter the institution's residual cyber risk?

This leads to one of the central principles of the book:

$$\text{Operational AI Risk} = f(\text{Capability, Authority, Autonomy, Tools, Data, Controls}). \quad (2)$$

A highly capable model with no tools and no operational authority may create limited direct financial risk. A less capable agent with access to payments, trading systems, confidential data, or production code may create much greater exposure.

The book therefore focuses on the **system** rather than merely the model.

A third objective is to preserve a strict safety boundary while still providing meaningful intuition.

All technical examples are designed to be:

synthetic; local; isolated; predetermined; defensive; and materially innocuous.

The companion notebooks use fictional identities, fake files, synthetic logs, toy workflows, and transparent rules. Students learn how suspicious behavior appears from the defensive side without scanning real systems, testing public infrastructure, using real credentials, generating exploit payloads, or creating tools that could be used for unauthorized access.

This is not merely an ethical restriction. It is a pedagogical choice.

For finance students, the most valuable questions are:

1. Which financial process is affected?
2. Which identity, data set, application, vendor, or agent is involved?
3. What unauthorized outcome is possible?
4. Which preventive and detective controls should exist?
5. What is the maximum plausible financial consequence?
6. How quickly can the institution detect and contain the event?
7. Can the institution restore a trusted operating state?
8. Who owns the residual risk?

The final objective is institutional literacy.

A finance professional should be able to challenge management, evaluate a vendor, participate in due diligence, interpret a cyber incident, question an AI deployment, and understand whether a control architecture is credible.

The professional does not need to write attack code.

The professional does need to understand the economic significance of digital trust.

Safety Boundary

No exercise in this book should scan, probe, test, access, modify, or interfere with a real system, public website, institutional network, third-party account, device, payment platform, trading system, or cloud environment.

All laboratories must remain local, synthetic, isolated, predetermined, and explicitly defensive. If a deeper technical exercise is desired, it should take place only in a purpose-built cyber range or other environment for which the learner has explicit authorization.

Finance and Operational-Risk Lens

The central thesis of the book is that cybersecurity is not peripheral to finance. It is part of the infrastructure through which financial claims, positions, payments, prices, information, and authority are expressed. As AI systems become more autonomous, the quality of cyber governance becomes a direct determinant of operational resilience and financial value.

Audience

This book is written primarily for Master of Finance students, but its practical audience is broader.

The common characteristic of the intended reader is not technical expertise. It is responsibility for decisions whose outcomes depend on digital systems.

The book is especially relevant for:

investment bankers; asset managers; portfolio managers; traders; treasury professionals; commercial and investment-bank risk officers; market-infrastructure executives; exchange and clearing personnel; fintech managers; payments professionals; private-equity and venture-capital investors; M&A professionals; regulators; auditors; consultants; board members; and senior executives.

The book assumes that the reader understands basic finance but may have very little prior cybersecurity knowledge.

No programming background is required to understand the text.

The companion notebooks use simple Python, but every technical concept is introduced through financial intuition first. A student should be able to follow the core argument even if the notebook is not executed.

The book is deliberately designed for readers who must answer questions such as:

How could a cyber event create a financial loss?

How much authority does this AI agent actually have?

Could a vendor failure stop a critical financial service?

What should a board know about autonomous systems?

How should cyber risk affect valuation, lending, due diligence, or investment decisions?

What the Reader Should Be Able to Do

By the end of the book, the reader should be able to:

1. explain cybersecurity without relying on technical mythology;
2. distinguish assets, threats, vulnerabilities, controls, events, alerts, incidents, and losses;

-
3. understand the relationship between authentication, authorization, and economic authority;
 4. explain why data integrity may be as important as confidentiality in finance;
 5. interpret a basic security timeline;
 6. connect detection speed to financial-loss severity;
 7. understand how AI accelerates vulnerability discovery and long-horizon cyber analysis;
 8. recognize common agentic architectures such as planner–executor systems, specialist teams, supervisor architectures, and memory-augmented agents;
 9. evaluate AI-agent permissions and segregation of duties;
 10. understand prompt injection, memory poisoning, tool misuse, and agent-to-agent trust as governance problems;
 11. identify third-party and model-provider concentration risk;
 12. quantify cyber risk using scenario analysis and simple frequency–severity models;
 13. participate constructively in incident response and business-continuity discussions;
 14. ask effective questions of security and technology teams;
 15. evaluate whether cyber and AI risks are appropriately reflected in governance and valuation.

What This Book Does Not Attempt to Teach

This book does not attempt to train:

offensive penetration testers; exploit developers; malware developers; credential thieves; unauthorized vulnerability scanners; and intrusion operators.

Those are different disciplines.

The objective here is financial and institutional competence.

A finance professional should understand the nature of the threat without needing to reproduce the attack.

Why This Audience Matters

Financial institutions increasingly delegate judgment and action to software.

Historically, a risk manager might ask whether an employee had the authority to release a payment or place a trade.

The emerging question is:

Does an autonomous agent have that authority?

This change creates a new literacy requirement.

Senior financial professionals will increasingly need to understand the difference between: a model that provides advice; a model connected to tools; a bounded workflow agent; an autonomous agent; and a multi-agent system with delegated authority.

That distinction is central to the book.

The reader is therefore not expected to become a cybersecurity engineer.

The reader is expected to become an informed owner of digital financial risk.

How to Use This Book

This book is designed to be read sequentially, but it can also be used as a reference.

The ten chapters form a progression from intuition to governance.

The Learning Sequence

Chapter 1 establishes the basic vocabulary and explains how AI changes the cyber baseline by strengthening adversarial capability, defensive analysis, and the operational authority of institutional systems.

Chapter 2 explains what attackers seek to achieve and how AI changes the economics, personalization, persistence, and coordination of that activity.

Chapter 3 introduces the defender’s perspective: logs, events, alerts, correlation, agent telemetry, and AI-assisted inference.

Chapter 4 focuses on identity, authorization, passwords, service accounts, and autonomous-agent authority.

Chapter 5 examines applications, data integrity, prompt injection, tool misuse, memory poisoning, and practical protections.

Chapter 6 develops monitoring, vulnerability discovery, security operations, AI-assisted detection, and defender-first cyber strategy.

Chapter 7 addresses incident response, business continuity, selective containment, and recovery in an agentic environment.

Chapter 8 introduces quantitative cyber-risk analysis, frequency–severity models, scenario analysis, tail risk, and AI threat multipliers.

Chapter 9 moves to governance, third parties, supply chains, model providers, concentration risk, and institutional accountability.

Chapter 10 integrates the complete framework into a finance professional’s cyber-risk playbook, with particular attention to automation decisions, agentic defense, due diligence, board oversight, containment, and trusted recovery.

The Repeating Pedagogical Structure

Most chapters contain the same elements:

1. **Learning Objectives** — what the reader should know by the end.

-
2. **Plain-Language Explanation** — the concept without unnecessary technical vocabulary.
 3. **Financial-Market Interpretation** — why the concept matters for banking, trading, payments, asset management, or market infrastructure.
 4. **AI Threat Lens** — how frontier models and autonomous systems change the threat.
 5. **Typical AI Architecture or Strategy** — a safe description of the relevant attacker or defender structure.
 6. **Protection Strategy** — practical controls.
 7. **Mini Case** — a fictional financial scenario.
 8. **Safe Notebook Lab** — a synthetic exercise.
 9. **Chapter Summary**.
 10. **Review Questions**.

This repetition is intentional.

Cybersecurity becomes easier when the reader repeatedly asks the same questions in different contexts.

How to Read the AI Sections

The AI sections distinguish four separate ideas.

Model Capability How capable is the underlying model at reasoning, coding, vulnerability discovery, or long-horizon tasks?

Tool Access Which external functions can the model invoke?

Autonomy Can the system continue acting without a human specifying every next step?

Authority Can the system create a financial or operational consequence?

The last category is especially important.

A highly capable model with no tools may be less risky than a modest agent with permission to release payments.

The recommended conceptual formula is:

$$R_{\text{agent}} = f(\text{Capability, Tools, Autonomy, Authority, Data, Controls}). \quad (3)$$

How to Use the Notebook Labs

Each notebook lab should be treated as a defensive thought experiment.

The exercises are not designed to approximate a real attack environment.

Instead, they model the defender's evidence.

Typical notebook objects include:

fictional users; synthetic passwords; fake payment instructions; toy portfolios; predetermined login attempts; fake web paths; in-memory documents; synthetic AI agents; transparent permission rules; fictional alerts; and hypothetical financial losses.

The notebooks should never be extended to real targets.

The learner should focus on the sequence:

Action → Evidence → Control → Alert → Financial Decision. (4)

Recommended Classroom Use

A typical chapter can be taught in four stages.

Stage 1: Conceptual Discussion Begin with the financial process.

For example:

What happens if the pricing file is wrong?

Then introduce the cyber mechanism.

Stage 2: Mini Case Students should identify:

assets; identities; vulnerabilities; controls; and potential losses.

Stage 3: Notebook Students observe the synthetic evidence.

The objective is to see how a defensive platform converts raw events into a risk judgment.

Stage 4: Governance Discussion The final question should be:

Who should be allowed to make the decision, and what evidence should be required?

Recommended Reading Discipline

Readers should resist two temptations.

The first is to become fascinated by the mechanics of attack while forgetting the financial consequence.

The second is to treat cybersecurity as abstract policy without understanding the technical mechanism.

The book tries to remain between those extremes.

The correct level of understanding for finance is:

Enough Technical Intuition + Strong Financial Context + Clear Governance. (5)

A Suggested Study Checklist

At the end of each chapter, the reader should be able to answer:

1. What is the protected financial process?
2. What could an unauthorized actor or agent try to achieve?
3. What evidence would the defender observe?
4. Which controls should prevent or detect the event?
5. How does AI alter speed, scale, autonomy, or authority?
6. What is the potential financial loss?
7. What is the recovery process?
8. Who owns the residual risk?

If these questions can be answered clearly, the student understands the chapter.

Contents

Book Purpose	i
Audience	iv
How to Use This Book	vii
1 Cybersecurity Without Mystification	1
1.1 Why Finance Students Need Cybersecurity Intuition	1
1.2 The Simplest Possible Model	2
1.3 Essential Vocabulary	3
1.4 Cybersecurity as Operational Risk	3
1.5 The Financial Loss Channels	4
1.6 A Financial-Market Example: The Trading Desk	5
1.7 A Payment-Business Example	5
1.8 Cybersecurity and Valuation	6
1.9 Risk, Controls, and Residual Exposure	6
1.10 The Role of the Board and Senior Management	7
1.11 Artificial Intelligence Changes the Baseline	7
1.12 Safe Cybersecurity Education	9
1.13 Mini Case: The Asset Manager	9
1.14 Safe Notebook Lab	10
1.15 Chapter Summary	10
1.16 Review Questions	10
2 What Attackers Try to Achieve	12
2.1 Begin with the Objective	12
2.2 Theft of Money and Financial Assets	13
2.3 Fraud and Unauthorized Decisions	13
2.4 Extortion and Coercion	13
2.5 Disruption of Critical Services	14
2.6 Manipulation of Data and Decisions	14
2.7 Espionage and Information Advantage	15
2.8 Unauthorized Authority as the Common Objective	15
2.9 Third Parties and Supply Chains	16

2.10	How AI Changes Attacker Economics	16
2.11	AI-Enabled Social Engineering	17
2.12	Agentic and Coordinated Activity	17
2.13	Financial Interpretation	17
2.14	Mini Case: The Treasury Instruction	18
2.15	Safe Notebook Lab	18
2.16	Chapter Summary	18
2.17	Review Questions	19
3	What a Defensive Platform Actually Sees	20
3.1	The Defender Does Not See “The Hacker”	20
3.2	From Raw Telemetry to Business Evidence	21
3.3	Events Are Not Alerts	21
3.4	Financial Context Changes the Meaning of an Alert	22
3.5	False Positives and False Negatives	23
3.6	From Alert to Case to Incident	24
3.7	The AI Threat Lens: Why the Defensive Problem Is Changing	24
3.8	Frontier Models and the Cyber Capability Frontier	25
3.9	Why Agentic Teams Matter More Than a Single Model	25
3.10	AI Changes the Speed of Detection as Well as Attack	26
3.11	The New Defensive Platform: Humans Plus Agents	26
3.12	A New Form of Model Risk	27
3.13	Mini Case: An Agentic Treasury Assistant	27
3.14	Safe Notebook Lab	28
3.15	A Pragmatic Framework for Financial Institutions	28
3.16	Chapter Summary	29
3.17	Review Questions	30
4	Identity, Passwords, and Access Risk in the Age of Agentic AI	31
4.1	Identity Is a Financial Control	31
4.2	Authentication Is Not Authorization	32
4.3	Why Passwords Became a Weak Control	32
4.4	Multifactor Authentication	33
4.5	Least Privilege	33
4.6	Segregation of Duties	34
4.7	Privileged Identities	34
4.8	Machine Identities and Service Accounts	35
4.9	The AI Threat Lens: Models Are Becoming Operational Actors	35
4.10	Frontier Cyber Models	36
4.11	Typical AI Models Used in an Attack Architecture	36
4.12	Typical Agentic Architectures Used by Threat Actors	37
4.13	Typical AI-Enabled Threat Strategies	38

4.14	Identity Attacks in an Agentic World	38
4.15	The New Control: Agent Identity	39
4.16	A Finance Example: Autonomous Treasury	39
4.17	A Trading Example: The Autonomous Research Agent	40
4.18	Defensive Strategies for the AI Identity Era	40
4.19	Mini Case: The Autonomous Payment Assistant	41
4.20	Safe Notebook Lab	41
4.21	A Pragmatic Identity Checklist for Finance Professionals	42
4.22	Chapter Summary	42
4.23	Review Questions	43
5	Applications, Data, and Integrity Risk in the Age of Agentic AI	44
5.1	Applications Are Financial Decision Systems	44
5.2	Integrity Is Often More Important Than Secrecy	45
5.3	A Simple Integrity Control	45
5.4	The Traditional Application Threat	46
5.5	The AI Threat Lens: AI Changes Both Sides of the Application	46
5.6	Prompt Injection: Social Engineering for Machines	47
5.7	Typical AI-Enabled Attack Strategies	48
5.8	Typical Agentic Threat Architectures	50
5.9	Protection Strategy 1: Separate Information from Authority	50
5.10	Protection Strategy 2: Least Privilege for Tools	51
5.11	Protection Strategy 3: Deterministic Gates	51
5.12	Protection Strategy 4: Human Approval for Material Actions	51
5.13	Protection Strategy 5: Isolation and Sandboxing	52
5.14	Protection Strategy 6: Provenance and Trusted Data	52
5.15	Protection Strategy 7: Independent Reconciliation	52
5.16	Protection Strategy 8: Immutable and External Logging	52
5.17	Protection Strategy 9: Limit Time, Money, and Scope	53
5.18	Protection Strategy 10: Design for Recovery	53
5.19	Financial Practice: The Valuation Agent	53
5.20	Financial Practice: The Trading Agent	54
5.21	Mini Case: The Research Document	54
5.22	Safe Notebook Lab	55
5.23	A Pragmatic Protection Checklist	55
5.24	Chapter Summary	56
5.25	Review Questions	57
6	Detection, Monitoring, and Security Operations in the Age of Agentic AI	58
6.1	The Purpose of Security Operations	58
6.2	Visibility Must Follow the Business Service	59
6.3	Detection Engineering	59

6.4	Vulnerability Management as a Race	60
6.5	Triage and Case Management	60
6.6	Threat Intelligence and Institutional Relevance	61
6.7	AI-Enabled Defensive Analysis	61
6.8	Defensive Agents as Institutional Users	62
6.9	The Risk of Automated Defensive Action	62
6.10	The Human–Machine Operating Model	63
6.11	Metrics That Matter	63
6.12	Mini Case: The Defensive Treasury Agent	63
6.13	Safe Notebook Lab	64
6.14	Chapter Summary	64
6.15	Review Questions	65
7	Incident Response and Business Continuity in the Age of Agentic AI	66
7.1	When an Alert Becomes an Incident	66
7.2	The Incident-Response Lifecycle	67
7.3	Cyber Response Is a Business Decision	68
7.4	The AI Threat Lens: Incidents Can Move Faster	68
7.5	Long-Horizon AI Agents	69
7.6	Typical AI-Enabled Incident Tactics	69
7.7	AI Can Also Shorten the Defender’s Response Time	70
7.8	The Danger of Autonomous Defensive Response	71
7.9	Business Continuity in an AI-Dependent Institution	71
7.10	Recovery Requires Trust, Not Merely Availability	72
7.11	Protection Strategy 1: Predefine Decision Rights	72
7.12	Protection Strategy 2: Maintain Independent Communication Channels	72
7.13	Protection Strategy 3: Preserve Immutable Evidence	72
7.14	Protection Strategy 4: Build Kill Switches and Scope Limits	73
7.15	Protection Strategy 5: Separate Recovery Credentials	73
7.16	Protection Strategy 6: Reconcile Before Reopening	73
7.17	Protection Strategy 7: Exercise AI-Specific Scenarios	73
7.18	Financial Practice: The Payment Platform	74
7.19	Financial Practice: The Exchange During Market Stress	74
7.20	Mini Case: Compromised Treasury Agent	75
7.21	Safe Notebook Lab	75
7.22	A Pragmatic Incident-Response Checklist	76
7.23	Chapter Summary	77
7.24	Review Questions	77
8	Quantifying Cyber and AI-Enabled Operational Risk	79
8.1	Why Cyber Risk Is Difficult to Quantify	79
8.2	The Basic Frequency–Severity Model	80

8.3	From Technical Events to Financial Loss	80
8.4	Exposure, Threat, Vulnerability, and Control	81
8.5	Inherent and Residual Risk	81
8.6	The AI Threat Lens: Threat Pressure Is Becoming Endogenous	81
8.7	AI Can Affect Severity as Well as Frequency	82
8.8	Scenario Analysis	83
8.9	Scenario 1: Payment Identity Compromise	83
8.10	Scenario 2: AI-Assisted Vulnerability Discovery	83
8.11	Scenario 3: Manipulated Autonomous Agent	84
8.12	Scenario 4: Exchange Outage	84
8.13	Tail Risk	84
8.14	AI and Tail Risk	85
8.15	Control Effectiveness	85
8.16	The Economics of Security Investment	85
8.17	AI-Specific Security Investment	86
8.18	Monte Carlo Simulation	86
8.19	Adding an AI Threat Multiplier	87
8.20	Stress Testing	87
8.21	Capital and Liquidity	87
8.22	Cyber Insurance	88
8.23	Model Risk in Cyber Quantification	88
8.24	Financial Practice: The Autonomous Trading Agent	88
8.25	Mini Case: AI Threat Multiplier at a Broker-Dealer	89
8.26	Safe Notebook Lab	89
8.27	A Pragmatic Quantification Checklist	90
8.28	Chapter Summary	90
8.29	Review Questions	91

9 Governance, Third Parties, and Institutional Accountability in the Age of Agentic AI 93

9.1	Cybersecurity Is Not an IT Problem	93
9.2	Governance Begins with Accountability	94
9.3	The Three Lines	95
9.4	Board Responsibility	96
9.5	Risk Appetite	96
9.6	The AI Threat Lens: Governance Is Becoming a Cyber Control	97
9.7	The System Is the Unit of Risk	98
9.8	Typical AI-Enabled Governance Attack Surfaces	98
9.9	Third-Party Risk	99
9.10	AI Model Providers as Critical Vendors	100
9.11	Cloud and Model Concentration	100
9.12	Vendor Due Diligence	101

9.13	The Software Supply Chain	101
9.14	Agent Supply Chains	101
9.15	Policies, Standards, Procedures, and Controls	102
9.16	Agent Governance	102
9.17	Segregation of Duties for Agent Teams	103
9.18	Governance of Agent Memory	103
9.19	Governance of Frontier Cyber Models	103
9.20	Protection Strategy 1: Inventory Every Material Agent	104
9.21	Protection Strategy 2: Separate Vendor Access from Business Authority	104
9.22	Protection Strategy 3: Contract for Evidence	104
9.23	Protection Strategy 4: Build Exit Plans	105
9.24	Protection Strategy 5: Test Concentration Scenarios	105
9.25	Protection Strategy 6: Independent AI Control Layer	105
9.26	Financial Practice: Third-Party Pricing Provider	106
9.27	Financial Practice: External AI Research Provider	106
9.28	Financial Practice: Autonomous Vendor-Management Agent	106
9.29	Mini Case: Common AI Dependency	107
9.30	Safe Notebook Lab	107
9.31	A Pragmatic Governance Checklist	108
9.32	Chapter Summary	109
9.33	Review Questions	109
10	A Finance Professional's Cyber-Risk Playbook in the Age of Agentic AI	111
10.1	The Finance Professional's Objective	111
10.2	One Integrated Management Cycle	112
10.3	The Institution as a Network of Trust and Authority	113
10.4	AI Capability Is a Management Variable	113
10.5	How AI Changes Cyber Economics	114
10.6	The Control Architecture	114
10.7	Deciding What to Automate	115
10.8	Due Diligence, Lending, and Investment	116
10.9	Board Oversight and Management Information	117
10.10	Agentic Defense	117
10.11	A Ninety-Day Management Program	118
10.12	Capstone Case: Meridian Financial Group	118
10.13	The Questions That Organize Judgment	119
10.14	Safe Notebook Lab	120
10.15	Continuing Learning	120
10.16	Final Lessons	120
10.17	Final Review Questions	121
	Glossary	122

Safe Laboratory Rules	127
Rule 1: Use Fictional Identities	127
Rule 2: Use Synthetic Data	127
Rule 3: Keep the Environment Local	127
Rule 4: No Real Scanning	128
Rule 5: No Real Authentication Testing	128
Rule 6: No Operational Exploit Payloads	128
Rule 7: No Malware	128
Rule 8: Constrain AI Agents	128
Rule 9: Make Every Action Visible	129
Rule 10: Prefer Defensive Questions	129
Rule 11: Use Deterministic Guardrails	129
Rule 12: Preserve Auditability	129
Rule 13: Use Purpose-Built Cyber Ranges for Deeper Technical Work	130
Rule 14: Stop When the Educational Objective Is Met	130
Minimum Laboratory Verification Checklist	130
 Suggested Capstone	 131
Purpose	131
The Institution	131
The Synthetic Incident	132
Required Analysis	132
Deliverables and Evaluation	133
Safety and Academic Integrity	134
 Instructor Notes	 135
Teaching Philosophy	135
Recommended Course Structure	136
Teaching the AI Threat	136
Teaching Attack Concepts Safely	137
Recommended Case Discussions	138
Assessment Philosophy	141
Suggested Assignments	141
Notebook Review Checklist	146
Discussion Questions for the Full Course	146
Instructor’s Final Message	147
 Bibliography	 148

Chapter 1

Cybersecurity Without Mystification

Learning Objectives

By the end of this chapter, the reader should be able to explain cybersecurity in plain language; distinguish assets, threats, vulnerabilities, controls, events, alerts, incidents, and losses; and connect technical failures to valuation, liquidity, payments, trading, settlement, client trust, regulation, and continuity. The reader should also understand how artificial intelligence changes adversarial capability, defensive analysis, and the design of institutional systems, and why safe cybersecurity education should emphasize mechanisms, evidence, controls, and consequences rather than operational attack techniques.

1.1 Why Finance Students Need Cybersecurity Intuition

Financial institutions are information-processing institutions. A bank may hold deposits and make loans, an asset manager may allocate capital, an exchange may match buyers and sellers, and a broker may route orders, but in every case the institution depends on the accurate, timely, and authorized processing of information. Prices, balances, positions, identities, instructions, collateral values, settlement records, risk limits, and payment messages are all forms of information. If those records are wrong, unavailable, delayed, or manipulated, the financial business can fail even when its economic strategy is sound.

This is the first reason cybersecurity matters for finance students. Cybersecurity is not merely a technical specialty that belongs to an information-technology department. It is part of the operating architecture of every modern financial institution. The reliability of a trading desk depends not only on the quality of its models but also on whether traders can authenticate, whether market data are accurate, whether orders are transmitted to the correct venue, and whether controls prevent unauthorized changes. The reliability of a fund's net asset value depends not only on valuation methodology but also on whether pricing files, positions, and reference data have preserved their integrity. The reliability of a payment operation depends not only on sufficient liquidity but also on whether payment instructions are genuine and systems are available when needed.

The second reason is that cyber events often become financial events. A compromise of client data may create legal liabilities and reputational damage. A ransomware incident may interrupt trading or payment operations. A manipulated data file may distort risk metrics or valuations. An identity failure may allow an unauthorized user to initiate a payment. A denial-of-service event may make an exchange, brokerage platform, or online bank unavailable during a period of market stress. The technical event is therefore only the first layer. The business consequence may appear in revenues, expenses, liquidity needs, regulatory capital, litigation exposure, insurance claims, client attrition, or even market confidence.

For Master of Finance students, the objective is not to become hackers. The objective is to understand enough about the mechanics of cyber risk to ask the right questions. A senior finance professional should be able to ask: What are our critical systems? Which identities have privileged access? What happens if market data are corrupted? How quickly can we restore the payment platform? Which vendors are single points of failure? How do we know that a suspicious login is merely a user mistake and not part of a broader event? How would a three-day outage affect liquidity, client obligations, and regulatory reporting?

These are management questions, investment questions, and risk questions. They require technical intuition but not offensive capability.

1.2 The Simplest Possible Model

A useful way to remove the mystery from cybersecurity is to reduce it to a sequence of actions and observations.

Core Intuition

A malicious actor attempts to produce an outcome that the institution did not authorize. A defensive system attempts to prevent that outcome, observe the relevant evidence, and respond before the business suffers unacceptable damage.

The simplest sequence is:

$$\text{Action} \rightarrow \text{Event} \rightarrow \text{Rule or Analysis} \rightarrow \text{Alert} \rightarrow \text{Decision}. \quad (1.1)$$

Suppose a fictional brokerage has an administrative account. A user enters the wrong password once. That action creates a failed-login event. The event itself does not prove anything malicious. People mistype passwords every day. If the same source generates ten failed login attempts in a short interval, however, a defensive rule may classify the pattern as unusual. The platform may create an alert. A security analyst or automated control then makes a decision: ignore the activity, ask the user to verify identity, temporarily block further attempts, or investigate additional evidence.

The distinction between event and alert is fundamental. An event says that something happened. An alert says that the institution believes the event or pattern deserves attention. An incident goes one step further: it represents a situation that is sufficiently credible or consequential to require coordinated handling.

In finance, we can use an analogy with market surveillance. One unusual trade is not necessarily market manipulation. A surveillance platform records the trade as an event. A pattern of trades may trigger an alert. An investigation then determines whether the activity is legitimate, suspicious, or a breach. Cybersecurity operates in a similar way. The defender observes behavior and evaluates it in context.

1.3 Essential Vocabulary

Cybersecurity becomes much easier when a small number of concepts are kept distinct.

An **asset** is something the institution values and wants to protect. In finance, assets include not only cash and securities but also client records, trading systems, pricing data, payment credentials, algorithms, risk models, regulatory reports, communication systems, and institutional reputation.

A **threat** is a source of potential harm. Threats may include criminal groups, insiders, competitors, politically motivated actors, careless employees, malicious vendors, or simply automated systems searching for exposed weaknesses.

A **vulnerability** is a weakness that could be used to create an unwanted outcome. A weak password is a vulnerability. An unnecessary public-facing service can be a vulnerability. Excessive user privileges, outdated software, poor segregation of duties, or an untested backup process can also be vulnerabilities.

A **control** is a mechanism that reduces either the probability or the impact of an adverse event. Multifactor authentication is a control. Rate limiting is a control. Encryption is a control. Reconciliation is a control. Segregation of duties is a control. A tested disaster-recovery plan is a control.

An **event** is an observable occurrence. A login, a file change, a network request, a system restart, or a failed payment can all be events.

An **alert** is a defensive interpretation of one or more events. An alert normally indicates that the pattern is unusual, risky, or inconsistent with policy.

An **incident** is a confirmed or sufficiently credible security event requiring formal response.

A **loss event** is the business consequence. The loss may include fraud, remediation expense, operational downtime, legal cost, client compensation, regulatory penalty, or lost revenue.

These concepts are related but they are not interchangeable. A vulnerability is not the same as an incident. An alert is not the same as proof of compromise. A technical compromise is not the same as a financial loss. Strong risk management depends on keeping the chain of causation clear.

1.4 Cybersecurity as Operational Risk

Cybersecurity belongs naturally within operational risk because cyber events typically operate through failures of people, processes, systems, or external dependencies. These are the same broad categories that have historically defined operational risk.

Consider a trading business. A trader may make a legitimate decision to buy a security. The business process then requires authentication, order entry, pre-trade controls, routing, execution, confirmation, settlement, accounting, and risk reporting. A cyber event can interfere with any point in this chain.

If credentials are compromised, an unauthorized person may enter orders. If order-routing software is unavailable, the firm may lose market access. If reference data are corrupted, the system may misclassify a security. If settlement instructions are altered, cash or securities may be sent to the wrong destination. If the risk database is unavailable, management may lose visibility into exposures. The economic strategy can be entirely correct while the operational infrastructure fails.

This distinction is important for finance students because traditional financial training often emphasizes market risk, credit risk, and liquidity risk. Cyber risk interacts with all three.

A cyber incident can create **market-risk consequences** if positions cannot be hedged or closed. Imagine a derivatives dealer whose trading system becomes unavailable during a sharp market movement. Even if the dealer's original exposures were within limits, the inability to trade can create losses.

A cyber incident can create **credit-risk consequences** if counterparty information is corrupted or if settlement is delayed. If a system cannot confirm collateral balances, the institution may face uncertainty about exposure.

A cyber incident can create **liquidity-risk consequences** if payments cannot be made, margin calls cannot be processed, or clients withdraw funds after a public breach.

A cyber incident can also create **model-risk consequences**. Suppose the inputs to a risk model are altered while the model itself continues to run correctly. The mathematical model may be sound, but the output becomes unreliable because the data are not trustworthy.

For this reason, cyber risk should be treated as a cross-cutting operational risk rather than a narrow technology problem.

1.5 The Financial Loss Channels

A useful first approximation is to decompose cyber loss into several channels:

$$L_{\text{cyber}} = L_{\text{direct}} + L_{\text{business interruption}} + L_{\text{legal}} + L_{\text{remediation}} + L_{\text{reputation}} + L_{\text{strategic}}. \quad (1.2)$$

The first component, L_{direct} , includes direct financial theft, unauthorized payments, fraudulent transfers, or direct asset loss.

The second, $L_{\text{business interruption}}$, captures lost revenues or additional costs caused by unavailable systems. An exchange that cannot match orders, a bank that cannot process payments, or an asset manager that cannot value portfolios may experience losses even without theft.

The third, L_{legal} , includes litigation, regulatory penalties, contractual claims, and disclosure-related costs.

The fourth, $L_{\text{remediation}}$, includes forensic investigations, replacement systems, external consultants, customer support, legal review, and restoration expenses.

The fifth, $L_{\text{reputation}}$, captures client attrition, reduced willingness to transact, higher funding costs, or weaker franchise value.

The sixth, $L_{\text{strategic}}$, reflects longer-term consequences. A serious cyber failure can delay a transaction, undermine a digital strategy, affect a merger, damage regulatory relationships, or force management to redirect investment.

This decomposition is not intended to produce false precision. In practice, the categories can overlap. The purpose is pedagogical: to make clear that the cost of a cyber event is rarely limited to the immediate technical repair.

1.6 A Financial-Market Example: The Trading Desk

Consider a fictional institutional trading desk. Its critical assets include trader identities, market data, order-management software, risk limits, position records, and communication with exchanges and counterparties.

Suppose the desk experiences repeated login failures on a privileged account. The defensive platform records the activity. At first, the operational impact is zero. No trade has been altered and no system is unavailable.

Now imagine that a successful login follows those failures. The event becomes more interesting. The defender asks whether the successful login came from the same workstation normally used by the employee. Was multifactor authentication completed? Did the user then access unusual functions? Were risk limits changed? Were orders entered?

The institution does not need to assume the worst immediately. It needs to investigate proportionately.

If the account was legitimate and the user simply mistyped the password, the incident may close with no loss. If the account was compromised but no sensitive action occurred, the institution may reset credentials and increase monitoring. If an unauthorized order was entered, the issue becomes both a cyber event and a trading-control event. The financial consequence depends on whether the order was executed, whether it was detected before settlement, and whether it generated market exposure.

This example shows why cybersecurity and financial controls should not be separated. The best defense is often not a single security tool. It is a combination of identity controls, trading limits, supervisory review, reconciliation, and rapid response.

1.7 A Payment-Business Example

Payments provide another intuitive illustration.

A payment instruction has several important properties. It should come from an authorized person or system. The amount and destination should be correct. The instruction should not

be altered in transit. The payment platform should be available. The institution should be able to prove what occurred.

These requirements correspond closely to core cybersecurity properties.

Confidentiality means that sensitive payment information is accessible only to authorized parties.

Integrity means that the payment instruction has not been improperly altered.

Availability means that the system can process the payment when required.

Authentication provides evidence about who initiated the action.

Authorization determines whether that identity is permitted to initiate or approve the payment.

Auditability preserves evidence of what happened.

A failure in any one of these dimensions can become a financial loss. For this reason, a finance professional reviewing a payment business should ask not only about liquidity and settlement arrangements but also about identity controls, resilience, change management, and recovery.

1.8 Cybersecurity and Valuation

Cybersecurity also has implications for valuation.

Suppose two financial technology firms have identical revenues, margins, and growth rates. Firm A has strong identity controls, tested backups, documented incident response, diversified vendors, and disciplined software change management. Firm B has weak controls, undocumented systems, excessive administrator privileges, and a history of unresolved security findings.

Traditional valuation models may initially assign similar cash flows to both firms. Yet the distributions of future cash flows are not identical. Firm B has greater probability of operational interruption, remediation costs, regulatory action, and customer loss.

Cybersecurity therefore affects valuation through expected cash flow, volatility, tail risk, and potentially the appropriate discount rate. It can also affect deal structure. An acquirer may demand indemnities, escrow arrangements, cyber insurance, remediation commitments, or a lower purchase price after due diligence identifies material weaknesses.

For finance professionals, this is one of the most important insights of the chapter: cyber risk is economically relevant even when no attack is currently occurring.

1.9 Risk, Controls, and Residual Exposure

Risk is not eliminated simply because a control exists. A control reduces risk, and the remaining exposure is residual risk.

A simple conceptual relationship is:

$$R_{\text{residual}} = R_{\text{inherent}} - \text{Effect of Controls.} \quad (1.3)$$

This equation is conceptual rather than literal. Risk cannot always be subtracted mechanically. But it highlights the distinction between the risk that would exist without controls and the risk that remains after controls are applied.

A financial institution may face high inherent cyber risk because it processes large payments, holds valuable client information, or operates critical market infrastructure. That does not necessarily mean the institution is poorly managed. The relevant question is whether controls reduce the risk to a level consistent with the institution's risk appetite.

This is the same logic used elsewhere in finance. A bank may accept credit risk but manage it through underwriting, limits, collateral, pricing, and capital. A trading firm accepts market risk but manages it through limits, hedging, and monitoring. Cyber risk is similar: the objective is not zero exposure but disciplined, visible, governable exposure.

1.10 The Role of the Board and Senior Management

Cybersecurity is often described as a board-level issue. This does not mean directors should review code or configure security systems. It means they should understand the institution's exposure and challenge management on critical questions.

A board should know which services are essential to the business. It should understand how long those services can be unavailable before losses become unacceptable. It should know whether backups have been tested, whether critical vendors create concentration risk, whether major incidents are escalated promptly, and whether management is closing known control weaknesses.

Senior management should translate technical risk into business language. A report that says "we detected 50,000 malicious packets" is not useful to most executives. A report that says "a control prevented unauthorized access to the payment platform; no customer funds were affected; the vulnerability was closed; and no residual exposure has been identified" is much more useful.

This translation between technical evidence and business consequence is one of the core skills this book seeks to develop.

1.11 Artificial Intelligence Changes the Baseline

Artificial intelligence does not replace the cybersecurity model developed in this chapter. Financial institutions still need to protect assets, govern identities, identify vulnerabilities, operate controls, interpret events, respond to incidents, and restore trusted operations. AI changes the environment in which those activities occur. It can increase the productivity of an adversary, improve the analytical capacity of a defender, and create a new class of institutional system that must itself be secured.

The first change is economic. Advanced models can analyze large volumes of text, code, configuration, and operational evidence. Agentic systems can preserve context, call tools, divide work among specialized components, evaluate intermediate results, and continue through a sequence of tasks with limited supervision. These capabilities may reduce the cost

of reconnaissance, social engineering, software analysis, and repeated experimentation. They may also increase persistence and parallelism. The prudent conclusion is not that AI makes every adversary sophisticated or every existing control obsolete. It is that assumptions about the scarcity, speed, and scale of expert work require regular review.

The second change is defensive. AI can help an institution correlate events, summarize investigations, identify relationships among identities and systems, review code, prioritize remediation, and translate technical evidence into business consequence. Used carefully, it can reduce the time between observation and understanding. Yet an analytical assistant is not automatically a safe decision maker. Its inputs may be incomplete or manipulated, its conclusions may be wrong, and its confidence may not reflect the financial importance of the decision. Defensive value therefore depends on evidence, validation, restricted access, and clear human accountability.

The third change is architectural. A model may be embedded in a system that reads email, retrieves documents, queries databases, modifies files, writes code, communicates with clients, or initiates payment and trading workflows. The relevant unit of risk is then the complete system rather than the model alone:

$$R_{\text{AI system}} = f(\text{Capability, Data, Tools, Autonomy, Authority, Controls}). \quad (1.4)$$

A highly capable model that can only draft a report creates a different exposure from an agent that can change a beneficiary, deploy production code, submit an order, or alter a risk limit. Financial institutions should therefore separate intelligence from authority. Models may propose, classify, explain, or recommend, while deterministic limits, segregation of duties, approval thresholds, reconciliation, and independent logging govern economically material actions.

AI systems also create their own attack surface. Untrusted documents can influence an agent's context, inaccurate information can persist in memory, tools can be combined in unintended ways, and one agent can place excessive trust in another. Model and cloud providers may also become concentrated dependencies. These risks connect cybersecurity with model risk, data governance, vendor management, operational resilience, and business continuity.

The durable management principle is simple. Institutions should not rely on a model, employee, vendor, or security product being perfectly reliable. They should limit authority, make important actions observable, require independent verification where consequences are material, preserve the ability to interrupt activity, and maintain a tested path back to a trusted state. AI makes this principle more urgent, but it extends familiar financial disciplines rather than replacing them.

Finance and Operational-Risk Lens

AI changes cyber risk through three connected channels: it can strengthen adversarial capability, improve defensive analysis, and become a material institutional system that requires protection. The financial consequence depends less on intelligence alone than

on the authority, data, tools, dependencies, and controls surrounding that intelligence.

1.12 Safe Cybersecurity Education

There is an important pedagogical issue. Students need enough understanding of attacker behavior to recognize risks, but training should not unnecessarily create operational capability for misuse.

The safest educational approach is to model the attacker as a generator of synthetic events. A notebook can simulate repeated login failures, suspicious path requests, or an unexpected file change without contacting any external system. Students can then focus on the defender's problem: what evidence appears, how should it be interpreted, which control should respond, and what financial consequence could follow?

This approach is especially appropriate for finance students. Their comparative advantage is not in developing offensive techniques. It is in understanding institutional exposure, incentives, controls, governance, and loss transmission.

Safety Boundary

All laboratories in this book should remain synthetic, local, isolated, predetermined, and defensive. The objective is to understand cyber risk without testing real systems, using real credentials, scanning external infrastructure, or creating tools designed for unauthorized access.

1.13 Mini Case: The Asset Manager

Consider a fictional asset manager with \$20 billion under management. The firm has 120 employees, an order-management system, a portfolio-accounting platform, a client portal, and several external pricing vendors.

At 8:12 a.m., the security platform records five failed login attempts against a portfolio administrator's account. At 8:14 a.m., the same account successfully authenticates. At 8:18 a.m., a pricing file used for daily valuation changes unexpectedly.

What should management conclude?

The correct answer is not that the firm has definitely been hacked. The evidence is insufficient. The login failures may reflect a user mistake. The successful login may be legitimate. The pricing-file change may be an authorized update.

However, the combination of events deserves investigation. The institution should verify the identity of the user, determine whether the successful login came from an expected device, review whether multifactor authentication was completed, inspect the file-change process, compare the new pricing file with authorized vendor data, and determine whether any valuation process used the modified file.

From a finance perspective, the most important question is whether the integrity of the portfolio valuation was affected. If the file was modified before the NAV calculation, the firm

may need to rerun valuation, review client reporting, examine trading decisions based on the affected data, and document the incident.

The technical alert becomes a financial-control problem.

Finance and Operational-Risk Lens

The central lesson is that cybersecurity should be analyzed through the business process it can disrupt. For a financial institution, the relevant question is not merely “Was there a cyber event?” but “Which financial process depended on the affected system, identity, or data, and what losses could follow if that process failed?”

1.14 Safe Notebook Lab

Safe Notebook Lab

The companion notebook for this chapter creates fictional assets, identities, web requests, login events, and file-integrity events entirely in memory.

Students observe how an ordinary activity becomes a structured event, how repetition creates a pattern, how a transparent rule converts that pattern into an alert, and how a file hash reveals a change in synthetic content. They then place several events on a timeline and translate technical evidence into operational-risk questions. A final comparison shows how AI-assisted triage may summarize or prioritize evidence while deterministic rules and a human decision maker retain authority over the response.

No external network target is used. The notebook does not perform real reconnaissance, password cracking, exploitation, persistence, evasion, or data extraction.

1.15 Chapter Summary

Financial institutions are information-processing businesses, which makes cybersecurity inseparable from financial operations. Cyber risk connects assets, authority, actions, events, controls, alerts, decisions, and possible losses. An event is not automatically an incident, an alert is not proof of compromise, and a technical failure matters because of the financial process that depends on the affected identity, system, data, agent, or vendor.

Artificial intelligence expands this framework by changing the speed and scale of adversarial work, strengthening defensive interpretation, and becoming an operational actor with access to institutional data and tools. The resulting risk depends on capability combined with authority, autonomy, permissions, dependencies, and control design. Finance professionals do not need offensive proficiency, but they do need enough technical intuition to evaluate these relationships and preserve resilient operations.

1.16 Review Questions

1. Why can a financial institution be viewed as an information-processing institution?

2. What is the difference between an event, an alert, and an incident?
3. Give three examples of financial assets that are primarily informational rather than physical.
4. How can a cyber incident create market risk?
5. How can a cyber incident create liquidity risk?
6. Why does a file-integrity alert not by itself prove malicious activity?
7. What is the difference between inherent cyber risk and residual cyber risk?
8. Why should cybersecurity due diligence matter in an acquisition of a financial technology company?
9. Which questions should a board ask about cyber resilience without becoming involved in technical implementation?
10. In the asset-manager case, why is the integrity of the pricing file a financial-control issue rather than merely an IT issue?

Chapter 2

What Attackers Try to Achieve

Learning Objectives

By the end of this chapter, the reader should be able to interpret cyber threats through the outcomes an adversary seeks rather than the tools an adversary uses. The reader should be able to connect theft, fraud, extortion, disruption, manipulation, espionage, and unauthorized authority to financial processes; distinguish immediate technical activity from the underlying economic objective; explain how AI changes the speed, scale, personalization, persistence, and coordination of adversarial work; and identify controls that limit financial consequence even when an initial security barrier fails.

2.1 Begin with the Objective

Cybersecurity becomes easier to understand when attention moves away from dramatic technical imagery and toward institutional outcomes. An attacker does not normally value a password, a server, an email account, or a software weakness for its own sake. Those objects are useful because they may provide access to money, information, authority, leverage, disruption, or strategic advantage. The most useful management question is therefore not “Which tool might be used?” but “What unauthorized result is the actor trying to produce?”

For a financial institution, the distinction is essential. The same identity weakness could support several objectives. It might be used to read confidential client information, alter a beneficiary, submit a trade, approve a payment, change a risk limit, or interrupt a service. The control response depends on the outcome that becomes possible. Strong analysis begins with the business process, the authority attached to the affected identity or system, and the financial consequences of misuse.

Adversary Objective → Required Authority → Action → Financial Consequence. (2.1)

This model is intentionally high level. It gives finance students enough structure to interpret a threat without turning the discussion into operational instruction.

2.2 Theft of Money and Financial Assets

The most direct objective is theft. An adversary may seek to divert a payment, change settlement instructions, take control of an account, redirect a refund, or obtain a financial asset. The technical path can vary, but the economic requirement is stable: the actor must acquire enough authority to make the institution or a counterparty accept an unauthorized instruction.

The strongest controls therefore govern authority rather than merely secrecy. Multifactor authentication reduces the probability that a stolen password is sufficient. Segregation of duties prevents one identity from preparing and releasing the same payment. Approved-beneficiary rules constrain where value can move. Transaction and aggregate limits reduce severity. Independent confirmation and reconciliation may detect an unauthorized change before or shortly after value leaves the institution.

The finance professional should ask how much value the affected identity can move, how quickly repeated actions could accumulate, whether the action is reversible, and which independent control remains if authentication fails. A technically minor weakness can become economically material when it is attached to payment, custody, trading, or administrative authority.

2.3 Fraud and Unauthorized Decisions

Not every adversary seeks immediate transfer of money. Some seek to make the institution take a decision that appears legitimate. A false invoice may be approved, an account detail may be changed, a trade may be entered, a credit decision may be influenced, or a financial record may be altered. In these cases the institution's own process becomes the mechanism through which the loss occurs.

Fraud is therefore closely related to trust. The adversary attempts to make an instruction, identity, document, or data point appear authoritative. Controls should test important claims through an independent channel and ensure that the person or system confirming the claim is not merely repeating the same compromised source. A callback to a number contained in a suspicious message is not independent verification. A second AI agent that relies on the same manipulated document may not provide independent judgment.

The distinction between automation and authority matters. An automated system may accelerate a legitimate workflow, but it can also accelerate a fraudulent one if the initial assumption is wrong. Financial institutions should preserve deterministic conditions around material decisions and should make exceptions visible, time-limited, and attributable to an accountable owner.

2.4 Extortion and Coercion

Extortion seeks leverage. The adversary may threaten to keep systems unavailable, disclose confidential information, publish stolen data, damage a reputation, or increase operational

disruption unless the institution provides money or another concession. The immediate technical event may be encryption, data theft, or loss of control, but the objective is to place management under time pressure.

Resilience reduces that leverage. Tested backups, alternative communications, manual procedures, segmented systems, prepared legal and regulatory coordination, and clear decision rights improve the institution's ability to resist coercion. A backup has value only if it is independent, complete, and usable within the business's recovery requirement. A continuity plan has value only if employees can execute it while normal identity, communication, or infrastructure services are degraded.

Extortion also creates governance questions. Management may need to balance continuity, legal constraints, client interests, safety, evidence preservation, and uncertainty about whether an adversary can or will honor a promise. Preparation is therefore not limited to technology. It requires financial, legal, operational, communications, and executive decision-making before the crisis occurs.

2.5 Disruption of Critical Services

An adversary may seek to prevent the institution from operating. For a bank, the target may be payment processing or customer access. For a broker-dealer, it may be order routing, market data, or settlement. For an asset manager, it may be portfolio accounting, valuation, or custody communication. For an exchange, it may be participant access, matching, surveillance, clearing interfaces, or market-data distribution.

The loss is not limited to unavailable technology. A trading outage can leave positions unhedged. A payment outage can create liquidity pressure and missed obligations. A valuation outage can delay reporting and subscriptions or redemptions. An exchange disruption can affect market confidence beyond the institution's own balance sheet. The relevant measure is therefore the condition of the business service and the duration for which obligations cannot be met.

Availability controls should reflect these consequences. Redundancy, alternative providers, manual fallbacks, tested recovery, communication plans, and selective containment may be more important than simply restoring the failed component. The institution must know which minimum service can be maintained safely and which dependencies could cause apparently separate recovery arrangements to fail together.

2.6 Manipulation of Data and Decisions

Data manipulation can be more subtle than theft or disruption. An adversary may seek to alter a price, position, risk limit, beneficiary, reference-data field, model input, client record, or regulatory report. The application can remain available and appear to function correctly while producing financially incorrect results.

This objective makes integrity central. A trusted source must be identifiable, changes must be attributable, and material values should be reconciled independently. Version histories,

digital signatures, approval workflows, immutable logs, and comparison with authoritative sources can reveal whether information changed and whether the change was permitted. Recovery may require more than restoring a file; the institution may need to identify every calculation, report, trade, payment, or client communication that relied on the altered data.

AI systems expand the number of information sources that may influence a decision. An agent can read email, documents, websites, databases, market feeds, and messages from other agents. If it cannot distinguish untrusted content from authorized instruction, manipulated information may influence a financial workflow. The protective principle is that data may inform a decision but should not automatically create authority to act.

2.7 Espionage and Information Advantage

Some adversaries seek information rather than immediate financial action. Client records, transaction plans, investment research, merger discussions, algorithms, risk positions, credentials, and internal communications may have strategic or market value. The loss may remain invisible while the information is used elsewhere.

Confidentiality controls must therefore consider both access and aggregation. A user may have legitimate access to individual records while an unusual volume, combination, or export pattern creates risk. Monitoring should relate access to role, purpose, time, device, and business context. Data minimization and segmentation reduce the amount of information reachable through one identity or system.

AI can increase the value of stolen or exposed information by making large collections easier to summarize, classify, translate, and connect. It may also allow an adversary to personalize later social engineering. The defensive response includes limiting unnecessary retention, controlling bulk access, monitoring agent retrieval, and ensuring that an analytical system cannot silently expand its data scope beyond the approved task.

2.8 Unauthorized Authority as the Common Objective

Theft, fraud, manipulation, and disruption share a common requirement: the adversary needs authority. That authority may come from a compromised human identity, a machine account, an application flaw, an excessive vendor connection, a manipulated agent, or a trusted process that accepts false information. The name of the technical method matters less to management than the authority it creates.

$$\text{Potential Loss} \approx \text{Unauthorized Authority} \times \text{Business Criticality} \times \text{Time Before Containment.} \quad (2.2)$$

This relationship explains why least privilege and segregation of duties are powerful. They do not assume that every initial barrier will succeed. They constrain what can happen after one barrier fails. Short-lived credentials, transaction limits, independent approvals, restricted tools, and rapid revocation further reduce the duration and reach of unauthorized authority.

The principle applies equally to AI. A model that can produce a persuasive paragraph has limited direct authority. An agent that can read confidential information, change files, call payment interfaces, or administer infrastructure has operational power. Governance should focus on the complete system and should ensure that capability is not confused with permission.

2.9 Third Parties and Supply Chains

An adversary may pursue an institution through a vendor, software component, cloud service, data provider, or other trusted dependency. This approach is attractive because one provider may connect to many customers, and because institutional controls may treat established vendor channels as inherently trustworthy.

Third-party risk is not transferred merely because a contract exists. The institution remains responsible for the financial service. It should understand the provider's access, subcontractors, software dependencies, incident-notification duties, recovery capabilities, concentration, and exit arrangements. Access should be limited to the required service, and vendor identities should not acquire broad standing privileges simply for operational convenience.

AI increases the importance of this analysis. Multiple business units may rely on one model provider, orchestration platform, vector database, or cloud environment. A change in model behavior, availability, data-handling policy, or safety control can affect several internal processes at once. The threat is not necessarily malicious compromise; concentration and uncontrolled change can produce similar operational consequences.

2.10 How AI Changes Attacker Economics

AI can lower the cost of some adversarial work by accelerating research, software analysis, document processing, personalization, and repeated decision making. Tool-using agents can preserve state and perform bounded tasks without continuous human attention. Coordinated systems can distribute work among specialized components and evaluate whether another iteration is required. Public evaluations of frontier systems increasingly examine longer autonomous cybersecurity tasks, which makes capability progress an operational assumption rather than a distant speculation.¹

The principal changes are speed, scale, persistence, parallelism, and adaptation. A faster adversary shortens the time available for remediation. A scalable adversary can examine more assets or contact more people. A persistent agent can continue through repeated failures. Parallel agents can explore several hypotheses at once. Adaptive systems can revise an approach when an initial attempt does not produce the intended result.

These effects should not be exaggerated. Real institutions remain complex, access remains constrained, and automated systems make errors. AI does not eliminate the need for knowledge, infrastructure, opportunity, or authority. It changes the productivity of some tasks and

¹<https://www.aisi.gov.uk/blog/how-fast-is-autonomous-ai-cyber-capability-advancing>

therefore changes the assumptions used in detection, vulnerability management, staffing, and incident response.

2.11 AI-Enabled Social Engineering

Social engineering attempts to influence a person or system into granting trust or authority. AI can improve fluency, translation, personalization, and persistence. A message may incorporate public information, imitate an expected tone, or adapt to a recipient's response. The key control cannot be an employee's ability to identify awkward writing. Important instructions must be verified through a process that remains reliable even when the message appears convincing.

For payments, beneficiary changes, sensitive data releases, privileged access, and urgent executive requests, independent verification should be required by design. Employees should have a clear way to pause a request without being penalized for delay. AI agents that read messages or documents need similar boundaries. Untrusted content should not be able to override the agent's approved purpose or authorize a tool call.

The most robust defense is institutional rather than psychological. A persuasive message should still encounter transaction limits, segregation of duties, approved channels, provenance checks, and independent approval. The objective is to prevent persuasion from becoming unilateral economic authority.

2.12 Agentic and Coordinated Activity

An agentic system can observe, plan, use a tool, inspect the result, revise its approach, and continue. A multi-agent system can distribute research, coding, retrieval, and evaluation across specialized components. The cyber significance lies less in a mysterious form of intelligence than in operational continuity and scale.

Defenders may observe this activity as a series of ordinary events: a document retrieval, an identity query, a code action, a database request, or a workflow attempt. Correlation becomes essential because no single event may reveal the objective. Monitoring should connect actions across identities, tools, time, and business services. Agent identities should be distinct, tool permissions narrow, and action histories preserved outside the agent's control.

The same architecture can strengthen defense. Defensive agents can collect context, summarize evidence, identify relationships, and test remediation in isolation. The governance question is symmetrical: which tools are available, what authority exists, how long can the system operate, and what independently limits mistakes?

2.13 Financial Interpretation

Management should interpret a threat through four questions. What outcome does the actor seek? Which authority or trust relationship is required? Which financial process would be

affected? Which control prevents the technical event from becoming an economic loss? These questions create a stable analytical method even as technologies and model capabilities change.

A strong response does not rely on recognizing a particular adversary or predicting every method. It limits authority, preserves evidence, monitors critical processes, and prepares recovery. The institution should be able to withstand the failure of one identity, model, vendor, control, or data source without allowing that failure to become catastrophic.

2.14 Mini Case: The Treasury Instruction

A fictional bank receives an urgent instruction that appears to come from a senior treasury executive. The message requests a change to an internal transfer and includes language consistent with current market conditions. An AI-supported assistant classifies the request as plausible and prepares the transfer for approval. Shortly afterward, the security platform reports an unusual login associated with the executive's account.

The institution should not conclude immediately that the instruction is fraudulent, but it should recognize that the combination creates material uncertainty. The correct response verifies the executive through an independent channel, restricts beneficiary or routing changes, preserves the message and authentication evidence, examines the assistant's inputs and tool calls, and determines whether similar instructions were processed. The payment workflow should remain subject to deterministic limits and dual authorization regardless of how convincing the message or the AI assessment appears.

The case illustrates the central lesson: the adversary's objective is not to write a persuasive message. It is to acquire enough trusted authority to move value. The control architecture should ensure that persuasion alone cannot achieve that objective.

2.15 Safe Notebook Lab

Safe Notebook Lab

The companion notebook should use synthetic events to connect observable activity with possible adversary objectives. Students can compare a failed login, an unusual file change, a beneficiary update, a burst of document retrieval, and an anomalous agent tool call. Transparent logic should show that the same event may support several hypotheses and that business context changes severity. A final exercise should compare a human-only workflow, an AI-assisted workflow, and an agentic workflow with independently enforced permissions and limits. No real target, credential, account, or external system may be used.

2.16 Chapter Summary

Attackers pursue outcomes rather than tools. Their objectives may include theft, fraud, extortion, disruption, manipulation, espionage, and strategic leverage, but most require some

form of unauthorized authority. Financial institutions reduce risk by limiting that authority, separating duties, verifying important instructions independently, monitoring critical services, and preparing trusted recovery.

AI changes the productivity and coordination of adversarial work while also strengthening defense. It can increase speed, scale, persistence, personalization, and parallelism, and it can create new attack surfaces when agents consume untrusted information or receive broad tool access. The relevant unit of risk is the complete system: model, data, memory, tools, autonomy, permissions, dependencies, and controls.

2.17 Review Questions

1. Why is the adversary's objective more useful to management than the name of an attack tool?
2. How does segregation of duties reduce the severity of payment theft?
3. Why can data manipulation be more difficult to recognize than service disruption?
4. What is the relationship between trust and fraud?
5. How does operational resilience reduce an extortionist's leverage?
6. Why should third-party access be treated as institutional authority?
7. How can AI change the speed, scale, persistence, and personalization of adversarial work?
8. Why should untrusted content not automatically create authority for an AI agent?
9. What evidence would help determine whether several ordinary events form one coordinated campaign?
10. In the treasury case, which controls matter even if the message appears genuine?

Chapter 3

What a Defensive Platform Actually Sees

Learning Objectives

By the end of this chapter, the reader should be able to: distinguish raw telemetry, events, alerts, cases, and confirmed incidents; explain why cybersecurity is fundamentally a problem of inference under uncertainty; understand how financial institutions use context, correlation, and thresholds to detect suspicious activity; explain the costs of false positives and false negatives in a financial operating environment; assess how frontier AI models, autonomous agents, and coordinated agentic teams change both the threat environment and the defensive architecture; and identify the governance controls required when AI systems themselves become users of institutional tools, data, and workflows.

3.1 The Defender Does Not See “The Hacker”

One of the most useful ideas in cybersecurity is also one of the simplest: a defensive platform does not normally see a hacker. It sees traces.

Those traces may include a failed login, an unusual request, a change to a file, an unexpected process, a new device, a large data transfer, an unfamiliar sequence of commands, or a transaction that violates a control. The defender must decide what those observations mean.

This is highly familiar territory for finance students. Financial markets are also environments in which decisions are made from incomplete information. A risk manager does not directly observe “future loss.” The manager observes positions, prices, correlations, counterparties, volatilities, and liquidity conditions. A compliance team does not directly observe “market abuse.” It observes orders, cancellations, executions, account relationships, timing, and patterns. A credit officer does not directly observe “default.” The officer observes leverage, cash flows, collateral, payment behavior, and changing conditions.

Cybersecurity is similar:

$$\text{Observed Evidence} + \text{Context} + \text{Rules} + \text{Judgment} \rightarrow \text{Security Decision.} \quad (3.1)$$

The practical implication is important. Cybersecurity is not principally about recognizing an evil-looking action. Many suspicious events are individually ordinary. A failed login is common. A file change may be legitimate. A connection to a new service may be expected. What matters is the combination of events, the identity involved, the asset affected, the timing, the normal baseline, and the business consequence.

For financial institutions, this means that cyber detection and operational-risk management should be connected. A security platform may identify an unusual authentication event, but the financial significance depends on what the identity can do. An anomaly involving a public website may be low priority. The same anomaly involving the account that can approve a \$100 million payment is entirely different.

3.2 From Raw Telemetry to Business Evidence

Modern systems generate enormous amounts of telemetry. A financial institution may collect records from:

identity and authentication systems; employee laptops and servers; cloud environments; trading platforms; payment systems; databases; network infrastructure; email and collaboration platforms; market-data systems; vendor connections; application programming interfaces; and AI agents and automated workflows.

Raw telemetry is simply machine-generated evidence. It becomes useful only when it is normalized and interpreted.

A basic security event may contain:

$$e_t = (\text{time, source, identity, action, target, result, context}). \quad (3.2)$$

For example:

At 09:14:22, identity `portfolio_admin` attempted to access the valuation database from device D-172. Authentication succeeded.

That record does not say whether the activity was good or bad. To evaluate it, the defensive platform needs context.

Was D-172 the administrator's normal device? Was the login performed during normal working hours? Was multifactor authentication completed? Did the user normally access the valuation database? Was the account supposed to be active? What happened immediately afterward?

The central progression is therefore:

$$\text{Telemetry} \rightarrow \text{Event} \rightarrow \text{Enrichment} \rightarrow \text{Pattern} \rightarrow \text{Alert} \rightarrow \text{Investigation}. \quad (3.3)$$

3.3 Events Are Not Alerts

An event records an occurrence. An alert represents a judgment.

Suppose a fictional brokerage records one failed login by a trader. The appropriate output is usually an event, not an incident.

Now suppose the platform sees:

1. ten failed logins;
2. from a device never previously associated with the trader;
3. outside the trader's normal working hours;
4. followed by a successful login;
5. followed by a request to modify a trading limit.

The significance comes from correlation.

A simplified alert function can be written as:

$$A_t = f(E_{t-k:t}, C_t, B_t, R), \quad (3.4)$$

where $E_{t-k:t}$ is the recent sequence of events, C_t is contextual information, B_t is the expected behavioral baseline, and R is the set of detection rules.

This is not unlike financial surveillance. A single order cancellation is ordinary. Thousands of cancellations concentrated around particular market conditions may deserve investigation. The surveillance system evaluates a pattern rather than a single observation.

3.4 Financial Context Changes the Meaning of an Alert

A mature defensive platform does not treat every system equally. The meaning of an event depends on business criticality.

Consider three successful logins:

1. a login to a public marketing-content system;
2. a login to an internal research repository;
3. a login to a privileged payment-approval console.

Technically, all three events may be represented as successful authentications. Economically, they are not equivalent.

A useful conceptual risk score is:

$$S_t = P_t \times I_t \times C_t, \quad (3.5)$$

where P_t represents the estimated probability that the activity is unauthorized, I_t represents the impact of misuse, and C_t represents contextual criticality.

The exact formula is not important. The key idea is that detection should reflect business consequence.

For a bank, identities attached to payment approval, treasury, privileged administration, customer data, or regulatory reporting should normally receive greater scrutiny than low-impact identities.

For an exchange, the most sensitive systems may include participant authentication, order routing, matching, market-data distribution, surveillance, and clearing interfaces.

For an asset manager, the critical points may include portfolio accounting, pricing, risk data, trade instructions, custody interfaces, and investor information.

Cybersecurity becomes much more useful to management when alerts are linked to these business processes.

3.5 False Positives and False Negatives

Every detection system faces two kinds of error.

A **false positive** occurs when benign activity is classified as suspicious.

A **false negative** occurs when genuinely dangerous activity is not detected.

This trade-off is familiar in finance. A credit model that rejects too many good borrowers creates an opportunity cost. A model that approves too many bad borrowers creates credit losses. A market-surveillance system that produces thousands of irrelevant alerts overwhelms investigators; one that is too permissive may miss misconduct.

Cybersecurity has the same problem.

Let:

$$C_{FP}$$

represent the cost of a false positive and

$$C_{FN}$$

the expected cost of a false negative.

A simplified decision objective is:

$$\min [P(FP)C_{FP} + P(FN)C_{FN}] . \quad (3.6)$$

In financial institutions, C_{FP} can be material. An automated rule that freezes legitimate payment activity may create client harm or liquidity problems. A control that disables a trader during market stress may create unmanaged exposure.

But C_{FN} can be much larger. Missing unauthorized access to a payment system, market infrastructure, or client database can generate substantial loss.

This is why high-quality cyber defense cannot depend on one crude threshold. Detection requires context, escalation rules, human judgment, and increasingly AI-assisted interpretation.

3.6 From Alert to Case to Incident

Organizations should distinguish several levels of security interpretation.

Event: something observable occurred.

Alert: a rule or analytical system identified activity deserving attention.

Case: analysts grouped related evidence for investigation.

Incident: the institution concluded that the event represents a sufficiently credible or material security problem requiring coordinated response.

The distinction matters because financial institutions need disciplined escalation.

If every alert is called an incident, management becomes desensitized. If serious alerts remain at the analyst level for too long, response may be delayed.

A good escalation process asks:

Which critical business service is affected? Is unauthorized access confirmed or merely suspected? Has any financial action occurred? Is data integrity in question? Is the event continuing? Could counterparties or clients be affected? Is regulatory or legal escalation required?

3.7 The AI Threat Lens: Why the Defensive Problem Is Changing

From this chapter onward, every chapter in this book should consider an additional dimension: artificial intelligence is changing the economics, speed, persistence, and scale of cyber activity.

The important development is not merely that a language model can answer cybersecurity questions. The deeper change is the emergence of **agentic systems**: models connected to tools, memory, software environments, data stores, and other agents.

A conventional chatbot answers a prompt.

An autonomous agent can potentially:

$$\text{Observe} \rightarrow \text{Plan} \rightarrow \text{Act} \rightarrow \text{Check} \rightarrow \text{Revise} \rightarrow \text{Continue}. \quad (3.7)$$

A team of agents can distribute the work:

$$\text{Planner} + \text{Researcher} + \text{Coder} + \text{Evaluator} + \text{Coordinator}. \quad (3.8)$$

The financial-risk significance is enormous. Historically, many forms of sophisticated cyber activity were constrained by scarce human expertise and attention. A human operator could investigate only a limited number of systems simultaneously. Autonomous agentic systems can lower the cost of experimentation and increase parallelism.

This does not mean that AI automatically defeats modern security. It means that the operational economics are changing.

3.8 Frontier Models and the Cyber Capability Frontier

By 2026, this issue is no longer theoretical.

OpenAI describes GPT-5.6 as its strongest model for accelerating AI research and reports that it is used internally across activities including diagnosis, optimization, experimentation, and interpretation. The GPT-5.6 family also includes a frontier model, GPT-5.6 Sol, designed for complex professional work.

Anthropic’s Claude Mythos line provides an even more explicit cybersecurity example. Anthropic introduced Mythos Preview in April 2026 as a general-purpose model with unusually strong computer-security capabilities and restricted its deployment while using it through Project Glasswing to help identify weaknesses in critical software. The UK AI Security Institute independently described Mythos Preview as a substantial step up from previous frontier models in cybersecurity evaluations. Mythos 5 has subsequently remained restricted to vetted partners because of its capability profile.

The lesson for financial institutions is not that one specific model is uniquely dangerous. Model names will change quickly. The relevant structural trend is:

$$\text{Model Capability} \times \text{Tool Access} \times \text{Autonomy} \times \text{Parallelism} = \text{Potential Operational Power.} \quad (3.9)$$

A moderately capable model with extensive tools and persistent autonomy may create more operational risk than a stronger model confined to a text box.

3.9 Why Agentic Teams Matter More Than a Single Model

The most important unit of analysis may therefore be the **system**, not the model.

Imagine five harmless administrative agents inside a financial institution:

one reads email; one retrieves documents; one generates code; one accesses a database; and one can initiate workflow actions.

Each agent may individually appear safe. Yet if they share memory, permissions, and goals, the combined system can perform complex sequences without continuous human review.

The same principle applies externally. Coordinated AI agents can divide analysis, maintain state, retry failed approaches, compare results, and operate for long periods.

This creates a major change in threat modeling:

Core Intuition

The cyber-risk question is no longer only “What can this model say?” It becomes “What can this agentic system observe, decide, access, coordinate, and execute?”

For financial firms, this is directly analogous to segregation of duties. We would not ordinarily allow one junior employee to read every confidential file, modify production code, approve payments, and disable controls. Yet poorly designed AI architectures can accidentally

combine equivalent capabilities.

3.10 AI Changes the Speed of Detection as Well as Attack

The AI story is not purely negative.

The same models that can accelerate code analysis can also strengthen defense.

Defensive AI agents can:

summarize large volumes of alerts; correlate events across systems; identify unusual identity behavior; explain why a pattern may be suspicious; prioritize incidents by business impact; compare observed activity with known controls; help analysts reconstruct timelines; assist with remediation planning; and continuously review configurations and code.

This creates the possibility of an emerging contest:

$$\text{Agentic Offense} \quad \text{versus} \quad \text{Agentic Defense.} \quad (3.10)$$

For a financial institution, the objective should not be to build an unconstrained autonomous defender. A defensive agent with excessive permissions can itself become a source of operational risk.

The correct architecture is governed autonomy.

3.11 The New Defensive Platform: Humans Plus Agents

A future security operations center may consist of both humans and AI agents.

A simple architecture could be:

$$\begin{aligned} &\text{Telemetry} \rightarrow \text{Deterministic Controls} \rightarrow \text{AI Triage} \\ &\rightarrow \text{Human or Governed Agent Decision} \rightarrow \text{Response.} \end{aligned} \quad (3.11)$$

Deterministic controls remain important because some decisions should be predictable. For example, a payment exceeding an approved limit should not depend on whether an AI model “feels” that the transaction is unusual.

AI is most valuable where interpretation is complex: correlating evidence, summarizing context, identifying relationships, and helping humans investigate.

The architecture should preserve clear boundaries:

agents should have minimum necessary permissions; sensitive actions should require explicit authorization; every agent action should be logged; tool access should be restricted by role; memory should be scoped and protected; high-impact actions should require independent verification; autonomous behavior should have time, cost, and action limits; and agents should be interruptible.

These controls are the AI equivalent of familiar financial controls.

3.12 A New Form of Model Risk

Finance students should recognize another connection: agentic AI introduces a form of model risk.

Traditional model risk asks whether a model is conceptually sound, correctly implemented, appropriately validated, and used within its intended scope.

Agentic systems add a new dimension because the model may take actions.

The risk becomes:

$$R_{\text{agent}} = f(\text{model error, tool permissions, autonomy, memory, environment, oversight}). \quad (3.12)$$

A hallucinated paragraph is inconvenient.

A hallucinated payment instruction executed by an agent can be a financial loss.

A mistaken coding suggestion reviewed by an engineer is manageable.

A mistaken coding action deployed autonomously into production can be an operational incident.

Therefore, the governance of AI agents should be proportional to the consequence of their actions.

3.13 Mini Case: An Agentic Treasury Assistant

Consider a fictional international bank that deploys an AI treasury assistant.

The agent can:

1. read cash-balance reports;
2. retrieve payment instructions;
3. summarize liquidity needs;
4. prepare proposed transfers;
5. submit transfers for human approval.

The system is initially safe because the agent cannot approve or release payments.

Now management proposes an efficiency improvement. The agent will be allowed to execute transfers below \$250,000 automatically.

The change appears small, but the risk architecture changes fundamentally.

The agent is no longer purely analytical. It now has economic agency.

Management should ask:

Can the agent's instructions be manipulated by external content? Which accounts can it access? What is the maximum daily aggregate amount it can transfer? Can it create new beneficiaries? Can one agent override another control? Are actions logged independently? Can the system be stopped immediately? What happens if the model behaves unpredictably?

This is cybersecurity, operational risk, model risk, and payment governance simultaneously.

Finance and Operational-Risk Lens

As AI becomes agentic, the relevant exposure is not simply model intelligence. The key quantity is the product of capability and authority. A highly capable model with no tools may create limited direct operational risk. A moderately capable agent with broad permissions can create substantial financial exposure.

3.14 Safe Notebook Lab

Safe Notebook Lab

The companion notebook for this chapter should model a miniature defensive platform using only synthetic events.

Students should create:

1. normal login events;
2. repeated failed authentication events;
3. unusual access to a fictional sensitive system;
4. an unexpected synthetic file change;
5. deterministic alert rules;
6. an AI-style triage layer represented by transparent scoring or classification logic;
7. a final human decision stage.

A second exercise can represent three fictional defensive agents—Identity Agent, Data Integrity Agent, and Risk Agent—that exchange only synthetic summaries and produce a consolidated case.

The notebook must not give the agents external network access, real credentials, shell control, autonomous exploitation capability, or permission to act on real systems.

3.15 A Pragmatic Framework for Financial Institutions

When a financial institution evaluates a defensive platform in the age of AI, management should ask seven questions:

1. **What evidence does the platform actually observe?**
2. **Which business context is attached to that evidence?**
3. **How does the system distinguish events from alerts and incidents?**

4. **What are the expected costs of false positives and false negatives?**
5. **Which decisions are deterministic, which are AI-assisted, and which require humans?**
6. **What tools and permissions do defensive agents possess?**
7. **How can the institution stop, audit, and recover from an agent that behaves incorrectly?**

These questions will become increasingly important as financial institutions move from conventional automation to autonomous systems.

3.16 Chapter Summary

The central lessons of this chapter are:

1. Defensive platforms observe evidence, not intentions. Cybersecurity is therefore a problem of inference under uncertainty.
2. Raw telemetry becomes useful only when it is normalized, enriched with business context, correlated, and interpreted.
3. An event, an alert, a case, and an incident are different levels of institutional judgment.
4. Financial criticality changes the meaning of a technical event. The same login pattern can have radically different significance depending on the permissions and systems involved.
5. Detection systems must manage the trade-off between false positives and false negatives.
6. Frontier AI models and agentic systems are changing the economics of cybersecurity by increasing automation, persistence, and parallelism.
7. The key AI risk variable is not model capability alone but capability combined with tools, permissions, autonomy, memory, and coordination.
8. AI can also strengthen defense, particularly in triage, correlation, interpretation, and remediation.
9. Defensive AI agents must themselves be governed as operational actors.
10. For financial institutions, agentic AI increasingly merges cybersecurity risk, model risk, operational risk, and governance risk.

3.17 Review Questions

1. Why is cybersecurity described in this chapter as a problem of inference under uncertainty?
2. What is the difference between telemetry, an event, an alert, a case, and an incident?
3. Why should business criticality influence alert severity?
4. Give one example of a false positive that could create financial harm.
5. Give one example of a false negative that could create financial harm.
6. Why can an agentic system be more consequential than the underlying language model considered in isolation?
7. What does the expression “capability times authority” mean in the context of AI agents?
8. How can AI improve a security operations center without being permitted to take high-impact autonomous actions?
9. Why should AI agent permissions be analyzed in a way similar to segregation of duties in finance?
10. In the treasury-assistant case, which control changes would you require before allowing autonomous transfers?

Chapter 4

Identity, Passwords, and Access Risk in the Age of Agentic AI

Learning Objectives

By the end of this chapter, the reader should be able to: distinguish authentication, authorization, and accounting in financial institutions; explain why identity is one of the most important control layers in modern financial systems; understand password, session, privilege, and service-account risk without relying on offensive techniques; evaluate multifactor authentication, least privilege, segregation of duties, and privileged-access controls; describe, at a safe and non-operational level, the AI models, agentic architectures, and automation strategies that may increase identity-related cyber threats; explain why AI agents themselves must be governed as institutional identities with limited authority; and connect identity compromise to payments, trading, asset management, treasury, custody, and financial-market infrastructure.

4.1 Identity Is a Financial Control

A financial institution is full of decisions that depend on identity.

Who may enter an order? Who may change a risk limit? Who may release a payment? Who may access client data? Who may modify a pricing source? Who may deploy software? Who may approve a model change? Who may instruct a custodian?

In each case, the institution must answer three questions:

Who are you? What may you do? What evidence remains? (4.1)

These correspond to three classical control concepts:

Authentication: establishing the identity of the user or system; **Authorization:** determining which actions that identity is permitted to perform; and **Accounting or auditability:** recording what the identity actually did.

For finance students, this should feel familiar. Financial businesses already depend on authority structures. A junior trader and the head of trading do not have the same limits. A

payment preparer and payment approver should not have identical authority. An analyst who prepares a valuation should not necessarily have the authority to approve the final NAV. A portfolio manager may propose a transaction, while operations personnel confirm and settle it.

Cybersecurity extends these control principles into digital systems.

The central risk is not simply that an unauthorized person obtains a password. The real risk is that the institution mistakenly grants authority to someone or something that should not possess it.

Core Intuition

Identity risk is the risk that a financial institution assigns trust, authority, or access to the wrong human, device, service, or autonomous agent.

4.2 Authentication Is Not Authorization

Authentication and authorization are often confused.

Suppose Alice successfully logs into a portfolio-management system. Authentication answers:

Is this really Alice?

Authorization answers:

Even if this is Alice, is Alice permitted to change the portfolio's benchmark, export the complete client list, or modify settlement instructions?

A secure financial system needs both.

Strong authentication combined with excessive authorization remains dangerous. If a legitimate employee has far more permissions than required, the institution has created unnecessary operational risk. The account may be misused intentionally, compromised externally, or used incorrectly by accident.

Conversely, perfect authorization rules are useless if authentication is weak. The system may have carefully designed roles, but if an unauthorized actor can impersonate a highly privileged user, those roles no longer protect the institution.

A useful conceptual decomposition is:

$$R_{\text{identity}} = P(\text{identity misuse}) \times I(\text{authority attached to identity}). \quad (4.2)$$

The second term is frequently underestimated.

A compromised account that can read a public research archive is different from a compromised account that can release treasury payments.

4.3 Why Passwords Became a Weak Control

Passwords are historically convenient because they allow a person to prove knowledge of a secret. But passwords have several structural weaknesses.

Users may choose weak secrets. They may reuse the same password across services. They may reveal it accidentally. A password may be exposed in a breach at another organization. Users may respond to convincing fraudulent messages. Shared passwords may become impossible to attribute to one person.

Finance professionals do not need to know how password attacks are technically executed. They need to understand why a password alone may provide insufficient assurance for high-impact actions.

The weakness becomes particularly important when the same identity has broad economic authority.

Consider a treasury employee whose account can prepare a payment. If the account is protected only by a password, the institution is making a strong assumption: knowledge of one string is sufficient evidence that a high-value financial action comes from the correct human.

That is a weak governance proposition.

4.4 Multifactor Authentication

Multifactor authentication improves assurance by requiring more than one type of evidence.

The usual categories are:

something the user knows; something the user possesses; and something the user is.

The objective is not to make authentication inconvenient. It is to make one failure insufficient.

For a financial institution, multifactor authentication should be especially important for: privileged administrator accounts; payment and treasury systems; remote access; cloud administration; sensitive client data; production software deployment; trading administration; and critical vendor interfaces.

However, multifactor authentication is not a complete solution. An authenticated session can still be misused. A user can authorize the wrong action. A malicious process may operate inside an already authenticated environment. A poorly designed recovery procedure may bypass the stronger control.

This is why identity defense requires a chain of controls rather than one mechanism.

4.5 Least Privilege

The principle of least privilege says that an identity should possess only the authority required to perform its legitimate function.

This principle has a direct analogue in financial control.

A trader may need authority to enter orders within defined limits but not to change the limits themselves.

An operations employee may need to prepare a payment but not approve it.

A valuation analyst may need access to pricing data but not the ability to alter production source files.

An AI research assistant may need read access to research documents but not permission to submit trades.

Least privilege reduces the impact of identity compromise.

If an account is compromised but its permissions are narrow, the potential damage remains constrained.

$$\text{Compromise} \times \text{Limited Authority} \rightarrow \text{Limited Loss Potential.} \quad (4.3)$$

The reverse is equally important:

$$\text{Compromise} \times \text{Broad Authority} \rightarrow \text{Potentially Large Loss.} \quad (4.4)$$

4.6 Segregation of Duties

Segregation of duties prevents one identity from controlling an entire high-risk process.

A classic financial example is payment processing:

$$\text{Prepare} \neq \text{Approve} \neq \text{Release.} \quad (4.5)$$

The same principle applies to cybersecurity and AI.

A developer who writes production code should not necessarily have unilateral authority to deploy it.

An employee who creates a new beneficiary should not necessarily be allowed to release a large transfer to that beneficiary.

An AI agent that recommends a trade should not automatically possess the authority to execute it.

Segregation of duties assumes that individual controls can fail. The architecture is designed so that one failure does not automatically create the final adverse outcome.

4.7 Privileged Identities

Some accounts deserve special treatment because they can change the environment itself.

Privileged identities may be able to:

create or delete users; change permissions; access confidential databases; modify system configuration; disable monitoring; deploy software; access backups; and alter security controls.

In a financial institution, privileged-access management should therefore be viewed as a concentration-risk problem.

If one identity can modify many critical systems, the institution has concentrated operational power.

The control response may include stronger authentication, temporary privilege elevation, independent approval, continuous monitoring, session recording, and rapid revocation.

4.8 Machine Identities and Service Accounts

Not every identity represents a human.

Financial institutions use service accounts, application identities, API credentials, software certificates, automated jobs, and machine-to-machine permissions.

These identities can be extremely powerful because they operate continuously and may have broad access.

Historically, organizations often gave less attention to machine identities than human identities. That becomes increasingly dangerous as automation expands.

The arrival of autonomous AI agents makes the issue much more important.

An agent that can read email, query databases, call APIs, edit documents, execute code, or initiate workflows is effectively an institutional user.

It should therefore have an identity.

It should have a role.

It should have permissions.

It should have limits.

It should leave an audit trail.

4.9 The AI Threat Lens: Models Are Becoming Operational Actors

The identity problem changes materially when frontier AI models are connected to tools.

OpenAI's current agent architecture describes agents as systems built from models, tools, state or memory, and orchestration. Its agent tooling also supports handoffs among agents, guardrails, and tracing. Anthropic similarly documents tool-using and managed agent systems in which a model can autonomously invoke approved functions.

This matters because the model is no longer limited to generating text.

A tool-enabled model can potentially:

$$\text{Read} \rightarrow \text{Reason} \rightarrow \text{Select Tool} \rightarrow \text{Act} \rightarrow \text{Observe Result} \rightarrow \text{Continue}. \quad (4.6)$$

The cyber-risk significance depends on what tools are available.

A model with access only to a public research database has limited authority.

A model with access to internal email, file systems, customer information, payment APIs, code repositories, cloud consoles, and administrative systems has much greater operational power.

The relevant unit of risk is therefore not the model alone.

$$R_{\text{AI system}} = f(\text{model capability, tools, permissions, memory, autonomy, coordination}). \quad (4.7)$$

4.10 Frontier Cyber Models

The frontier is moving rapidly.

OpenAI reports that GPT-5.6 is its strongest cybersecurity model to date and that GPT-5.6 Sol extends capability on long-horizon security tasks. OpenAI's deployment safety analysis also states that these models represent a meaningful increase in cybersecurity capability, while not reaching its highest classified cyber-risk level.

Anthropic has taken a similarly cautious approach with the Mythos family. It describes Claude Mythos as a highly capable cybersecurity model and has limited access to vetted partners. Anthropic's research around Mythos Preview reports substantial gains in computer-security tasks and explicitly frames those gains as useful for defensive vulnerability discovery while acknowledging misuse risk.

These examples illustrate a general trend rather than a competition among model brands:

Core Intuition

The amount of expert-level cyber reasoning that can be automated is increasing, and the time required to perform complex analysis is declining.

For financial institutions, this means that historical assumptions about the scarcity of sophisticated attackers may become less reliable.

4.11 Typical AI Models Used in an Attack Architecture

This book will not describe operational attack procedures. It is nevertheless important for risk managers to understand the types of AI components that can appear in a malicious architecture.

A high-level architecture may include several model roles.

Reasoning Model A frontier reasoning model can interpret evidence, maintain a plan, compare alternatives, and revise its approach.

Its risk contribution is persistence and analytical scale.

Coding Model A coding-specialized model can analyze software, generate or modify code, and help automate technical tasks.

Its risk contribution is lowering the cost of software analysis and experimentation.

Vision or Multimodal Model A multimodal model can interpret screenshots, dashboards, interfaces, diagrams, and documents.

Its risk contribution is expanding automation beyond purely text-based environments.

Small Local Model A smaller model may perform repetitive classification, extraction, or coordination tasks cheaply and at scale.

The lesson is important: a threat architecture does not necessarily require the most capable model for every task.

Coordinator Model A coordinating agent can allocate work among specialized agents, maintain shared state, and decide which task should occur next.

Its risk contribution is orchestration.

4.12 Typical Agentic Architectures Used by Threat Actors

At a safe level of abstraction, several architectures are particularly relevant.

Single-Agent Tool Loop The simplest architecture is:

$$\text{Observe} \rightarrow \text{Plan} \rightarrow \text{Tool} \rightarrow \text{Evaluate} \rightarrow \text{Repeat}. \quad (4.8)$$

The model maintains one objective and iteratively uses available tools.

The defensive implication is that malicious activity may become more persistent and less dependent on continuous human attention.

Planner–Executor Architecture One agent creates a plan while another performs constrained tasks.

$$\text{Planner} \rightarrow \text{Executor} \rightarrow \text{Verifier}. \quad (4.9)$$

The verifier checks whether the objective was achieved and sends the task back for revision if necessary.

This structure can increase reliability.

Specialist Agent Team A coordinated team may include:

an information-gathering agent; a software-analysis agent; an identity-analysis agent; a coordinator; and an evaluator.

The risk is not that each specialist is extraordinary. The risk is that parallel agents can divide work and maintain persistent attention.

Hierarchical Agent Architecture A supervisory agent may manage many lower-level agents.

$$\text{Supervisor} \rightarrow \{A_1, A_2, \dots, A_n\} \rightarrow \text{Aggregated Result}. \quad (4.10)$$

This creates scale.

Memory-Augmented Agent An agent can preserve findings, previous attempts, system information, and workflow lessons across many iterations.

Memory reduces repeated work.

For defenders, this means that an automated adversary may accumulate context over time rather than beginning every interaction from zero.

4.13 Typical AI-Enabled Threat Strategies

Again, the purpose here is threat recognition rather than operational instruction.

The important strategies include:

Automation of Repetitive Investigation AI can reduce the human effort required to analyze large numbers of systems, configurations, messages, or code artifacts.

The strategic effect is scale.

Adaptive Decision-Making Instead of following a rigid script, an agentic system can evaluate outcomes and change its next action.

The strategic effect is adaptability.

Parallelization Multiple agents can work simultaneously.

The strategic effect is lower marginal cost per target or task.

Persistent Operation Agents can continue working for extended periods without normal human attention limits.

The strategic effect is endurance.

Personalization AI can analyze available context and produce more tailored messages, requests, or interactions.

For financial institutions, this increases the importance of independent verification procedures.

Tool Chaining The greatest risk often comes from combining several legitimate capabilities.

A model may read information with one tool, transform it with another, and initiate a workflow with a third.

The individual tools may all be legitimate. The risk emerges from the sequence.

4.14 Identity Attacks in an Agentic World

AI changes the identity threat in three ways.

First, attackers may automate the analysis of organizational identities and relationships.

Second, AI can make fraudulent communications more context-aware, linguistically convincing, and persistent.

Third, compromised legitimate identities may themselves be used by autonomous systems.

This makes identity assurance more important, not less.

A financial institution should increasingly assume that a convincing email, voice message, document, or chat interaction is not sufficient proof of identity.

Independent verification matters.

4.15 The New Control: Agent Identity

Financial institutions increasingly need an explicit concept of **agent identity**.

An autonomous agent should not inherit the full authority of the human who created it. Instead:

$$\text{Human Identity} \neq \text{Agent Identity.} \quad (4.11)$$

The institution should be able to answer:

Which agent performed the action? Which human or business function owns the agent? Which model powers it? Which tools can it call? Which data can it read? Which actions can it execute? What monetary or operational limits apply? When does its authorization expire? Can its authority be revoked immediately?

This is the agentic equivalent of access governance.

4.16 A Finance Example: Autonomous Treasury

Suppose a financial institution deploys an autonomous treasury agent.

The initial version can read cash balances, forecast liquidity, and propose transfers.

This is a decision-support system.

Management then adds the ability to submit transfer instructions.

The agent has become an operational actor.

Later, management considers allowing automatic execution below a threshold.

At that point, the agent possesses economic authority.

A sound control structure could separate:

$$\begin{aligned} &\text{Forecast Agent} \rightarrow \text{Recommendation Agent} \\ &\rightarrow \text{Payment Preparation} \rightarrow \text{Independent Approval.} \end{aligned} \quad (4.12)$$

The institution should be cautious about collapsing these functions into one autonomous identity.

Finance and Operational-Risk Lens

The central financial principle is the same whether the actor is human or artificial: authority should be proportional to need, economically bounded, independently observable, and revocable.

4.17 A Trading Example: The Autonomous Research Agent

Consider an investment manager using an AI research agent.

The agent can read filings, internal research, portfolio information, and market data.

That architecture already raises confidentiality questions.

Suppose the agent is later permitted to generate trade recommendations.

The risk increases, but the agent still has no execution authority.

Suppose it is finally connected directly to an order-management system.

The architecture has crossed a major governance boundary.

The institution must now consider:

position limits; instrument restrictions; pre-trade risk checks; human approval thresholds; model drift; prompt or context manipulation; kill switches; independent trade surveillance; and complete action logs.

The relevant principle is not “never use autonomous agents.” It is “never confuse analytical capability with authorized economic authority.”

4.18 Defensive Strategies for the AI Identity Era

The defensive response should combine conventional identity controls with agent-specific governance.

A pragmatic architecture includes:

1. strong human authentication;
2. unique identities for agents and services;
3. least privilege;
4. short-lived credentials where possible;
5. segregation of duties;
6. transaction and action limits;
7. independent logging;
8. continuous behavioral monitoring;
9. explicit approval for high-impact actions;
10. immediate revocation capability.

Financial institutions should also avoid embedding long-lived credentials directly into AI prompts, code, notebooks, or agent memory.

The distinction between reasoning state and secret material should be explicit.

4.19 Mini Case: The Autonomous Payment Assistant

A fictional bank deploys an AI payment assistant.

Phase 1 allows the agent to read payment requests and classify them.

Phase 2 allows it to prepare payments for human approval.

Phase 3 allows it to release payments below \$50,000.

At Phase 1, the principal risks concern confidentiality and classification error.

At Phase 2, authorization risk increases because the agent can create actionable financial instructions.

At Phase 3, the agent can directly create financial loss.

The bank should therefore reassess the control architecture at every phase.

The appropriate questions include:

Is the agent represented by a unique machine identity? Are its privileges different from those of its human owner? Can it create new beneficiaries? Is the \$50,000 limit per transaction or aggregate? Can many small transfers bypass the economic intent of the limit? Is a second control independent of the agent? Are all actions recorded outside the agent's own environment? Can operations disable the agent immediately?

This is a practical example of cybersecurity, operational risk, model risk, and financial control converging.

4.20 Safe Notebook Lab

Safe Notebook Lab

The companion notebook for this chapter should remain entirely synthetic.

Students can create fictional identities representing:

a trader; a treasury employee; an administrator; a research agent; and a payment agent.

Each identity receives a transparent permission set.

The notebook can then simulate harmless requests such as “read portfolio,” “prepare payment,” or “change limit” and determine whether each identity is authorized.

A second exercise can compare three control architectures:

1. one broad privileged identity;
2. segregated human roles;
3. segregated human and AI-agent identities.

The educational objective is to quantify how authority concentration affects potential loss.

The notebook should not use real credentials, external systems, authentication services, payment APIs, trading APIs, or network scanning.

4.21 A Pragmatic Identity Checklist for Finance Professionals

When evaluating an important financial process, ask:

1. Who can perform the action?
2. How is each identity authenticated?
3. What is the maximum economic authority of each identity?
4. Is approval independent from initiation?
5. Which machine identities and AI agents participate?
6. Are agent permissions narrower than the permissions of their human owners?
7. Can one identity change its own permissions?
8. Are high-impact actions independently logged?
9. How quickly can access be revoked?
10. What happens if the identity is correct but the decision is wrong?

The final question is especially important in the AI era. Authentication can prove that the correct agent performed the action. It does not prove that the action was economically sensible.

4.22 Chapter Summary

The central lessons are:

1. Identity is a financial control because digital identities exercise economic authority.
2. Authentication establishes identity; authorization defines permitted actions; accounting preserves evidence.
3. Passwords alone provide weak assurance for high-impact financial processes.
4. Multifactor authentication, least privilege, segregation of duties, and privileged-access controls reduce the probability and impact of identity misuse.
5. Machine identities are as important as human identities.
6. Autonomous AI agents should be treated as institutional users with unique identities, explicit permissions, limits, ownership, and audit trails.
7. Frontier models such as GPT-5.6-class systems and Anthropic's Mythos family illustrate the rapid increase in automated cybersecurity capability.

8. Typical malicious AI architectures may involve reasoning models, coding models, coordinators, memory, tool loops, planner–executor patterns, and specialist agent teams.
9. AI increases threat scale through automation, adaptability, parallelization, persistence, personalization, and tool chaining.
10. The core control principle remains simple: capability should never imply authority.

4.23 Review Questions

1. What is the difference between authentication and authorization?
2. Why is identity risk fundamentally a financial-control issue?
3. Why does least privilege reduce cyber loss severity?
4. How does segregation of duties protect payment and trading processes?
5. Why should service accounts and machine identities receive the same governance attention as human identities?
6. What additional risks arise when a language model is connected to tools?
7. Describe the difference between a single-agent tool loop and a planner–executor architecture.
8. Why can a multi-agent team create greater operational risk than one model acting alone?
9. What does the statement “capability should never imply authority” mean for an autonomous trading or payment agent?
10. In the payment-assistant case, which controls would you require before allowing any autonomous payment execution?

Chapter 5

Applications, Data, and Integrity Risk in the Age of Agentic AI

Learning Objectives

By the end of this chapter, the reader should be able to: explain why applications and data integrity are financial controls rather than merely technology concerns; distinguish confidentiality, integrity, availability, provenance, and authorization in data-driven financial processes; understand how frontier AI models and autonomous agents expand the attack surface of financial institutions; describe, at a safe and non-operational level, the principal AI-enabled attack strategies relevant to applications, data, and autonomous workflows; explain prompt injection, context manipulation, memory poisoning, tool misuse, data poisoning, and agent-to-agent trust failures without learning offensive implementation techniques; evaluate practical protections based on least privilege, separation of data and authority, deterministic controls, human approval, isolation, provenance, monitoring, and recovery; and connect AI-enabled cyber threats to valuation, trading, payments, risk management, compliance, and financial-market infrastructure.

5.1 Applications Are Financial Decision Systems

A financial application is not simply software. It is a mechanism that transforms information into economically meaningful actions.

A portfolio-accounting system receives positions and prices and produces valuations. A trading system receives orders and produces executions. A payment platform receives instructions and produces transfers of value. A risk engine receives exposures and market data and produces limits, capital measures, and management information. A regulatory-reporting platform transforms internal data into external representations of the institution.

The simplest representation is:

$$\text{Inputs} \rightarrow \text{Application Logic} \rightarrow \text{Decision or Action} \rightarrow \text{Financial Consequence.} \quad (5.1)$$

Cybersecurity becomes economically important whenever an unauthorized actor can alter any part of this chain.

If the application logic is changed, the system may behave incorrectly.

If the inputs are corrupted, a perfectly functioning application may produce a wrong result.

If authorization is weak, the correct application may execute the wrong person's instruction.

If the application becomes unavailable, a legitimate financial process may fail at the moment it is needed.

The first practical lesson is therefore that application security and data integrity belong inside the financial control framework.

Core Intuition

A financial model can be mathematically correct and still produce a dangerous answer if its data, permissions, or operating environment are not trustworthy.

5.2 Integrity Is Often More Important Than Secrecy

Cybersecurity is frequently discussed as protection against information theft. Confidentiality is important, but in many financial businesses integrity can be even more important.

Consider a simple pricing file containing a bond price of 98.25.

If an unauthorized process reads that price, there may or may not be a material confidentiality problem.

If an unauthorized process changes the price to 108.25 and the altered value enters the valuation system, the consequences can be immediate.

The portfolio may be overstated. Risk measures may be distorted. Performance may be misreported. A client may receive an incorrect NAV. Collateral calculations may be wrong. A trade may be executed on a false signal.

For this reason, financial institutions should distinguish:

Confidentiality: who may see the data? **Integrity:** can the institution trust the data? **Availability:** can the institution access the data when required? **Provenance:** where did the data come from? **Authorization:** who may change or act upon the data?

The addition of provenance is increasingly important in the AI era. An autonomous system may process information from email, websites, documents, databases, market feeds, and other agents. The system must distinguish trusted instructions from untrusted content.

5.3 A Simple Integrity Control

A cryptographic hash provides a useful pedagogical example.

Let the trusted content be x_0 . The institution calculates:

$$h_0 = H(x_0). \quad (5.2)$$

Later it calculates:

$$h_1 = H(x_1). \quad (5.3)$$

If:

$$h_0 \neq h_1, \quad (5.4)$$

the content changed.

The hash does not explain why.

The change may have been authorized. It may be accidental. It may be malicious.

This distinction is essential. Cyber controls often detect deviations, not intentions. Governance provides the context required to decide whether the deviation is acceptable.

In financial practice, integrity controls can be complemented by reconciliation, independent data sources, approval workflows, digital signatures, version histories, and audit trails.

5.4 The Traditional Application Threat

Before considering AI, it is useful to understand the conventional application-risk model.

An application receives inputs. Those inputs must be validated. The user must be authenticated. The requested action must be authorized. Sensitive information must be protected. Changes to the application must be controlled. Logs must preserve evidence.

A weakness can therefore occur at several layers:

$$\text{Identity} + \text{Input} + \text{Logic} + \text{Data} + \text{Configuration} + \text{Dependencies}. \quad (5.5)$$

Historically, application-security programs tried to reduce weaknesses through secure development, testing, patching, access control, segmentation, change management, and monitoring.

Those controls remain necessary.

Artificial intelligence does not replace the traditional attack surface.

It adds another one.

5.5 The AI Threat Lens: AI Changes Both Sides of the Application

AI creates two distinct cybersecurity problems.

The first is:

AI makes attackers more capable.

Frontier models can help analyze code, reason about complex systems, automate repetitive work, and sustain long sequences of technical analysis. Current frontier cybersecurity evaluations illustrate substantial progress. OpenAI reports that GPT-5.6 and GPT-5.6 Sol materially

advance cybersecurity performance, while Anthropic has limited access to Mythos-class models because of their unusually strong capabilities in software-security tasks.

The second problem is different:

AI applications can themselves be manipulated.

A conventional application normally distinguishes code from data relatively clearly. An AI agent may consume natural-language content and treat some of that content as information and some as instructions.

This creates a new security boundary.

An autonomous financial agent may read:

email; research reports; financial statements; websites; internal documents; spreadsheets; database records; and messages from other agents.

Some of those sources are trustworthy.

Some are not.

If the agent cannot reliably distinguish information from instructions, external content may influence its behavior.

This is one of the central security problems of agentic AI.

5.6 Prompt Injection: Social Engineering for Machines

OpenAI describes prompt injection as a form of social engineering directed at conversational AI systems. Anthropic similarly identifies prompt injection as a major security challenge for browser-based and tool-using agents.

The concept can be explained safely.

Suppose a financial research agent has the following legitimate objective:

Read public financial information and summarize risks for the portfolio manager.

While reading an external document, the agent encounters text that attempts to persuade it to disregard its intended task and take some unrelated action.

A secure architecture should treat that external text as **data**, not as an authorized instruction.

The risk becomes much greater when the agent has tools.

A chatbot manipulated by external text may produce a bad answer.

A tool-using agent may take a bad action.

This difference can be summarized as:

$$\text{Manipulated Model} + \text{No Authority} \rightarrow \text{Bad Output}, \quad (5.6)$$

while:

$$\text{Manipulated Agent} + \text{Operational Authority} \rightarrow \text{Potential Real-World Loss}. \quad (5.7)$$

For financial institutions, this is a critical distinction.

5.7 Typical AI-Enabled Attack Strategies

The purpose of this section is threat recognition, not offensive instruction. The strategies are described only at the architectural level required for risk management.

1. Prompt and Context Manipulation The attacker attempts to influence the instructions or context processed by an AI system.

The content may arrive through a document, message, website, database record, or another tool.

The strategic objective is to cause the agent to prioritize an unauthorized instruction over its legitimate objective.

The financial risk depends entirely on authority.

A research-only agent may generate a misleading report.

A payment agent may create an unauthorized workflow.

A trading agent may generate or submit an inappropriate order.

The protective principle is to prevent untrusted content from automatically creating trusted authority.

2. Indirect Prompt Injection Indirect prompt injection occurs when adversarial instructions are embedded in content that the agent retrieves while performing another task.

This is especially important for agents that browse external information, review email, process uploaded files, or read third-party data.

A portfolio-research agent is exposed because it necessarily consumes external material.

A customer-service agent is exposed because it reads customer messages.

A treasury agent may be exposed if it processes free-form instructions from external counterparties.

The defensive implication is that data ingestion and instruction execution must be separated.

3. Memory Poisoning Agentic systems often maintain memory.

Memory may contain previous decisions, user preferences, task summaries, learned facts, or workflow state.

If inaccurate or adversarial information becomes persistent memory, future decisions may be influenced long after the original interaction disappears.

For a financial institution, persistent memory can create a subtle integrity problem.

Suppose an agent incorrectly records that a beneficiary is trusted, a limit was approved, or a vendor is authoritative. The risk may persist across many future workflows.

Memory should therefore be treated as a controlled data store, not as an informal notebook.

4. Tool Misuse The model itself may not possess direct access to a financial system. Tools provide that access.

Typical tools may include:

document retrieval; database queries; email; code execution; cloud administration; payment APIs; trading interfaces; file modification; and ticketing and workflow systems.

The risk emerges when a model can combine tools in an unintended sequence.

The central control principle is:

$$\text{Tool Availability} \neq \text{Tool Authority.} \quad (5.8)$$

An agent may need to query a payment database without needing authority to release a payment.

An agent may need to read code without authority to deploy it.

5. Agent-to-Agent Trust Manipulation Multi-agent architectures create another risk.

One agent may accept information or recommendations from another agent.

If the receiving agent assumes that every message from another agent is trustworthy, compromised information can propagate through the system.

For example:

$$\text{Research Agent} \rightarrow \text{Risk Agent} \rightarrow \text{Trading Agent.} \quad (5.9)$$

A false assertion introduced at the research layer may eventually influence a trading decision.

Agent communications therefore require provenance and authorization.

The fact that a message came from “another AI agent” does not make it authoritative.

6. Data Poisoning AI systems depend heavily on data.

An attacker may attempt to influence the information used for training, retrieval, memory, or real-time decision support.

For finance, the relevant risk is not only model accuracy. It is financial decision integrity.

A corrupted reference-data source, manipulated news feed, or poisoned knowledge base may change the agent’s conclusions.

Traditional reconciliation becomes newly important.

7. AI-Assisted Vulnerability Discovery Frontier cybersecurity models increasingly assist in finding software weaknesses.

This capability has substantial defensive value. OpenAI states that its current testing suggests GPT-5.6 is presently better at finding and fixing vulnerabilities than at exploiting them in real attacks. Anthropic’s Project Glasswing similarly uses Mythos-class capabilities to discover and remediate weaknesses in critical software.

But the same capability changes the threat environment.

The cost of analyzing large software estates can fall.

The time between vulnerability discovery and attempted misuse may shrink.

Financial institutions must therefore shorten the defensive cycle:

$$\text{Discover} \rightarrow \text{Prioritize} \rightarrow \text{Patch} \rightarrow \text{Verify}. \quad (5.10)$$

8. Autonomous Parallelization A human security analyst has limited attention. An agentic system can potentially run many analytical tasks in parallel. A coordinated architecture might include:

$$\text{Coordinator} + \text{Code Analyst} + \text{Identity Analyst} + \text{Data Analyst} + \text{Verifier}. \quad (5.11)$$

The key threat is not mysterious intelligence. It is economic scalability.

Activities that once required many hours of expert human labor can increasingly be automated or distributed among agents.

5.8 Typical Agentic Threat Architectures

Several architecture patterns deserve recognition.

Single Agent with Tools One model operates in a loop:

$$\text{Observe} \rightarrow \text{Reason} \rightarrow \text{Act} \rightarrow \text{Observe}. \quad (5.12)$$

Risk increases with tool permissions and execution time.

Planner–Executor–Verifier One agent develops a plan, another performs constrained tasks, and a third checks the result.

This architecture increases persistence and reliability.

Supervisor and Specialist Agents A supervisory model assigns work to many specialized agents.

This architecture increases parallelism.

Memory-Augmented Architecture Agents maintain persistent state across tasks.

This increases continuity but creates memory-integrity risk.

Human-in-the-Loop Architecture Agents prepare actions but humans approve high-impact decisions.

For financial institutions, this will often be the preferable architecture for material actions.

5.9 Protection Strategy 1: Separate Information from Authority

The most important AI control is architectural.

Untrusted information should not automatically grant authority.

A research agent may read the open internet, but it should not therefore have permission to execute payments.

A customer-support agent may read customer messages, but a message should not be able to redefine the agent's system permissions.

A useful principle is:

$$\text{Untrusted Content} \rightarrow \text{Interpretation}, \quad (5.13)$$

but not:

$$\text{Untrusted Content} \rightarrow \text{Automatic High-Impact Action}. \quad (5.14)$$

OpenAI's current guidance on prompt-injection-resistant agents emphasizes constraining the consequences of manipulation rather than assuming every malicious input can be perfectly detected. This is particularly relevant to finance.

5.10 Protection Strategy 2: Least Privilege for Tools

Every agent should receive the minimum tools required for the task.

If an agent only needs to read a portfolio, give it read access.

If it needs to prepare a payment, do not automatically give it release authority.

If it needs to analyze code, do not give it production deployment access.

This is ordinary least privilege applied to autonomous systems.

5.11 Protection Strategy 3: Deterministic Gates

Some controls should remain outside the model.

A language model should not decide whether a payment exceeds an authorized limit.

The system can encode:

$$\text{If Amount} > L, \quad \text{Require Independent Approval}. \quad (5.15)$$

Similarly, trading limits, beneficiary restrictions, position limits, data-export constraints, and production deployment rules can be deterministic.

AI may provide analysis.

The control layer should enforce policy.

5.12 Protection Strategy 4: Human Approval for Material Actions

Human approval is not useful if it is merely ceremonial.

The approver should see:

what the agent proposes; why it proposes it; which data it used; which tools will be invoked; the economic consequence; and any policy exceptions.

The human must be able to reject the action.

For very high-risk processes, a second independent approver may still be necessary.

5.13 Protection Strategy 5: Isolation and Sandboxing

AI-generated or AI-modified code should not automatically operate in critical production environments.

Testing environments, constrained execution, permission boundaries, and network restrictions reduce the impact of error or manipulation.

The same principle applies to financial models.

An experimental agent should not share unrestricted access with the production payment environment merely because both systems belong to the same institution.

5.14 Protection Strategy 6: Provenance and Trusted Data

Financial institutions should identify which data sources are authoritative.

A valuation agent should know which pricing feed is approved.

A treasury agent should know which cash-balance source is authoritative.

A compliance agent should distinguish formal policy from unverified commentary.

Where possible, institutions should preserve:

$$\text{Data} + \text{Source} + \text{Time} + \text{Version} + \text{Authorization}. \quad (5.16)$$

This creates traceability.

5.15 Protection Strategy 7: Independent Reconciliation

AI increases the value of an old financial control: reconciliation.

If an agent calculates a portfolio value, compare key results with an independent source.

If an agent prepares a transfer, reconcile the destination and amount against approved instructions.

If an agent changes a risk parameter, compare the new value with approved governance records.

Independent verification reduces dependence on one cognitive system.

5.16 Protection Strategy 8: Immutable and External Logging

An autonomous agent should not be the sole custodian of its own audit trail.

Logs should be recorded outside the agent's control.

The institution should preserve:

agent identity; human owner; model version; input sources; tool calls; proposed actions; approvals; executed actions; and exceptions.

This is essential for investigation, model-risk management, and accountability.

5.17 Protection Strategy 9: Limit Time, Money, and Scope

Autonomy should have boundaries.

An agent can be constrained by:

maximum transaction amount; maximum aggregate daily amount; approved counterparties; approved instruments; approved systems; operating hours; maximum execution duration; maximum number of actions; and maximum data-access scope.

These are the autonomous-system equivalent of trading and credit limits.

5.18 Protection Strategy 10: Design for Recovery

No control is perfect.

A financial institution should assume that an agent may eventually make an incorrect or unauthorized action.

The architecture should support:

$$\text{Detect} \rightarrow \text{Stop} \rightarrow \text{Isolate} \rightarrow \text{Reconstruct} \rightarrow \text{Restore}. \quad (5.17)$$

Kill switches, credential revocation, version rollback, trusted backups, transaction reconciliation, and independent logs are therefore essential.

5.19 Financial Practice: The Valuation Agent

Consider a fictional asset manager with an AI valuation assistant.

The agent reads approved pricing feeds, issuer documents, portfolio positions, and market commentary. It identifies unusual price movements and proposes overrides for human review.

This is a relatively controlled architecture.

Now suppose the firm allows the agent to retrieve arbitrary external websites and automatically write approved prices into the production valuation system.

The risk changes substantially.

Untrusted external content is now connected to a production financial action.

A safer architecture is:

$$\begin{aligned} &\text{External Research} \rightarrow \text{Agent Analysis} \rightarrow \text{Proposed Override} \\ &\rightarrow \text{Independent Validation} \rightarrow \text{Production Update}. \end{aligned} \quad (5.18)$$

The key protection is not that the model is guaranteed to resist manipulation.

The protection is that manipulation does not automatically become a financial record.

5.20 Financial Practice: The Trading Agent

Suppose an investment manager deploys an agent that reads research and proposes trades.

Initially, the system is advisory.

Later it is connected to the order-management system.

The firm should preserve deterministic controls around:

instrument eligibility; position limits; concentration; liquidity; restricted lists; trading hours; and maximum order size.

The agent can propose.

The risk engine should constrain.

The execution system should enforce.

Finance and Operational-Risk Lens

In financial AI, the correct architecture separates intelligence from authority. The more capable the model becomes, the more important it is that economic authority remain independently governed.

5.21 Mini Case: The Research Document

A fictional hedge fund operates a research agent.

The agent reads public documents and prepares summaries for portfolio managers.

One day it reads an external document containing misleading instructions designed to influence an automated reader.

In Architecture A, the agent can only generate a research note.

The maximum direct operational consequence is a misleading recommendation that must still be reviewed by a human.

In Architecture B, the same agent can generate and submit orders.

The identical manipulation now has a different loss distribution.

In Architecture C, the agent can submit orders, change risk limits, and write to portfolio memory.

The risk becomes much greater again.

Nothing about the external document changed.

The architecture changed.

This yields one of the most important principles in the book:

$$\text{Cyber Consequence} = f(\text{Manipulation, Authority, Controls}). \quad (5.19)$$

5.22 Safe Notebook Lab

Safe Notebook Lab

The companion notebook should simulate an AI-enabled financial workflow entirely with synthetic data.

Students can create:

1. a fictional portfolio;
2. an approved pricing source;
3. an untrusted research document;
4. a simple research “agent” represented by transparent Python logic;
5. a proposed price override;
6. a deterministic control that prevents automatic production changes;
7. an independent reconciliation step;
8. an audit log.

A second exercise can compare three agent architectures:

1. read-only research;
2. research plus recommendation;
3. research plus autonomous action.

Students should estimate how the potential loss changes as authority increases.

The notebook must not browse real targets, exploit applications, use real credentials, access external financial accounts, or generate operational attack payloads.

5.23 A Pragmatic Protection Checklist

For every AI-enabled financial application, management should ask:

1. What information can the agent read?
2. Which information sources are untrusted?
3. Can external content influence the agent’s instructions?
4. What persistent memory does the agent maintain?
5. Which tools can the agent call?
6. Which actions have financial consequences?

7. Which controls exist outside the model?
8. Which actions require independent human approval?
9. Are critical data independently reconciled?
10. Are agent actions logged outside the agent's control?
11. Are monetary, temporal, and operational limits defined?
12. Can the institution immediately stop and revoke the agent?
13. Can the institution restore trusted data and reconstruct what happened?

5.24 Chapter Summary

The main lessons of this chapter are:

1. Financial applications convert information into economic outcomes, so application security is part of financial control.
2. Data integrity can be more consequential than confidentiality when financial decisions depend on accurate prices, positions, limits, or instructions.
3. Frontier models increase the speed and scale of software-security analysis, changing both defensive capabilities and the threat environment.
4. Agentic AI creates a second problem because AI systems themselves can be manipulated through the information they consume.
5. Prompt injection is best understood as social engineering for AI systems; indirect prompt injection arises through external content processed by agents.
6. Other important AI-era threats include memory poisoning, tool misuse, agent-to-agent trust failures, data poisoning, automated vulnerability discovery, and autonomous parallelization.
7. Typical threat architectures include single tool-using agents, planner-executor systems, supervisor-specialist teams, and memory-augmented agents.
8. The strongest protection is architectural: separate untrusted information from economic authority.
9. Least privilege, deterministic gates, human approval, sandboxing, provenance, reconciliation, external logging, and strict limits reduce the consequence of AI manipulation.
10. Financial institutions should assume that sufficiently capable agents will sometimes make mistakes or be manipulated and must therefore design for containment and recovery.

5.25 Review Questions

1. Why can data integrity be more important than confidentiality in a valuation process?
2. What is the difference between a manipulated chatbot and a manipulated tool-using agent?
3. Explain prompt injection in non-technical terms.
4. Why is indirect prompt injection particularly relevant to research and email agents?
5. How can persistent agent memory become an integrity risk?
6. Why should tool availability be separated from tool authority?
7. What risk arises when one AI agent automatically trusts another?
8. How does autonomous parallelization change the economics of cyber threats?
9. Why should some financial controls remain deterministic rather than model-based?
10. How does independent reconciliation protect against both conventional data corruption and AI error?
11. In the valuation-agent example, why should external research not automatically update production prices?
12. What are the minimum controls you would require before allowing any AI agent to take an economically material action?

Chapter 6

Detection, Monitoring, and Security Operations in the Age of Agentic AI

Learning Objectives

By the end of this chapter, the reader should be able to explain how a financial institution converts telemetry into defensible security decisions; distinguish monitoring, detection engineering, vulnerability management, triage, investigation, and response coordination; evaluate whether coverage reflects business criticality; understand how AI can improve correlation, code review, alert interpretation, and remediation; identify the risks of automated defensive action; and describe a human-machine operating model that preserves accountability, evidence, proportionality, and continuity.

6.1 The Purpose of Security Operations

Security operations helps an institution recognize and manage conditions that could undermine trusted financial activity. It is not merely a team that watches technical alerts. A mature function connects evidence from identities, devices, applications, networks, cloud environments, data stores, vendors, and AI agents to the critical business services that depend on them.

The practical sequence is:

$$\text{Telemetry} \rightarrow \text{Normalized Event} \rightarrow \text{Context} \rightarrow \text{Detection} \rightarrow \text{Case} \rightarrow \text{Decision}. \quad (6.1)$$

Each step adds interpretation. Telemetry records activity. Normalization gives records a consistent structure. Context identifies the user, device, asset, business owner, baseline, and criticality. Detection evaluates whether the activity deserves attention. A case assembles related evidence. A decision determines whether to dismiss, monitor, restrict, escalate, contain, or recover.

The quality of security operations should therefore be measured by the quality and timeliness of decisions, not by the volume of data collected or alerts generated. A platform that produces thousands of unexplained alerts may be less useful than one that identifies a

small number of material conditions and connects them clearly to financial processes.

6.2 Visibility Must Follow the Business Service

Monitoring begins with the institution's critical services. A bank should understand the evidence generated by payment, deposit, lending, liquidity, and customer-access processes. A broker-dealer should cover order entry, market connectivity, risk controls, settlement, and client communications. An asset manager should cover valuation, portfolio accounting, trading, custody interfaces, and investor reporting. An exchange should cover participant identity, order routing, matching, market data, surveillance, and clearing connections.

This service-oriented view prevents blind spots. Collecting operating-system logs from many servers does not establish that a payment process is observable from instruction through approval and release. Monitoring should identify the identities that can act, the applications that transform information, the data that determine outcomes, the vendors that support the service, and the controls that should produce evidence when they operate.

AI systems must be included in this map. The institution should know which agent received a task, which model and version were used, which data sources were consulted, which tools were called, which permissions were granted, what memory changed, which action was proposed or executed, and who reviewed the result. Without that evidence, an agent may become an opaque operational actor.

6.3 Detection Engineering

Detection engineering is the disciplined design, testing, and improvement of methods that identify activity deserving investigation. A detection should begin with a risk hypothesis. For example, a compromised payment identity might attempt repeated authentication, access from an unusual device, modify a beneficiary, and submit a transaction. The rule or analytical method should identify observable evidence associated with that pathway.

A useful detection has a clear purpose, defined data requirements, an understood population of legitimate behavior, a documented severity rationale, and a test process. It should be evaluated against both false positives and false negatives. A rule that never alerts may be quiet because the environment is safe, because the behavior is rare, or because the required data are missing. A rule that alerts constantly may reflect real exposure, poor thresholds, insufficient context, or a control that is not aligned with business practice.

Detections should be linked to ownership and response. An alert concerning a privileged identity connected to treasury should identify the affected service, the identity owner, the available containment actions, and the evidence required before financial activity resumes. A generic label such as "suspicious login" is insufficient when the same technical pattern has radically different implications across a marketing application and a payment console.

AI can assist detection engineering by summarizing examples, identifying relationships, proposing hypotheses, reviewing logic, and explaining why a pattern may be important. It should not become the sole authority for deciding that activity is malicious or for changing

a high-impact rule in production. Detection content should remain testable, versioned, attributable, and subject to review.

6.4 Vulnerability Management as a Race

Vulnerability management identifies weaknesses, determines whether they are reachable and material, prioritizes remediation, verifies closure, and manages residual exposure. The number assigned to a technical finding is only one input. Business criticality, external exposure, available authority, dependency, evidence of active interest, and the strength of compensating controls determine practical urgency.

AI increases the importance of time. Advanced systems can help defenders review code, analyze software components, compare configurations, and prioritize likely weaknesses. The same progress can reduce the time available before a weakness is understood or tested by others. The institution should therefore measure its defensive window:

$$W = T_{\text{harmful action}} - T_{\text{verified remediation}}. \quad (6.2)$$

If remediation and verification occur first, the weakness may never become an incident. If adversarial action occurs first, the institution must depend on segmentation, access controls, monitoring, containment, and recovery. The objective is not simply to patch faster in every case. It is to prioritize the weaknesses that connect most directly to critical authority and financial services.

AI-assisted software analysis should operate in controlled environments. Proposed fixes require testing, code review, dependency analysis, and change management. A generated patch can introduce new errors even when it addresses the original weakness. The value of AI lies in accelerating analysis while the institution preserves evidence and engineering accountability.

6.5 Triage and Case Management

Triage determines which alerts deserve immediate attention, which require additional context, which can be monitored, and which can be closed. The process should consider confidence, business criticality, potential impact, time sensitivity, current market or liquidity conditions, and the reversibility of available actions.

Case management assembles related evidence so that analysts and decision makers work from a common record. A useful case contains a timeline, affected identities and assets, business ownership, supporting and contradictory evidence, actions already taken, financial implications, outstanding questions, and decision authority. It distinguishes observed facts from hypotheses and records why a response was proportionate at the time.

AI is well suited to some triage tasks. It can summarize large records, correlate names and systems, explain technical terms, identify missing fields, and draft a timeline. These outputs should be treated as analytical assistance. The underlying evidence must remain accessible,

and material conclusions must be verified. A fluent narrative can conceal a missing log or an unsupported causal link just as easily as it can clarify a complex case.

6.6 Threat Intelligence and Institutional Relevance

Threat intelligence provides information about actors, campaigns, techniques, vulnerabilities, infrastructure, and sector conditions. Its value depends on relevance. A general report becomes useful when it changes the institution's assessment of exposure, detection, remediation, or response. Management should ask whether the described behavior is possible in its environment, whether the necessary data are visible, whether existing controls would interrupt the pathway, and whether a critical service requires additional protection.

AI can help process large volumes of threat reporting and map external descriptions to internal assets. It can also create a false sense of completeness if the asset inventory is poor or if the model associates terms without sufficient evidence. The institution should preserve source provenance, separate confirmed facts from analytical inference, and avoid treating model-generated summaries as independent corroboration.

The most actionable intelligence often concerns timing. A newly disclosed weakness, a change in observed targeting, or evidence that automation has reduced the effort required for a task may justify accelerated remediation or enhanced monitoring. Intelligence should therefore be integrated with vulnerability management, detection engineering, incident response, and business ownership rather than distributed as an isolated report.

6.7 AI-Enabled Defensive Analysis

AI can strengthen security operations where the problem is interpretive and labor intensive. It can compare alerts across systems, retrieve relevant asset and identity context, summarize prior incidents, review code, explain relationships, and propose investigation steps. Agentic systems can coordinate bounded tasks, such as asking one component to gather identity history while another examines file integrity and a third maps the affected service to financial obligations.

The architecture should preserve a visible evidence chain:

$$\text{Evidence} \rightarrow \text{AI Analysis} \rightarrow \text{Human Validation} \rightarrow \text{Authorized Action}. \quad (6.3)$$

This separation is important because a model can be wrong, manipulated, or overly confident. An agent that reads untrusted email, tickets, documents, or web content may encounter instructions designed to influence its behavior. That content should remain data, not authority. Retrieval and reasoning should not silently expand the agent's permissions.

Defensive AI also requires confidentiality and provenance controls. Investigation records may contain client information, employee data, credentials, vulnerabilities, and legally sensitive material. The institution should know where inputs are processed, whether they are retained, which provider has access, how model changes are governed, and whether an alternative

process exists if the service becomes unavailable.

6.8 Defensive Agents as Institutional Users

A defensive agent should be governed as a machine identity. It should have a defined owner, approved purpose, distinct credentials, narrow tools, limited data access, bounded runtime, external logging, and an independent interruption mechanism. Permissions should reflect the task. An agent that investigates an alert may need read access to selected logs but no authority to disable an account or alter production data.

The institution should distinguish proposed actions from executed actions. An agent may recommend that an identity be restricted, a file restored, a transaction paused, or a vulnerability remediated. Material execution should pass through deterministic rules, human approval, or both. Emergency automation may be justified for narrow, rapidly reversible actions when delay would create greater harm, but the conditions must be specified and tested in advance.

Agent memory requires governance. If an agent records that an identity, vendor, or beneficiary is trusted, that statement may influence future cases. Memory should therefore have provenance, scope, retention, correction, and rollback. It should not become an informal source of authority that survives after the evidence supporting it has changed.

6.9 The Risk of Automated Defensive Action

Security response can itself create financial harm. Disabling a trader during market stress may leave exposure unmanaged. Blocking a payment platform near settlement cutoff may create liquidity or legal consequences. Disconnecting an exchange participant may affect market access. Restoring a file without reconciliation may reintroduce inaccurate data.

The response decision should compare the expected harm of action with the expected harm of delay:

$$\text{Response Decision} = f(\text{Confidence, Potential Impact, Reversibility, Urgency, Continuity}). \quad (6.4)$$

AI does not remove this trade-off. It may help estimate context and propose a narrower intervention, but it should not obscure accountability. High-impact containment requires a decision maker who understands both the cyber evidence and the financial process. Where time is critical, preapproved playbooks should define who may act, which actions are permitted, how long they remain in force, and what evidence triggers escalation.

Selective containment is usually preferable to indiscriminate shutdown. Restricting beneficiary modification while preserving payment visibility, placing an agent in read-only mode, revoking one tool, or isolating one participant gateway may reduce authority while preserving legitimate obligations. The institution should design these options before an incident rather than improvise them under pressure.

6.10 The Human–Machine Operating Model

The strongest operating model assigns machines the work they perform well and preserves human responsibility for ambiguity, consequence, and institutional judgment. AI can gather context, correlate evidence, draft explanations, identify missing information, and propose actions. Humans should validate material conclusions, balance cyber and financial consequences, authorize high-impact containment, communicate with stakeholders, and accept residual risk.

This is not a simple human-in-the-loop slogan. Oversight is effective only when the reviewer has time, evidence, competence, and authority to disagree. A person asked to approve hundreds of opaque recommendations provides little control. The system should present the evidence, uncertainty, proposed action, expected effect, and alternatives in a form that supports genuine challenge.

Security operations should also preserve independent assurance. Detection engineers should not be the sole judges of detection quality, agents should not control their only audit trail, and the team taking an emergency action should not alone determine that recovery is complete. Review, reconciliation, and testing create confidence that the system operates as intended.

6.11 Metrics That Matter

Useful metrics describe exposure, decision quality, and resilience. Alert volume alone rarely does so. Management should understand coverage of critical services, time from material evidence to triage, time to restrict harmful authority, time to verified remediation, the age and business significance of unresolved vulnerabilities, the proportion of high-impact agent actions requiring independent approval, and the success of recovery tests.

Metrics should reveal where uncertainty remains. An institution may report rapid closure while repeatedly dismissing alerts without adequate evidence. It may report high patch counts while critical reachable weaknesses remain open. It may report that every agent action is logged while the logs do not identify the model, data, tool, approval, or financial effect. Measures should be designed to support decisions rather than produce reassuring activity statistics.

6.12 Mini Case: The Defensive Treasury Agent

A fictional bank uses a defensive agent to monitor treasury identities and payment workflows. The agent detects an unusual login followed by a beneficiary change and several below-threshold transfer proposals. It recommends disabling the identity and suspending the payment service.

The recommendation identifies a credible risk but is broader than necessary. The institution first verifies the identity, blocks beneficiary modification, pauses the proposed transfers, preserves logs and agent context, and maintains read access to balances and payment status. Analysts examine whether the aggregate amount, device history, approval sequence, and

timing support unauthorized activity. Treasury management evaluates upcoming settlement obligations and available manual alternatives.

The agent adds value by correlating events quickly. It does not own the decision. Deterministic controls prevent release, a human authorizes containment, and independent reconciliation determines whether any financial record changed. The case demonstrates how AI can accelerate understanding while a governed architecture limits the consequences of both the suspected activity and the defensive response.

Finance and Operational-Risk Lens

The value of AI in security operations lies in faster, broader, and more consistent interpretation. Its risk lies in allowing an uncertain interpretation to acquire operational authority. The correct architecture connects evidence to AI analysis, human validation, deterministic financial controls, and independently logged action.

6.13 Safe Notebook Lab

Safe Notebook Lab

The companion notebook should create synthetic identity, application, file-integrity, vulnerability, and agent-tool events. Students should build transparent detections, group alerts into a case, attach business criticality, and compare human-only with AI-assisted triage. A final exercise should compare broad shutdown with selective containment and should calculate which financial obligations remain available under each choice. The notebook must use no external target, live credential, real client data, unrestricted agent, or operational exploit logic.

6.14 Chapter Summary

Security operations converts telemetry into decisions that protect critical financial services. Effective monitoring follows business processes and authority, detection engineering begins with testable risk hypotheses, vulnerability management prioritizes reachable and consequential weaknesses, and case management preserves evidence and uncertainty. The objective is not maximum alert volume but timely, proportionate, and defensible action.

AI can improve correlation, code analysis, triage, investigation, and remediation, while agentic defense can coordinate bounded analytical work. These systems must themselves be governed through distinct identities, least privilege, protected logs, controlled memory, narrow tools, deterministic limits, human validation, and interruption. Automated defense is valuable only when it reduces the time to understanding without converting an uncertain conclusion into uncontrolled financial harm.

6.15 Review Questions

1. Why should monitoring coverage begin with critical business services?
2. What does context add to a raw security event?
3. How should a detection be tested and governed?
4. Why is a vulnerability's business reachability more important than its technical score alone?
5. What is the defensive window?
6. Which triage tasks are suitable for AI assistance?
7. Why should an AI-generated investigation narrative be verified against underlying evidence?
8. How should a defensive agent's identity, tools, memory, and logs be governed?
9. Why can automated containment create financial harm?
10. In the treasury case, why is selective containment preferable to immediate shutdown?

Chapter 7

Incident Response and Business Continuity in the Age of Agentic AI

Learning Objectives

By the end of this chapter, the reader should be able to: explain when a security alert becomes a financial and operational incident; distinguish containment, eradication, recovery, reconciliation, and post-incident learning; connect cyber incident response to liquidity, trading continuity, payments, client obligations, market infrastructure, and regulatory communication; understand how frontier AI models and autonomous agents can increase the speed, persistence, coordination, and adaptability of cyber incidents; describe, at a safe and non-operational level, the main AI-enabled tactics relevant to long-horizon attacks and crisis escalation; evaluate AI-assisted and autonomous defensive response without creating excessive operational risk; and design business-continuity and recovery architectures that remain robust even when AI agents, data, or automated controls are themselves compromised.

7.1 When an Alert Becomes an Incident

A financial institution receives thousands or millions of technical events each day. Only a fraction become alerts. An even smaller fraction become incidents.

The transition from alert to incident should be governed by business consequence rather than technical drama.

A suspicious login to a public marketing system may remain a low-priority case. A suspicious login to a payment-release account may require immediate escalation. A file-integrity alert affecting an archived document may be routine. The same alert affecting a production pricing file shortly before NAV calculation may represent a material operational event.

A useful decision framework is:

$$\text{Incident Materiality} = f(\text{credibility, asset criticality, financial authority, business impact, duration, external}) \quad (7.1)$$

The purpose of incident response is not simply to “remove the attacker.” It is to preserve the institution’s ability to operate safely while restoring a trustworthy environment.

For financial businesses, that means protecting:

client assets; payment obligations; market access; liquidity; position integrity; valuation accuracy; regulatory reporting; data confidentiality; business continuity; and institutional reputation.

7.2 The Incident-Response Lifecycle

A practical lifecycle is:

$$\text{Prepare} \rightarrow \text{Detect} \rightarrow \text{Contain} \rightarrow \text{Eradicate} \rightarrow \text{Recover} \rightarrow \text{Learn}. \quad (7.2)$$

Each stage has a financial interpretation.

Prepare Preparation includes roles, decision rights, playbooks, backups, communication channels, emergency access, vendor contacts, legal escalation, and business workarounds.

The preparation stage determines whether the institution can act quickly without improvising under pressure.

Detect Detection determines whether something material is occurring.

The objective is to establish sufficient confidence to act while recognizing that perfect certainty is rarely available.

Contain Containment limits the event.

The institution may restrict an account, isolate a device, disable a connection, suspend an application, or limit a business function.

Containment creates an important trade-off:

$$\text{Security Benefit} \quad \text{versus} \quad \text{Operational Disruption}. \quad (7.3)$$

In finance, both sides matter.

Eradicate Eradication removes the underlying weakness or unauthorized presence.

This may require resetting identities, fixing software, replacing compromised systems, correcting configuration, or removing malicious artifacts.

The objective is not merely to make the alert disappear. It is to remove the cause.

Recover Recovery restores trusted operations.

A system being available does not necessarily mean it is safe.

The institution must confirm that:

software is trustworthy; identities are valid; data are accurate; balances reconcile; payment instructions are correct; positions are complete; risk limits are restored; and logs remain available.

Learn After the event, the institution asks why the incident occurred, which controls failed, which controls worked, how losses were limited, and what must change.

Without learning, the institution may restore the environment but preserve the vulnerability.

7.3 Cyber Response Is a Business Decision

A technical team may want to disconnect a system immediately.

A trading desk may insist that the system remain available.

A treasury team may need to release payments before cutoff.

A regulator may expect continuity of critical functions.

Senior management must therefore make decisions under uncertainty.

Consider a fictional exchange. Security analysts detect unusual activity on a participant gateway.

One response is to disconnect the gateway.

That may reduce cyber risk.

But if the gateway is used by major market participants during a volatile trading session, disconnection may impair liquidity or price discovery.

The correct response depends on:

confidence in the alert; potential attack impact; availability of alternative gateways; market conditions; participant concentration; reversibility of the action; and regulatory obligations.

Incident response is therefore an exercise in constrained risk optimization.

7.4 The AI Threat Lens: Incidents Can Move Faster

Frontier AI changes the temporal structure of cyber incidents.

Current evaluations suggest that leading models can sustain increasingly long multi-step cyber tasks. OpenAI reports that GPT-5.6 is stronger than earlier systems in cybersecurity, particularly in vulnerability discovery and long-horizon security work.¹

The UK AI Security Institute reports rapid improvement in autonomous cyber time horizons and has evaluated models on multi-step cyber ranges requiring chained actions over extended sequences.²³

¹<https://openai.com/index/gpt-5-6/>

²<https://www.aisi.gov.uk/blog/how-fast-is-autonomous-ai-cyber-capability-advancing>

³<https://www.aisi.gov.uk/research/measuring-ai-agents-progress-on-multi-step-cyber-attack-scenarios>

Anthropic’s Mythos research similarly shows that frontier models are becoming unusually capable at finding complex vulnerabilities and combining technical reasoning across longer attack chains.⁴⁵

For financial institutions, this has one central consequence:

Core Intuition

The time available to detect, understand, and contain a serious cyber event may shrink as AI reduces the human effort required to sustain complex attack activity.

The response architecture must therefore become faster without becoming reckless.

7.5 Long-Horizon AI Agents

A conventional script follows predetermined instructions.

A long-horizon agent can maintain a goal over many steps, evaluate what happened, revise its plan, and continue.

At a safe conceptual level:

$$\text{Goal} \rightarrow \text{Plan} \rightarrow \text{Action} \rightarrow \text{Observation} \rightarrow \text{Revision} \rightarrow \text{Continuation}. \quad (7.4)$$

This matters because many security controls assume that hostile activity is fragmented or short-lived.

A persistent agent may repeatedly test alternatives, preserve context, and return to unresolved tasks.

OpenAI’s work on long-running models notes that persistence can expose security risks and that safeguards increasingly need to evaluate whole trajectories rather than isolated actions.⁶

The defender must therefore analyze sequences.

7.6 Typical AI-Enabled Incident Tactics

The following tactics are described only at the strategic level needed for defensive planning.

1. Accelerated Discovery AI can reduce the effort required to understand unfamiliar software, documents, configurations, and system relationships.

The practical threat is that the period between exposure and discovery may fall.

2. Parallelized Investigation A multi-agent team can divide tasks.

One agent may analyze identity relationships, another software, another configuration, and another collected evidence.

⁴<https://www.anthropic.com/research/mythos-preview>

⁵<https://www.anthropic.com/research/exploit-evals>

⁶<https://openai.com/index/safety-alignment-long-horizon-models/>

The strategic effect is speed.

3. Adaptive Replanning An agent can modify its approach when one avenue fails.

The strategic effect is resilience against simple static defenses.

4. Persistent Memory An agent can maintain findings over time.

The strategic effect is cumulative understanding of the target environment.

5. AI-Assisted Social Manipulation AI can create more personalized communications at scale.

The strategic effect is greater pressure on human verification controls.

6. Tool Chaining An agent can combine several capabilities into a workflow.

The strategic effect is that legitimate tools can produce an unauthorized outcome when connected in the wrong sequence.

7. Coordinated Agent Teams A supervisory agent may orchestrate multiple specialists.

A conceptual architecture is:

$$\text{Supervisor} \rightarrow \{\text{Identity Agent, Software Agent, Data Agent, Evaluator}\}. \quad (7.5)$$

The risk comes from coordination and persistence rather than any single action.

7.7 AI Can Also Shorten the Defender's Response Time

The same capabilities can improve incident response.

A defensive agent can:

summarize alerts; reconstruct timelines; identify affected assets; correlate identities; map systems to business processes; compare incidents with historical cases; propose containment options; identify relevant procedures; assist with vulnerability remediation; and prepare management summaries.

This creates an emerging contest:

$$T_{\text{defensive comprehension}} \quad \text{versus} \quad T_{\text{adversarial progression}}. \quad (7.6)$$

The institution wants:

$$T_{\text{defensive comprehension}} < T_{\text{adversarial progression}}. \quad (7.7)$$

But speed alone is not enough.

A fast wrong decision can be more damaging than a slower correct one.

7.8 The Danger of Autonomous Defensive Response

Suppose an AI security agent detects unusual behavior in a payment platform and immediately disables several accounts.

If the alert is correct, the action may prevent loss.

If the alert is wrong, legitimate high-value payments may miss settlement deadlines.

The institution may create liquidity problems through its own defensive system.

Similarly, an AI defender that isolates a trading gateway during a volatile market may prevent unauthorized activity but also create unmanaged positions.

A defensive action therefore has its own expected loss:

$$\mathbb{E}[L_{\text{response}}] = P(\text{wrong response}) \times I(\text{operational disruption}). \quad (7.8)$$

This means that autonomous response authority should be proportional to reversibility.

A practical hierarchy is:

$$\text{Observe} < \text{Recommend} < \text{Rate Limit} < \text{Restrict} < \text{Disable}. \quad (7.9)$$

The more consequential and difficult to reverse the action, the stronger the approval requirement should be.

7.9 Business Continuity in an AI-Dependent Institution

Financial institutions increasingly depend not only on conventional software but also on AI services.

This creates a new continuity question:

What happens if the AI system itself is unavailable, corrupted, manipulated, or untrustworthy?

A bank may use an AI agent for document review, fraud triage, treasury forecasting, client service, or operations.

If that agent becomes unreliable, the business must still be able to function.

A robust architecture requires graceful degradation.

$$\text{Normal Mode} \rightarrow \text{Restricted Mode} \rightarrow \text{Manual or Deterministic Fallback}. \quad (7.10)$$

The institution should know which processes can continue without AI.

This is especially important when an AI agent becomes part of a critical operational workflow.

7.10 Recovery Requires Trust, Not Merely Availability

One of the most dangerous mistakes in incident response is restoring systems before restoring trust.

Suppose a portfolio-accounting server is rebuilt after a cyber incident.

The application opens successfully.

That does not prove that the data are correct.

The institution should reconcile:

portfolio positions; cash balances; prices; transactions; corporate actions; client records; and risk limits.

The same principle applies to AI systems.

If an agent's memory or knowledge store may have been manipulated, simply restarting the model is not enough.

The institution may need to restore a trusted memory state, revalidate authoritative data sources, revoke old credentials, and re-establish tool permissions.

Recovery therefore has two dimensions:

$$\text{Technical Recovery} + \text{Information Recovery}. \quad (7.11)$$

7.11 Protection Strategy 1: Predefine Decision Rights

Incident response should not depend on discovering authority during the crisis.

The institution should define in advance:

who can disable an account; who can suspend a payment service; who can disconnect a trading system; who can communicate with clients; who notifies regulators; who can activate disaster recovery; and who can authorize emergency AI restrictions.

AI agents may assist, but decision ownership should remain explicit.

7.12 Protection Strategy 2: Maintain Independent Communication Channels

A serious incident may compromise normal email or collaboration tools.

Financial institutions therefore need trusted out-of-band communication methods.

This is particularly important when autonomous agents participate in ordinary communication workflows.

If the institution suspects that an AI system or communication environment is manipulated, incident leaders need a channel that does not depend on the affected system.

7.13 Protection Strategy 3: Preserve Immutable Evidence

Incident response requires reliable evidence.

Logs should exist outside the control of the system being investigated.

For AI-enabled workflows, the institution should preserve:

agent identity; model version; prompts or task instructions; data sources; tool calls; action sequence; human approvals; policy exceptions; and timestamps.

This allows reconstruction of the trajectory rather than only the final outcome.

7.14 Protection Strategy 4: Build Kill Switches and Scope Limits

Every materially autonomous financial agent should have a controlled way to stop.

The institution should be able to:

revoke credentials; disable tools; freeze memory updates; isolate the agent; prevent new transactions; and preserve logs.

The kill switch should not depend on the agent's cooperation.

7.15 Protection Strategy 5: Separate Recovery Credentials

An attacker or compromised agent should not automatically possess the credentials used for recovery.

Emergency administration, backup restoration, and credential reset functions should be separated from ordinary operating identities.

This is a digital version of keeping emergency liquidity separate from routine operating cash.

7.16 Protection Strategy 6: Reconcile Before Reopening

Critical financial services should not return to full operation until the institution verifies the state.

For a payment system:

reconcile pending payments; verify beneficiaries; confirm balances; and verify approval status.

For a trading system:

reconcile positions; confirm open orders; validate limits; and verify market connections.

For an asset manager:

reconcile holdings; validate prices; rerun NAV if necessary; and verify client reports.

7.17 Protection Strategy 7: Exercise AI-Specific Scenarios

Traditional tabletop exercises often assume a human attacker and conventional malware.

Institutions should now rehearse scenarios involving:

a manipulated internal agent; poisoned agent memory; compromised AI tool permissions; an AI-generated flood of credible alerts; an autonomous defensive false positive; loss of

access to a critical external AI service; and rapid AI-assisted discovery of a newly disclosed vulnerability.

The purpose is not to predict the exact next incident.

It is to make decision-making resilient.

7.18 Financial Practice: The Payment Platform

A fictional bank detects suspicious behavior on a payment-preparation account.

The account cannot release payments, but it can modify beneficiary details.

The SOC recommends disabling the account.

Treasury notes that the institution is thirty minutes from a major settlement cutoff.

Management has several options:

1. disable the account immediately;
2. restrict beneficiary modification while preserving read access;
3. shift payments to an alternate authorized operator;
4. pause only high-risk transactions;
5. activate a manual verification process.

The best response may be selective containment rather than total shutdown.

This is a core operational-risk lesson:

Core Intuition

Containment should reduce the attacker's authority faster than it reduces the institution's ability to meet legitimate obligations.

7.19 Financial Practice: The Exchange During Market Stress

Consider a fictional exchange during a period of extreme volatility.

The SOC sees unusual activity affecting one market-data distribution component.

An autonomous defender recommends isolating the component.

If the component is genuinely compromised, isolation may protect market integrity.

If the alert is wrong, the exchange may interrupt data distribution precisely when participants need it most.

The incident leader must coordinate security, market operations, technology, surveillance, legal, communications, and regulatory functions.

This is why cyber crisis management is multidisciplinary.

7.20 Mini Case: Compromised Treasury Agent

A fictional bank uses a treasury agent to forecast intraday liquidity and prepare transfers.

The agent has no final payment-release authority.

At 10:15 a.m., monitoring detects that the agent has begun proposing unusual transfers between accounts that are normally unrelated.

Management suspects that the agent's context or memory may have been manipulated.

The appropriate response is not to "argue" with the model.

The institution should:

1. suspend the agent's ability to prepare new transfers;
2. preserve its logs and memory state;
3. verify whether any proposals were approved;
4. reconcile affected accounts;
5. rotate relevant credentials;
6. restore the agent from a trusted configuration;
7. validate authoritative data sources;
8. review the control that allowed the manipulation.

If the agent had autonomous release authority, the incident would be materially more serious.

The lesson is that the severity of an AI incident is determined by the authority attached to the agent.

Finance and Operational-Risk Lens

In agentic finance, incident severity is a function of model capability, compromised context, tool permissions, economic authority, and the speed of containment.

7.21 Safe Notebook Lab

Safe Notebook Lab

The companion notebook should simulate an incident-response exercise using only synthetic data.

Students can create:

1. a fictional payment platform;
2. a human payment identity;
3. a treasury agent;

4. synthetic suspicious events;
5. deterministic containment options;
6. business-continuity alternatives;
7. a recovery checklist;
8. a final reconciliation table.

The notebook should compare three response strategies:

1. immediate shutdown;
2. selective containment;
3. observation without containment.

Students should assign hypothetical financial costs to false positives, false negatives, downtime, and delayed settlement.

A second exercise can simulate a manipulated AI agent and demonstrate how revoking tool permissions limits impact without requiring any real external action.

The notebook must remain local, synthetic, and disconnected from real payment, trading, or network infrastructure.

7.22 A Pragmatic Incident-Response Checklist

Finance professionals should ask:

1. Which financial service is affected?
2. What evidence confirms or contradicts unauthorized activity?
3. Which identities or agents currently possess authority?
4. What is the maximum plausible economic loss if no action is taken?
5. What is the operational cost of containment?
6. Can the institution use selective rather than total containment?
7. Are trusted communication channels available?
8. Are logs and agent trajectories preserved independently?
9. Can AI or machine credentials be revoked immediately?
10. Which manual or deterministic fallback exists?
11. What data must be reconciled before reopening?

12. Which clients, counterparties, regulators, or market participants require communication?
13. What control must change before normal operations resume?

7.23 Chapter Summary

The main lessons of this chapter are:

1. Incident response is a financial and operational discipline, not merely a technical exercise.
2. The purpose of containment is to reduce unauthorized capability while preserving legitimate business obligations.
3. Recovery requires restoration of trust, not simply restoration of system availability.
4. Frontier AI is increasing the speed, persistence, adaptability, and coordination possible in cyber operations.
5. Typical AI-enabled incident tactics include accelerated discovery, parallel agent teams, adaptive replanning, persistent memory, AI-assisted social manipulation, and tool chaining.
6. Long-horizon agents require defenders to monitor complete trajectories rather than only isolated events.
7. AI can also dramatically improve incident triage, correlation, vulnerability analysis, and response planning.
8. Autonomous defensive action can itself create financial loss, particularly in trading, payments, and market infrastructure.
9. Critical AI-dependent processes need manual or deterministic fallback modes.
10. AI agent recovery may require restoring trusted memory, data provenance, credentials, and tool permissions.
11. Financial institutions should rehearse AI-specific incident scenarios before they occur.
12. The governing objective is resilient, proportionate, and auditable response under uncertainty.

7.24 Review Questions

1. When should a security alert become a formal incident?
2. Why is containment a financial trade-off?
3. What does recovery of trust mean in a financial system?

4. How do long-horizon AI agents change the temporal structure of cyber incidents?
5. Name four high-level AI-enabled tactics that can increase incident speed or persistence.
6. Why should incident-response systems increasingly analyze full agent trajectories?
7. How can AI improve defensive incident response?
8. Why can autonomous defensive actions themselves create operational risk?
9. What is selective containment, and why can it be preferable to total shutdown?
10. Why should recovery credentials be separate from ordinary operating identities?
11. What additional recovery steps are required when an AI agent's memory may be compromised?
12. In the treasury-agent case, how would the incident differ if the agent had autonomous payment-release authority?

Chapter 8

Quantifying Cyber and AI-Enabled Operational Risk

Learning Objectives

By the end of this chapter, the reader should be able to: translate cyber and AI-enabled incidents into financial-loss scenarios; distinguish frequency, severity, exposure, vulnerability, control effectiveness, and residual risk; understand why cyber-risk quantification is difficult and why false precision is dangerous; build pragmatic scenario models for banks, brokers, asset managers, exchanges, payments, and financial infrastructure; incorporate AI-enabled threat multipliers such as speed, scale, automation, persistence, and parallelism into operational-risk analysis; evaluate how frontier models and agentic architectures can alter both incident probability and incident severity; use stress testing and Monte Carlo simulation as decision tools rather than as substitutes for judgment; and connect quantified cyber risk to capital, liquidity, insurance, resilience, governance, and strategic investment.

8.1 Why Cyber Risk Is Difficult to Quantify

Finance professionals are comfortable with numbers. This creates both an advantage and a danger when discussing cyber risk.

The advantage is that financial analysis forces vague statements to become explicit. Instead of saying “a cyber event could be serious,” we can ask:

How often could it occur? What would the direct loss be? How long could operations be interrupted? Which clients or counterparties would be affected? What liquidity would be required? What legal or remediation costs could follow?

The danger is false precision.

Cyber incidents are not generated by a stable physical process. Threat actors adapt. Technology changes. Controls improve or deteriorate. New vulnerabilities appear. Business dependencies change. AI capabilities can shift rapidly.

Historical loss data are therefore incomplete and often stale.

A prudent framework treats cyber-risk quantification as structured uncertainty rather than precise forecasting.

Core Intuition

The objective of quantification is not to discover the exact future cyber loss. It is to make assumptions explicit, compare scenarios, allocate resources, and understand which controls materially change the loss distribution.

8.2 The Basic Frequency–Severity Model

A standard operational-risk representation is:

$$L = \sum_{i=1}^N X_i, \quad (8.1)$$

where N is the number of incidents in a period and X_i is the loss severity of incident i . This formulation is useful because frequency and severity have different drivers.

A phishing attempt may be frequent but low severity.

A catastrophic outage at a systemically important exchange may be rare but extremely severe.

The total annual loss distribution depends on both.

We can write:

$$N \sim F_N(\lambda), \quad (8.2)$$

and:

$$X_i \sim F_X(\theta), \quad (8.3)$$

where λ represents frequency parameters and θ severity parameters.

The specific distribution is less important at first than the conceptual separation.

8.3 From Technical Events to Financial Loss

A cyber event becomes financially relevant through a loss channel.

A useful decomposition is:

$$L_{\text{total}} = L_{\text{fraud}} + L_{\text{downtime}} + L_{\text{market}} + L_{\text{remediation}} + L_{\text{legal}} + L_{\text{client}} + L_{\text{reputation}}. \quad (8.4)$$

For a bank, fraud and payment disruption may dominate.

For an asset manager, valuation integrity and client reporting may be more important.

For an exchange, availability and market confidence may dominate.

For a broker-dealer, trading continuity, settlement, and client obligations may be central.

The first step in quantification is therefore not selecting a probability distribution. It is understanding the business process.

8.4 Exposure, Threat, Vulnerability, and Control

A pragmatic cyber-risk model can be written as:

$$R = f(E, T, V, C), \quad (8.5)$$

where:

E is exposure; T is threat pressure; V is vulnerability; and C is control effectiveness.

Exposure asks how much valuable activity is reachable.

Threat asks how much adversarial pressure exists.

Vulnerability asks how susceptible the environment is.

Control effectiveness asks how much the institution reduces either probability or impact.

This is not a mechanical formula.

Its purpose is to structure thinking.

8.5 Inherent and Residual Risk

Inherent risk is the risk before controls.

Residual risk is the risk after controls.

A simple conceptual relationship is:

$$R_{\text{residual}} = R_{\text{inherent}} \times (1 - C_{\text{effective}}). \quad (8.6)$$

This formulation should not be interpreted too literally. Control effectiveness is difficult to measure and not all controls act independently.

However, it forces management to ask an important question:

Which controls actually move the loss distribution?

A control that looks impressive but has little effect on probability or severity may add cost without reducing material risk.

8.6 The AI Threat Lens: Threat Pressure Is Becoming Endogenous

Traditional cyber-risk models often treated threat intensity as an external parameter.

AI changes that assumption.

Frontier models can increase the productivity of attackers.

A useful conceptual multiplier is:

$$T_{\text{AI}} = T_0 \times M_{\text{capability}} \times M_{\text{automation}} \times M_{\text{parallelism}} \times M_{\text{persistence}}. \quad (8.7)$$

The multipliers are not directly observable constants.

They represent structural changes.

Capability Multiplier Frontier models can perform increasingly sophisticated code analysis, vulnerability discovery, reasoning, and technical interpretation.

The effect is to lower the expertise barrier for some tasks.

Automation Multiplier Agents can perform repeated analytical work without continuous human attention.

The effect is lower labor cost per task.

Parallelism Multiplier Multiple agents can work simultaneously.

The effect is scale.

Persistence Multiplier Long-horizon agents can preserve state and continue over extended sequences.

The effect is endurance.

For finance, these multipliers imply that historical incident-frequency estimates may understate future threat intensity if they ignore capability progress.

8.7 AI Can Affect Severity as Well as Frequency

AI does not only change the probability of attack.

It can also change impact.

Suppose an attacker identifies one vulnerable account.

Without automation, misuse may remain limited.

With agentic coordination, the attacker may more quickly identify related systems, privileges, and business processes.

This can increase severity.

A conceptual severity model is:

$$X_{\text{AI}} = X_0 \times S_{\text{speed}} \times S_{\text{authority}} \times S_{\text{coordination}} \times S_{\text{data access}}. \quad (8.8)$$

Again, this is a modeling framework rather than a calibration formula.

The key lesson is that AI can affect both axes of operational risk:

$$\text{Risk} = \text{Frequency} \times \text{Severity}. \quad (8.9)$$

8.8 Scenario Analysis

Cyber-risk scenario analysis is often more useful than pretending that one statistical distribution captures the future.

A scenario should answer:

What happens? Which system or identity is involved? What control fails? Which business process is affected? How long does disruption last? What financial losses follow? Which secondary effects appear?

A scenario should also distinguish:

$$\text{Gross Loss} \rightarrow \text{Control Mitigation} \rightarrow \text{Residual Loss.} \quad (8.10)$$

8.9 Scenario 1: Payment Identity Compromise

Consider a fictional bank.

A privileged payment-preparation account is compromised.

The account cannot release payments directly.

The gross loss scenario might assume:

unauthorized beneficiary changes; attempted high-value transfers; temporary payment suspension; forensic investigation; client communication; and legal review.

Segregation of duties limits direct fraud.

The residual loss may therefore be dominated by disruption and remediation rather than stolen funds.

This illustrates why control architecture affects severity.

8.10 Scenario 2: AI-Assisted Vulnerability Discovery

A fictional broker-dealer operates a proprietary order-management component.

A frontier AI system identifies a previously unknown software weakness.

If the defender finds it first, the loss may be close to zero.

If a malicious actor finds it first, the institution may face:

emergency patching; temporary trading restrictions; forensic review; client concern; and regulatory notification.

The scenario therefore depends on a race:

$$T_{\text{defender}} \quad \text{versus} \quad T_{\text{attacker}}. \quad (8.11)$$

A useful risk metric is the defensive window:

$$W = T_{\text{attacker action}} - T_{\text{defender remediation}}. \quad (8.12)$$

If $W > 0$, the defender closes the weakness first.

If $W < 0$, the attacker may act before remediation.

8.11 Scenario 3: Manipulated Autonomous Agent

Consider a fictional asset manager.

An AI research agent can access internal portfolio data and external research.

The agent proposes trades but cannot execute them.

A manipulation event causes the agent to produce inappropriate recommendations.

The direct loss is limited because a human reviews the trade.

Now change one assumption.

The same agent has autonomous execution authority for orders below \$2 million.

The loss distribution changes.

The risk can be represented as:

$$L_{\text{agent}} = P(\text{manipulation}) \times P(\text{action succeeds}) \times I(\text{economic authority}). \quad (8.13)$$

The architecture matters more than the model error alone.

8.12 Scenario 4: Exchange Outage

Consider a fictional exchange experiencing a six-hour outage during a volatile session.

Possible losses include:

lost transaction revenue; participant claims; operational remediation; regulatory costs; reputational damage; liquidity fragmentation; and market-quality deterioration.

The direct accounting loss may underestimate the economic effect.

A systemic financial institution may create externalities beyond its own balance sheet.

This is why operational-risk quantification for market infrastructure should include market consequences.

8.13 Tail Risk

Cyber losses are often heavy-tailed.

Many incidents are small.

A few can be very large.

This creates a distribution with:

$$P(X > x) \quad (8.14)$$

declining more slowly than in a conventional normal model.

For finance students, the practical lesson is that average loss is insufficient.

The institution should consider:

expected loss; severe but plausible loss; extreme stress loss; liquidity impact; and recovery time.

The relevant question is not:

What is the average cyber incident?

It is:

What happens if the rare incident hits a critical financial service at the worst possible time?

8.14 AI and Tail Risk

AI may increase tail risk through coordination.

A coordinated agent team can potentially compress many activities into a shorter period.

The institution may therefore experience a faster transition from initial access to material impact.

This creates a nonlinear effect.

A useful conceptual representation is:

$$L(t) = L_0 e^{\alpha t}, \quad (8.15)$$

where α represents the speed at which exposure compounds during an incident.

AI-enabled automation can increase α .

The purpose is not to claim exponential loss literally.

It is to emphasize that delay can become increasingly expensive.

8.15 Control Effectiveness

Controls should be evaluated by how they change probability or severity.

Examples include:

multifactor authentication; least privilege; segregation of duties; patching; asset inventory; network segmentation; backups; independent reconciliation; deterministic transaction limits; and AI-agent permission constraints.

A simple control-impact metric is:

$$\Delta R_C = R_{\text{before}} - R_{\text{after}}. \quad (8.16)$$

The highest-value controls are those that create the largest reduction in residual loss per unit cost.

8.16 The Economics of Security Investment

Suppose a control costs K .

Suppose it reduces expected annual loss from EL_0 to EL_1 .

The direct economic benefit is:

$$B = EL_0 - EL_1. \quad (8.17)$$

A simple decision rule is:

$$B > K. \quad (8.18)$$

But financial institutions should also consider tail-risk reduction, regulatory expectations, resilience, and strategic value.

A control may be justified even when expected-loss reduction alone appears modest.

8.17 AI-Specific Security Investment

AI creates new categories of control investment.

Examples include:

agent identity management; tool-permission gateways; prompt-injection-resistant architectures; external logging; memory provenance; AI-specific red teaming; model monitoring; human approval layers; autonomous-response limits; and kill switches.

The benefit of these controls should be evaluated against the authority granted to the agent.

A read-only research agent may require modest controls.

An autonomous payment agent requires much stronger governance.

8.18 Monte Carlo Simulation

Monte Carlo simulation can help explore uncertainty.

Suppose incident frequency is modeled as:

$$N \sim \text{Poisson}(\lambda). \quad (8.19)$$

Suppose severity is modeled as:

$$X_i \sim \text{Lognormal}(\mu, \sigma). \quad (8.20)$$

For each simulated year:

1. draw N ;
2. draw N severities;
3. sum the losses;
4. repeat many times.

This produces an empirical loss distribution.

We can then estimate:

mean annual loss; median loss; 95th percentile; 99th percentile; and probability of exceeding a threshold.

The model should be interpreted as scenario machinery, not truth.

8.19 Adding an AI Threat Multiplier

A simple classroom model can incorporate an AI threat multiplier.

Let baseline frequency be:

$$\lambda_0. \quad (8.21)$$

Define:

$$\lambda_{AI} = \lambda_0(1 + m), \quad (8.22)$$

where m is a hypothetical increase in threat intensity.

Similarly, severity may become:

$$X_{AI} = X_0(1 + s), \quad (8.23)$$

where s represents a hypothetical severity multiplier from faster escalation or broader authority.

Students can examine sensitivity.

The objective is not to forecast the exact effect of AI.

It is to understand how assumptions about AI change the loss distribution.

8.20 Stress Testing

Stress testing asks what happens under extreme but plausible assumptions.

For example:

frontier AI cuts vulnerability-discovery time by 70%; patch deployment remains unchanged; incident frequency doubles; autonomous agents have broader permissions; and a critical vendor fails simultaneously.

The institution can then evaluate:

capital impact; liquidity needs; operational capacity; recovery time; client obligations; and governance readiness.

8.21 Capital and Liquidity

Cyber risk can create liquidity needs even when accounting losses are not immediately large.

Examples include:

margin requirements; emergency vendor payments; client compensation; temporary duplication of systems; external forensic support; and legal and regulatory costs.

A stress framework should therefore consider:

$$\text{Cyber Loss} + \text{Liquidity Requirement} + \text{Operational Recovery Cost}. \quad (8.24)$$

8.22 Cyber Insurance

Insurance can transfer some cyber risk.

But insurance does not eliminate operational exposure.

Policies may contain:

exclusions; sublimits; deductibles; waiting periods; notification requirements; and control conditions.

A financial institution should understand which losses are insured and which remain on the balance sheet.

AI-enabled events may also create new coverage questions as autonomous systems become more common.

8.23 Model Risk in Cyber Quantification

Cyber-risk models are themselves models.

They can fail through:

poor data; outdated assumptions; incorrect independence assumptions; underestimated tail risk; unmodeled AI capability changes; and overconfidence in control effectiveness.

Therefore, cyber quantification should follow familiar model-risk principles:

$$\text{Design} \rightarrow \text{Validate} \rightarrow \text{Challenge} \rightarrow \text{Monitor} \rightarrow \text{Update.} \quad (8.25)$$

8.24 Financial Practice: The Autonomous Trading Agent

Consider a fictional hedge fund that allows an autonomous agent to execute trades up to \$1 million per order.

The firm estimates a 1% annual probability that the agent produces a materially wrong action due to manipulation, model error, or corrupted context.

Suppose the average gross loss from such an event is \$5 million.

A naive expected loss is:

$$EL = 0.01 \times 5,000,000 = 50,000. \quad (8.26)$$

But this estimate may be misleading.

If the agent can execute many transactions before detection, the tail loss may be much larger.

A daily aggregate limit, independent risk engine, and human approval threshold may dramatically reduce severity.

This illustrates why authority and detection time belong inside the loss model.

8.25 Mini Case: AI Threat Multiplier at a Broker-Dealer

A fictional broker-dealer has historically experienced one material cyber incident every five years.

Management assumes:

$$\lambda_0 = 0.2. \quad (8.27)$$

The risk team considers a scenario in which AI-enabled threat productivity increases incident frequency by 50%.

Then:

$$\lambda_{AI} = 0.2 \times 1.5 = 0.3. \quad (8.28)$$

Separately, the team assumes faster escalation increases average severity by 25%.

The exercise does not claim these numbers are forecasts.

It asks:

How sensitive is our risk profile to plausible changes in threat productivity?

This is the correct use of scenario analysis.

Finance and Operational-Risk Lens

AI risk should be modeled as a change in the economics of attack and defense, not as a magical new loss category. The key variables are speed, scale, automation, authority, and control response.

8.26 Safe Notebook Lab

Safe Notebook Lab

The companion notebook should build a synthetic cyber-loss model for a fictional financial institution.

Students can:

1. define baseline incident frequency;
2. define a synthetic severity distribution;
3. simulate annual losses;
4. calculate expected loss and tail percentiles;
5. introduce an AI threat multiplier;
6. introduce control-effectiveness assumptions;
7. compare gross and residual risk;

8. stress-test an autonomous-agent scenario.

A second exercise can compare three control architectures:

1. weak identity and broad agent authority;
2. strong identity but broad agent authority;
3. strong identity plus restricted agent authority and deterministic limits.

Students should observe how the loss distribution changes.

All data and assumptions must remain synthetic.

8.27 A Pragmatic Quantification Checklist

Finance professionals should ask:

1. What business process is being modeled?
2. Which loss channels are included?
3. What assumptions drive incident frequency?
4. What assumptions drive severity?
5. How are controls reflected?
6. Are tail losses modeled explicitly?
7. How does AI change speed, scale, automation, or authority?
8. Which assumptions are most uncertain?
9. How sensitive are results to those assumptions?
10. What liquidity requirement accompanies the loss?
11. Which losses are insured?
12. What management decision will the model support?

8.28 Chapter Summary

The main lessons of this chapter are:

1. Cyber-risk quantification should make uncertainty explicit rather than pretend the future is precisely measurable.
2. Frequency and severity should be modeled separately because they have different drivers.

3. Financial loss arises through fraud, downtime, market exposure, remediation, legal costs, client impact, and reputation.
4. Inherent risk depends on exposure, threat, vulnerability, and business criticality; residual risk depends on control effectiveness.
5. AI can change both frequency and severity through higher capability, automation, parallelism, persistence, and faster escalation.
6. AI-enabled vulnerability discovery can shorten the defensive window between weakness discovery and attempted misuse.
7. Scenario analysis is often more useful than one point estimate.
8. Tail risk matters because rare cyber incidents can affect critical financial services at the worst possible time.
9. Security investment should be evaluated by how much it changes the residual loss distribution.
10. Monte Carlo simulation is useful for sensitivity and scenario analysis, but it does not remove model uncertainty.
11. Cyber-risk models require model-risk governance and regular updating as AI capabilities change.
12. The most important AI variables are not model names but speed, scale, autonomy, tool access, and economic authority.

8.29 Review Questions

1. Why is cyber risk difficult to quantify precisely?
2. What is the difference between frequency and severity?
3. Give three financial loss channels created by a cyber incident.
4. What do exposure, threat, vulnerability, and control represent?
5. How can AI change incident frequency?
6. How can AI change incident severity?
7. What is the defensive window?
8. Why is scenario analysis especially useful for cyber risk?
9. Why can expected loss underestimate the importance of cyber risk?
10. How should control effectiveness be incorporated into a loss model?

11. What is the purpose of an AI threat multiplier in a classroom model?
12. Why should cyber-risk quantification itself be subject to model-risk governance?

Chapter 9

Governance, Third Parties, and Institutional Accountability in the Age of Agentic AI

Learning Objectives

By the end of this chapter, the reader should be able to: explain why cybersecurity and AI risk are institutional governance issues rather than technology-department issues; describe board, senior-management, business, risk, compliance, audit, and technology responsibilities; understand how third-party providers, cloud services, model vendors, software dependencies, and autonomous agents create concentration and contagion risk; identify the principal governance challenges created by frontier AI models, tool-using agents, multi-agent teams, persistent memory, and autonomous workflows; describe, at a safe and non-operational level, how AI-enabled threat actors may exploit institutional dependencies, delegated authority, vendors, and trust relationships; evaluate practical defenses based on ownership, segregation of duties, agent identity, permission boundaries, vendor due diligence, evidence, testing, kill switches, and resilience; and connect AI and cyber governance directly to financial stability, fiduciary responsibility, operational resilience, valuation, payments, trading, and market infrastructure.

9.1 Cybersecurity Is Not an IT Problem

One of the most persistent governance errors is to classify cybersecurity as an information-technology problem. Technology teams are indispensable because they design, operate, secure, and recover the systems on which the institution depends. Nevertheless, the consequences of failure belong to the institution as a whole. A disrupted payment platform can create missed obligations and liquidity pressure; corrupted market data can affect valuation and trading; compromised client information can produce legal liability and loss of confidence; and unavailable reporting systems can prevent the institution from meeting regulatory deadlines. These are not merely technical outcomes. They are failures of the financial operating model.

The same principle applies even more strongly to artificial intelligence because an AI

system may participate directly in judgment and action. An autonomous treasury agent can become part of the process through which liquidity is forecast, funding is allocated, or payment instructions are prepared. A trading agent may influence portfolio decisions or submit orders. A compliance agent may determine which transactions receive scrutiny and which are allowed to proceed without intervention. Once a system performs such work, its reliability, authority, and supervision become matters of business governance. Management cannot transfer accountability to the technology team simply because software mediates the decision.

This distinction changes the questions that leaders should ask. The relevant inquiry is not only whether the platform is technically secure, but whether the financial process remains controlled when the platform is wrong, unavailable, manipulated, or dependent on an external provider. The institution must know who can interrupt the process, which obligations must continue, how records will be reconciled, and who may accept the remaining risk. Cybersecurity therefore sits at the intersection of technology, finance, operations, law, compliance, and strategy.

Therefore:

$$\text{Technology Ownership} \neq \text{Risk Ownership.} \quad (9.1)$$

Technology may operate the platform, but the business owns the financial consequence. Risk and compliance provide challenge, internal audit provides assurance, and senior management determines whether the resulting exposure is consistent with the institution's obligations and risk appetite. Treating cybersecurity this way prevents technical activity from becoming detached from the services and stakeholders it is intended to protect.

9.2 Governance Begins with Accountability

A well-governed institution should be able to answer five questions for every critical cyber or AI system:

1. Who owns the business process?
2. Who owns the technology?
3. Who owns the risk?
4. Who approves material changes?
5. Who is accountable when the system fails?

These questions are concise, but their answers must be operational rather than ceremonial. Naming a business owner is not enough if that person cannot approve limits, obtain evidence, stop the system, or fund remediation. Likewise, naming a technical owner provides little assurance if model changes, vendor dependencies, and access permissions remain outside that

owner's visibility. Accountability requires decision rights, access to reliable information, and a defined duty to act.

If the answers are unclear, the institution has a governance vulnerability. Complex systems naturally diffuse responsibility: a business unit may say that technology selected the model; technology may point to the vendor's design; the vendor may argue that the institution configured the tools; and risk personnel may note that management accepted the residual exposure. During normal operations this ambiguity may remain hidden. During an incident it delays containment, weakens communication, and makes it difficult to determine who can authorize exceptional measures.

Good governance resolves those questions before failure. A material system should have an accountable executive, documented operational and technical owners, an independent risk challenger, explicit change authority, and a tested escalation path. The record should also identify who may suspend the system, invoke a fallback process, communicate with clients or regulators, and approve restoration. Accountability is therefore not principally about assigning blame after an event. It is about ensuring that qualified people possess the authority and information needed to protect the institution while the event is unfolding.

9.3 The Three Lines

A familiar governance framework is the three-lines model.

First Line: Business and Operations The first line owns the activity and is responsible for operating it within approved limits. A treasury function remains accountable for treasury decisions, a trading function for trading decisions, and an asset-management operation for valuation and portfolio processes. If an AI agent becomes part of those activities, the business must understand what the agent does, what information it relies upon, where human judgment remains necessary, and how errors will be detected. The agent does not become the risk owner, nor does procurement of a vendor service transfer the business's fiduciary or regulatory duties. First-line ownership means accepting responsibility for the design of the workflow, the suitability of its controls, and the consequences of using automation.

Second Line: Risk and Compliance The second line establishes risk frameworks, challenges assumptions, sets standards, monitors limits, and provides independent oversight. Its purpose is not to operate the system on behalf of the business, but to test whether the first line has identified material exposure and designed controls proportionate to it. For agentic AI, that challenge should examine the agent's authority, accessible data, permitted tools, persistence, vendor dependence, and potential effect on clients or markets. The second line should also ask which controls exist outside the model, how deviations become visible, what happens when behavior is unpredictable, and whether management has overstated the protection offered by human review. Effective challenge produces documented decisions, remediation commitments, and escalation when exposure exceeds appetite.

Third Line: Internal Audit Internal audit provides independent assurance that the governance framework is designed coherently and operates as management represents. Audit need not reproduce every technical cybersecurity test. It should determine whether ownership is real, approvals are supported by evidence, permissions reflect policy, monitoring reaches accountable leaders, and incidents produce corrective action. For AI systems, the audit scope may include model and configuration changes, agent inventories, exceptions, vendor controls, memory governance, recovery tests, and the integrity of independent logs. The central assurance question is whether the institution can demonstrate control through evidence rather than relying on policy statements or management confidence.

9.4 Board Responsibility

The board should not configure firewalls, select technical detection rules, or evaluate source code. It should understand the material exposures created by the institution's dependence on digital services and autonomous systems. Directors need a clear view of which services are critical, which AI systems can create or influence financial actions, where vendor concentration exists, and which failures could harm clients, counterparties, or markets. They should also understand what management considers unacceptable, which incidents require immediate escalation, whether recovery procedures have been demonstrated, and whether autonomous systems can be stopped without relying on the systems themselves.

This oversight depends on decision-useful reporting. A dashboard containing thousands of alerts or technical vulnerability counts may obscure rather than clarify risk. Board reporting should connect technical conditions to critical services, quantify or describe plausible financial consequences, identify overdue management actions, and show whether controls have been tested. Trends matter more than isolated numbers: recurring exceptions, expanding agent authority, repeated recovery failures, or increasing reliance on one provider may indicate a structural weakness even when no major loss has occurred.

The board's role is challenge, oversight, and accountability. Directors should ask management to explain assumptions, alternatives, and residual exposure, while avoiding direct involvement in daily operations. Their responsibility is fulfilled when material risk receives informed attention, decision rights are clear, resources match the exposure, and management can demonstrate that the institution is prepared to contain failure and restore trusted operations.

A useful principle is:

$$\text{Board Oversight} = \text{Material Risk} + \text{Decision Rights} + \text{Evidence} + \text{Challenge}. \quad (9.2)$$

9.5 Risk Appetite

Cybersecurity discussions often use language such as “zero tolerance,” but the phrase is rarely practical unless it refers to a narrowly defined prohibited outcome. Financial institutions

cannot operate with zero cyber exposure. Every online service, employee account, vendor connection, software dependency, and digital workflow creates some possibility of error, interruption, or misuse. A broad declaration of zero tolerance can therefore conceal difficult choices instead of guiding them.

The purpose of risk appetite is to distinguish risks the institution is willing to accept from conditions that require prevention, mitigation, escalation, or withdrawal. That distinction should be expressed in operational terms. An institution might prohibit autonomous payment release above a defined amount, prevent one AI identity from modifying both a trading limit and a trade, require tested recovery for critical production services, impose remediation periods for severe vulnerabilities, and require contingency arrangements for critical vendors. Each statement connects a management intention to a condition that can be monitored and enforced.

Risk appetite also needs an exception process. Temporary departures may sometimes be necessary, but they should have an accountable approver, a documented rationale, compensating controls, an expiration date, and a plan for closure. Without those elements, exceptions quietly become the normal operating model. Effective risk appetite is therefore not a slogan about being cautious. It is a system of boundaries, measurements, escalation triggers, and explicit decisions about residual exposure.

9.6 The AI Threat Lens: Governance Is Becoming a Cyber Control

As frontier AI capability increases, governance becomes part of the technical defense.

OpenAI's August 2026 deployment-safety update treats the latest GPT-5.6 Sol and Luna releases as High capability in cybersecurity under its Preparedness Framework.¹

OpenAI's broader GPT-5.6 system documentation similarly describes substantial cyber capability and extensive safeguards.²

Anthropic's Project Glasswing provides another indication of the frontier. Anthropic reports that partners using Claude Mythos Preview have identified large numbers of serious vulnerabilities across major software environments.³

The UK AI Security Institute reports that the length of cyber tasks frontier models can autonomously complete has been increasing rapidly, with recent systems exceeding previous capability trends.⁴

The implication for financial governance is profound.

The institution can no longer ask only:

Which AI model are we using?

It must ask:

¹<https://deploymentsafety.openai.com/gpt-5-6-august-update>

²<https://deploymentsafety.openai.com/gpt-5-6>

³<https://www.anthropic.com/news/expanding-project-glasswing>

⁴<https://www.aisi.gov.uk/blog/how-fast-is-autonomous-ai-cyber-capability-advancing>

Which system is the model embedded in, which tools does it control, which data does it consume, which agents does it coordinate, and what authority can the overall architecture exercise?

9.7 The System Is the Unit of Risk

A frontier model without tools may create limited direct operational exposure.

A moderately capable model with broad permissions may create far more risk.

Therefore:

$$R_{\text{agentic system}} = f(M, T, A, D, P, S, G), \quad (9.3)$$

where:

M is model capability; T is tool access; A is autonomy; D is data access; P is permissions; S is system coordination; and G is governance effectiveness.

The last variable matters enormously.

Governance can reduce the consequences of high capability.

9.8 Typical AI-Enabled Governance Attack Surfaces

Threat actors increasingly benefit from the same institutional complexity that creates operational efficiency.

The following strategies are described only at a defensive and conceptual level.

1. Trust-Relationship Exploitation Financial institutions trust vendors, counterparties, software providers, employees, APIs, and service accounts.

An attacker may seek to exploit those trust relationships rather than directly attack the final system.

The strategic lesson is:

$$\text{Trusted Connection} \neq \text{Risk-Free Connection}. \quad (9.4)$$

2. Third-Party Dependency Analysis AI can process large amounts of public and technical information to identify organizational dependencies.

The strategic effect is improved understanding of where one supplier or service supports many institutions.

For defenders, the implication is concentration-risk analysis.

3. AI-Assisted Social Engineering of Vendors A vendor relationship often involves regular communication.

AI can make fraudulent communications more personalized, fluent, and context-aware.

The relevant protection is independent verification of high-impact instructions.

4. Automated Supply-Chain Analysis AI can assist with reviewing software dependencies and identifying weak components.

This is highly valuable defensively.

It also means that weak links in software supply chains may be identified faster by adversaries.

Institutions need accurate software inventories and dependency governance.

5. Compromised Agent Trust One internal agent may rely on another.

A malicious or corrupted message can propagate if agents automatically trust each other.

This creates a new form of institutional contagion:

$$A_1 \rightarrow A_2 \rightarrow A_3 \rightarrow \text{Financial Action.} \quad (9.5)$$

Agent-to-agent communication therefore needs identity, provenance, and authorization.

6. Delegated Authority Abuse A threat actor may not need direct authority if it can manipulate an agent that possesses authority.

The threat therefore becomes indirect:

$$\text{Adversary} \rightarrow \text{Manipulated Agent} \rightarrow \text{Authorized Tool} \rightarrow \text{Financial Action.} \quad (9.6)$$

This is one of the most important governance risks of autonomous systems.

9.9 Third-Party Risk

Financial institutions depend heavily on external providers for cloud infrastructure, market data, pricing, payments, custody, communications, identity, cybersecurity, software components, and AI models. These relationships allow firms to obtain specialized capability, scale rapidly, and avoid duplicating infrastructure. In many cases outsourcing strengthens resilience because a mature provider can invest more deeply in security and availability than an individual institution could justify on its own.

The governance problem is that operational responsibility can be outsourced while institutional accountability cannot. If a pricing provider fails, the asset manager still owes clients a defensible valuation. If a cloud platform is unavailable, the bank still has payment and reporting obligations. If an AI provider changes model behavior, the institution remains responsible for decisions made within its workflow. Management must therefore understand not only whether a vendor is generally reputable, but exactly which business services depend on it, what data and authority cross the boundary, and how the institution will continue operating when the service fails.

Third-party dependence also creates concentration and contagion. One provider may support many functions within one institution or many institutions across the market. A common outage, compromised software update, identity-provider failure, or model defect can therefore produce simultaneous disruption. The risk cannot be assessed adequately by

reviewing each contract in isolation. It must be aggregated across services, legal entities, business units, subcontractors, and the wider financial ecosystem.

9.10 AI Model Providers as Critical Vendors

Model providers introduce a distinctive dependency because the service is not merely computational infrastructure. The institution may rely on model availability, behavior, API access, pricing, safety controls, data-handling policies, update practices, and regional availability. Changes in any of these dimensions can alter a workflow even when the institution has not modified its own application code. A model update may improve general capability while changing output style, tool-selection behavior, refusal patterns, latency, or performance on a specialized financial task.

This creates model-version risk. A workflow validated with one version should not automatically be assumed safe with its successor, particularly when the agent can invoke tools or influence financially material decisions. A robust institution should document the models used in critical workflows, preserve configuration and evaluation records, test significant upgrades against representative scenarios, and maintain a controlled method for rollback. It should also distinguish provider assurances from institution-specific evidence: a model can perform well in broad evaluations and still fail under the firm’s data, prompts, controls, or operating conditions.

Vendor governance must also address discontinuation and access changes. A provider may retire a model, modify usage terms, restrict a capability, or experience regional disruption. Critical processes require a migration plan that identifies acceptable substitutes, data portability, revalidation requirements, and the period during which manual or reduced-service operation is possible.

9.11 Cloud and Model Concentration

Consider a financial institution that uses one cloud provider and one AI model provider for multiple critical functions.

The architecture may be efficient.

But failure of either dependency can affect many business processes simultaneously.

A concentration metric can be conceptualized as:

$$C = \sum_{i=1}^n w_i^2, \tag{9.7}$$

where w_i represents the share of critical services dependent on provider i .

The formula resembles concentration metrics used elsewhere in finance.

The point is intuitive: dependence concentrated in one provider creates more common-mode risk.

9.12 Vendor Due Diligence

Vendor due diligence should go beyond questionnaires because a completed questionnaire mainly records representations at one point in time. For a critical provider, management should understand the service architecture, accessible data, subcontractor chain, geographic concentration, identity controls, recovery capability, incident history, notification commitments, change policies, audit rights, and termination arrangements. The depth of review should reflect business criticality and substitutability. A provider supporting an easily replaced administrative tool does not require the same scrutiny as one supporting payments, valuation, client authentication, or trading.

AI vendors require additional examination because model behavior and data handling may be partly opaque. The institution should identify the model versions in use, whether the provider can change them automatically, how prompts and outputs are retained, whether customer data can be used for training, which personnel or subcontractors can access content, and what tools a provider-side agent may invoke. It should also determine what evidence will be available after an incident. Without version history, protected logs, and cooperation obligations, the institution may be unable to reconstruct why an agent produced or executed a particular action.

Due diligence should lead to a decision, not simply a file of documents. Management should state the residual concerns, required contractual protections, control owners, monitoring plan, and circumstances that would trigger escalation or exit. Critical assumptions should be verified periodically through service reviews, assurance reports, recovery exercises, incident analysis, and tests of data portability. The purpose is to maintain a current view of dependency rather than to declare the vendor permanently approved.

9.13 The Software Supply Chain

Modern financial software depends on many components.

A trading application may incorporate operating-system libraries, open-source packages, commercial software, APIs, cloud services, and internal code.

The institution may therefore inherit vulnerabilities from components it did not create.

AI-assisted vulnerability discovery makes supply-chain governance more urgent because weaknesses can be found faster and at greater scale.

The institution should maintain:

$$\text{Application} \rightarrow \text{Dependencies} \rightarrow \text{Versions} \rightarrow \text{Owners} \rightarrow \text{Risk}. \quad (9.8)$$

An undocumented dependency is a governance failure.

9.14 Agent Supply Chains

Autonomous systems create a new dependency chain.

An agent may rely on:

a frontier model; an embedding model; a vector database; a search service; an orchestration framework; a tool gateway; cloud infrastructure; and external data sources.

A weakness in any component may affect the behavior of the full system.

The agent should therefore be governed as an ecosystem rather than one model.

9.15 Policies, Standards, Procedures, and Controls

Good governance needs a hierarchy.

Policy states what the institution requires.

Standard defines mandatory minimum conditions.

Procedure describes how the requirement is performed.

Control prevents, detects, or corrects failure.

Evidence demonstrates that the control operated.

This can be written as:

$$\text{Policy} \rightarrow \text{Standard} \rightarrow \text{Procedure} \rightarrow \text{Control} \rightarrow \text{Evidence}. \quad (9.9)$$

AI governance should follow the same structure.

A policy saying “AI must be safe” is insufficient.

A useful standard might say:

Any AI agent with financial execution authority must have a unique identity, externally logged actions, predetermined economic limits, and an independent kill mechanism.

That statement can be tested.

9.16 Agent Governance

Every material agent should have an institutional record that allows management to understand both its purpose and its maximum credible consequence. The record should identify the business and technical owners, model provider and version, approved use, accessible data, permitted tools, authority limits, human approval requirements, monitoring arrangements, fallback process, and kill procedure. It should also document dependencies and connections to other agents, because an apparently low-risk component may contribute to a high-impact workflow.

This record is the agent equivalent of a user-access inventory, but it must capture more than credentials. Human access reviews typically ask what a person can reach. Agent governance must additionally ask how long the agent can operate, how it chooses among tools, what memory it retains, which instructions it treats as authoritative, and how quickly its activity can scale. The inventory should be reconciled with actual identities, API keys, tool gateways, and network activity so that undocumented or abandoned agents do not retain authority.

Ownership records should be reviewed whenever the agent’s model, tools, data, autonomy, or business purpose changes. A research assistant can become materially different when connected to email, persistent memory, an order-management system, or a production database. Governance should treat such changes as changes in risk classification, not merely enhancements to functionality.

9.17 Segregation of Duties for Agent Teams

Multi-agent architectures create opportunities for deliberate separation.

Instead of one agent controlling the entire process:

Research Agent → Recommendation Agent → Risk Agent → Execution Gateway. (9.10)

The execution gateway can enforce deterministic policy.

This architecture is safer than allowing the research agent to execute directly.

However, separation is meaningful only if the agents do not share unrestricted permissions.

9.18 Governance of Agent Memory

Persistent memory deserves explicit governance.

Memory may contain:

prior instructions; user preferences; transaction history; learned relationships; risk judgments; and workflow state.

If memory becomes inaccurate or manipulated, future actions may inherit the error.

Therefore, institutions should define:

what may enter memory; which sources are authoritative; who may modify memory; how long memory persists; how memory is audited; and how trusted state is restored.

9.19 Governance of Frontier Cyber Models

Highly capable cybersecurity models require stronger controls.

The relevant governance dimensions include:

user access; permitted tasks; tool restrictions; logging; human oversight; environment isolation; disclosure procedures; and output handling.

Anthropic’s Project Glasswing illustrates one defensive governance approach: access to Mythos Preview was initially limited to selected partners using the model to identify and remediate vulnerabilities in critical software.⁵

OpenAI similarly describes stronger safeguards as cyber capabilities increase.⁶

The finance lesson is straightforward:

⁵<https://www.anthropic.com/glasswing>

⁶<https://openai.com/index/gpt-5-6/>

Core Intuition

More capable cyber models should not automatically receive broader institutional authority. Higher capability should normally lead to stronger governance.

9.20 Protection Strategy 1: Inventory Every Material Agent

An institution cannot govern what it cannot identify. The organization should therefore maintain an inventory of AI systems and agents that is sufficiently detailed to support access review, incident response, concentration analysis, and recovery. Discovery should not depend exclusively on voluntary registration. Procurement records, cloud usage, API credentials, network activity, expense data, software repositories, and identity platforms can reveal systems that have developed outside the formal approval process.

Shadow AI is the AI equivalent of shadow IT, but autonomous workflows can make the exposure more consequential. An unregistered assistant may retain confidential material, hold long-lived credentials, interact with external services, or take actions that its creator did not regard as operationally significant. Risk teams may therefore be unaware of the data involved, the authority delegated, or the provider dependencies created. A mature inventory process combines clear policy with practical discovery and offers a proportionate route for low-risk experimentation so that employees are not encouraged to conceal useful innovation.

9.21 Protection Strategy 2: Separate Vendor Access from Business Authority

A vendor may provide the intelligence layer, but it should not automatically control the business authority layer. A model provider can generate analysis or a recommendation while institution-controlled systems determine whether a payment is released, a trade is executed, code is deployed, a permission is changed, or sensitive data leave the environment. This separation preserves the institution's ability to enforce its own policies even when the vendor's model behaves unexpectedly.

The boundary should be technical as well as contractual. High-impact actions should pass through gateways that authenticate the agent, validate the requested action, apply deterministic limits, obtain required approval, and create an independent record. If the model provider also supplies the sole authorization mechanism and the sole audit trail, one dependency controls reasoning, action, and evidence. Separating these functions reduces common-mode failure and makes substitution, investigation, and containment more credible.

9.22 Protection Strategy 3: Contract for Evidence

Incident response requires evidence that remains available when the relationship is under stress. Critical vendor contracts should address logging, incident notification, data retention, audit cooperation, model-version history, subcontractor identification, and security testing.

The terms should specify timing, format, retention, and access rather than relying on a general promise to cooperate. A notification received days after a critical event, or a log that omits tool calls and configuration changes, may not support an effective response.

Contracting for evidence is not an attempt to transfer all investigative responsibility to the provider. The institution should preserve its own logs at important control boundaries and reconcile them with vendor records. Independent evidence helps establish what information entered the service, what action was requested, which controls responded, and whether the provider changed the model or environment. Without that foundation, management may be unable to estimate impact, meet reporting obligations, resolve client disputes, or restore a trusted state.

9.23 Protection Strategy 4: Build Exit Plans

A critical provider should not become impossible to replace. Exit planning includes data portability, alternative providers, manual fallback, contractual termination, recovery or revocation of credentials, preservation of records, and migration testing. The plan should identify which functions can move quickly, which require redevelopment or revalidation, and how long the institution can operate in a degraded state.

This capability can be understood as vendor liquidity: the practical ability to exit a dependency under stress without accepting an unacceptable discount in service quality, control, or continuity. A theoretical right to terminate is not enough when data formats are proprietary, integrations are undocumented, or no alternative has been tested. Exit readiness should therefore be demonstrated through exercises and selective migrations, not inferred from contract language alone.

9.24 Protection Strategy 5: Test Concentration Scenarios

Institutions should stress-test simultaneous failures.

For example:

What if our cloud provider and primary AI provider are both unavailable for six hours during a volatile market?

Or:

What if a widely used software component is found vulnerable by frontier AI and requires immediate remediation across many systems?

The purpose is to understand common-mode risk.

9.25 Protection Strategy 6: Independent AI Control Layer

High-impact agent actions should pass through an institution-controlled gateway. The gateway can authenticate the agent, restrict available tools, apply monetary and temporal limits, verify

counterparties, prevent prohibited data movement, collect human approval where required, and write logs outside the agent’s control. These safeguards are especially important when natural-language reasoning is connected to deterministic financial infrastructure.

The design does not assume that the model is untrustworthy in every interaction. It recognizes that probabilistic systems can make mistakes, encounter manipulated content, or behave differently after an update. By separating reasoning from authorization, the institution can benefit from flexible analysis while preserving stable control over consequential actions. The model reasons; the institution authorizes. That division is one of the clearest ways to convert governance policy into enforceable architecture.

9.26 Financial Practice: Third-Party Pricing Provider

Consider a fictional asset manager whose primary pricing vendor suffers a cyber outage at month-end.

The firm cannot obtain validated closing prices for several hundred securities.

The immediate problem is not only vendor availability.

It affects:

NAV calculation; client reporting; risk measures; performance reporting; and possible subscriptions and redemptions.

A well-governed firm has an alternative source, documented valuation hierarchy, escalation procedures, and evidence supporting any manual overrides.

This is third-party cyber risk translated into financial practice.

9.27 Financial Practice: External AI Research Provider

Suppose an investment bank uses an external AI provider to analyze confidential transaction documents.

The business owner focuses on analytical quality.

Cyber and governance teams must ask additional questions:

Where are the documents processed? Who can access them? Are outputs retained? Does the model provider use the information for training? What happens if the model changes? Which subcontractors participate? Can the institution export its records?

The AI system has become part of the confidentiality architecture of the transaction.

9.28 Financial Practice: Autonomous Vendor-Management Agent

A fictional bank deploys an agent that reviews vendors, reads contracts, tracks incidents, and recommends risk ratings.

Initially, the agent is advisory.

Management later allows it to automatically suspend vendor API credentials when it detects a serious risk.

The agent now possesses operational authority.

A false positive could disable a critical service.

The institution therefore needs:

confidence thresholds; critical-vendor exceptions; human approval for major suspensions; complete logging; and rapid rollback.

The lesson is the same throughout the book:

$$\text{Intelligence} \neq \text{Authority}. \quad (9.11)$$

9.29 Mini Case: Common AI Dependency

A fictional financial group operates:

an AI research assistant; an AI compliance assistant; a treasury forecasting agent; a software-development assistant; and a customer-service agent.

All five use the same frontier-model provider.

The business units initially treat them as five separate systems.

From a concentration-risk perspective, they are one dependency.

A material provider outage or model-behavior problem can affect all five functions simultaneously.

The group should therefore evaluate aggregate exposure.

A useful measure is:

$$E_{\text{provider}} = \sum_{j=1}^n w_j C_j, \quad (9.12)$$

where w_j represents dependence and C_j the criticality of service j .

The precise numerical score is less important than the discipline of aggregation.

Finance and Operational-Risk Lens

Third-party AI risk should be governed like concentration risk in finance. The institution must understand not only the probability that one vendor fails but also how many important activities fail together.

9.30 Safe Notebook Lab

Safe Notebook Lab

The companion notebook should create a synthetic governance inventory for a fictional financial institution.

Students can define:

1. ten financial business services;
2. several technology vendors;

3. two AI model providers;
4. five autonomous agents;
5. data dependencies;
6. tool permissions;
7. business owners;
8. control owners;
9. recovery alternatives.

The notebook should calculate simple concentration indicators and identify: single points of failure; agents with excessive authority; services dependent on the same vendor; systems without fallback; and missing ownership.

A second exercise can simulate loss of one provider and estimate which business processes become unavailable.

The notebook should remain entirely synthetic and should not connect to external vendor environments or real institutional systems.

9.31 A Pragmatic Governance Checklist

Boards, risk committees, and senior management should ask:

1. Which AI and cyber systems are material to the institution?
2. Who owns each system and its financial consequences?
3. Which agents possess economic authority?
4. Which vendors support multiple critical services?
5. Which dependencies create common-mode failure?
6. Are critical AI models version-controlled and tested before upgrades?
7. Are agent tools and permissions independently governed?
8. Is persistent agent memory controlled and auditable?
9. Are third-party incidents contractually reportable?
10. Can the institution reconstruct agent and vendor actions after an incident?
11. Does every critical provider have a credible exit or fallback plan?
12. Are AI-specific scenarios included in business-continuity testing?
13. Can management stop an autonomous system without relying on the system itself?

9.32 Chapter Summary

The main lessons of this chapter are:

1. Cybersecurity and AI risk belong to institutional governance because their consequences affect financial obligations, clients, markets, and strategy.
2. Technology ownership and risk ownership are different.
3. The three-lines model remains useful, but AI systems require explicit business ownership, risk oversight, and independent assurance.
4. Boards should govern material exposure, authority, concentration, resilience, and evidence rather than technical implementation.
5. Frontier cyber capability makes governance itself a defensive control.
6. The relevant unit of AI risk is the full agentic system: model, tools, data, permissions, autonomy, coordination, and governance.
7. Typical AI-enabled governance threats include exploitation of trust relationships, third-party dependencies, software supply chains, delegated authority, and agent-to-agent trust.
8. AI model providers may become critical vendors and concentration points.
9. Agent ecosystems create new supply chains involving models, orchestration frameworks, memory systems, tools, and cloud providers.
10. Material agents require inventories, identities, permissions, ownership, limits, monitoring, and kill procedures.
11. Critical vendor contracts should preserve evidence, incident notification, portability, and exit rights.
12. High-impact agent actions should pass through institution-controlled authorization layers.
13. Third-party AI exposure should be aggregated across business units rather than assessed one application at a time.

9.33 Review Questions

1. Why is cybersecurity not simply an IT risk?
2. What is the difference between technology ownership and risk ownership?
3. How does the three-lines framework apply to autonomous AI systems?

4. Which questions should a board ask about material AI agents?
5. Why is the full agentic system a better unit of risk than the model alone?
6. How can AI increase third-party and supply-chain risk?
7. What is agent-to-agent trust risk?
8. Why should AI model providers be treated as potentially critical vendors?
9. What is model-version risk?
10. Why should persistent agent memory be governed explicitly?
11. What does it mean to contract for evidence?
12. Why is an exit plan important for critical AI and cloud providers?
13. In the common-provider case, why are five applications potentially one concentration exposure?

Chapter 10

A Finance Professional's Cyber-Risk Playbook in the Age of Agentic AI

Learning Objectives

By the end of this chapter, the reader should be able to integrate cybersecurity, operational risk, AI-system risk, and governance into one decision framework. The reader should be able to evaluate exposure in banks, asset managers, broker-dealers, exchanges, payment businesses, fintechs, and market infrastructure; distinguish what should be automated from what should remain under explicit human authority; recognize material warning signs involving identity, data, applications, agents, vendors, and recovery; and translate technical evidence into decisions about valuation, lending, investment, liquidity, resilience, and board oversight.

10.1 The Finance Professional's Objective

A finance professional does not need to become a penetration tester to make sound cyber-risk decisions. The relevant capability is translation. Technical exposure must be connected to the business process it supports, the financial consequence of failure, the control that should prevent or limit harm, and the person or body authorized to accept the remaining risk. A weakness in a server, an unusual authentication event, or an anomalous AI-agent action has no complete management meaning until those relationships are understood.

The practical chain is:

$$\begin{aligned} \text{Technical Evidence} &\rightarrow \text{Business Process} \rightarrow \text{Financial Consequence} \\ &\rightarrow \text{Control Decision} \rightarrow \text{Accountability.} \end{aligned} \tag{10.1}$$

This approach prevents two common errors. The first is to dismiss cybersecurity as a specialist technology concern even when it affects payments, positions, valuations, client assets, or market access. The second is to treat every technical finding as equally important. A weakness matters because of the authority, information, dependencies, and financial services reachable through it. Prioritization should therefore reflect business criticality rather than

technical severity alone.

Artificial intelligence makes this translation more important. A model is not materially risky merely because it is capable, and an agent is not safe merely because its task sounds administrative. The relevant question is what the surrounding system permits. An AI service may read sensitive documents, preserve memory, call tools, communicate with other agents, modify records, prepare transactions, or initiate workflows. Its financial risk depends on the combination of capability and authority, the reliability of its inputs, the breadth of its permissions, the duration of its autonomy, and the controls that remain independent of the model.

10.2 One Integrated Management Cycle

The concepts in this book can be organized into a continuous management cycle: understand the institution, assess the exposure, design controls, monitor behavior, respond proportionately, recover a trusted state, and learn. This is not an annual compliance sequence. Each stage changes the information available to the next, and a material change in technology, business activity, vendor dependence, or AI capability should cause the cycle to begin again.

Understanding begins with critical financial services. Management should know which services must remain reliable, which data and identities they require, which applications and agents exercise authority, and which external providers create material dependencies. Assessment then asks how an unauthorized outcome could occur, how likely or plausible the pathway is, how much loss it could create, and which controls genuinely change probability or severity. Control design converts this analysis into access boundaries, approval conditions, deterministic limits, reconciliation, monitoring, containment, and recovery.

Monitoring should reveal whether the institution remains within those boundaries. It should observe human and machine identities, data changes, application behavior, vendor conditions, and agent tool use. Response should limit harm without creating unnecessary interruption, while recovery should restore trusted identities, data, software, memory, and financial records. Learning should change the architecture, not merely produce a report. A near miss that exposes excessive authority or a fragile dependency deserves action even when no loss occurs.

AI affects every stage. It introduces new assets, identities, dependencies, and attack surfaces during understanding; changes assumptions about speed and scale during assessment; requires tool and memory controls during design; creates new telemetry during monitoring; can accelerate both investigation and harmful action during response; and complicates recovery because the institution may need to validate context, memory, model versions, and agent state. Treating AI as one isolated risk category would therefore miss its interaction with the whole operating model.

10.3 The Institution as a Network of Trust and Authority

A modern financial institution is a network of trust relationships. Clients trust the institution to preserve assets and information. Employees trust applications and data. Applications trust identities, interfaces, and vendors. Counterparties trust payment and settlement instructions. Markets trust infrastructure to remain available and impartial. AI agents may trust documents, tools, memory, and other agents. Cybersecurity protects these relationships by ensuring that trust is granted to the correct party, for the correct purpose, within an acceptable boundary.

A failure occurs when trust and authority are assigned incorrectly. A valid credential may be used by the wrong person. Accurate software may process corrupted data. A legitimate vendor connection may receive excessive access. A well-performing model may act on manipulated context. A defensive agent may correctly identify an anomaly but apply a containment action whose financial cost exceeds the risk it was intended to reduce. The common structure is:

$$\text{Cyber Consequence} = f(\text{Incorrect Trust, Available Authority, Business Criticality, Control Failure}). \quad (10.2)$$

This explains why identity, provenance, least privilege, segregation of duties, independent verification, and recovery recur throughout the book. These are not unrelated best practices. They are methods for controlling the conversion of trust into action.

10.4 AI Capability Is a Management Variable

The cyber capability of frontier AI systems is changing rapidly. Public evaluations increasingly examine whether models can complete longer and more complex cybersecurity tasks with less human assistance, while institutions such as NIST frame the problem through the cybersecurity of AI systems, AI-enabled attacks, and AI-enabled defense.¹ The UK AI Security Institute has similarly reported rapid growth in the length of cyber tasks that advanced systems can complete autonomously.²

Management should not build its risk architecture around model names. Names, versions, providers, and benchmark results will change more quickly than institutional controls. The durable approach is to evaluate capability classes and operating authority. A text-only advisory model has a different risk profile from a tool-using assistant. A bounded workflow agent differs from a system that can plan, act, evaluate results, and continue. A coordinated multi-agent system differs again because it can divide work, preserve shared state, and create interactions that no single component fully represents.

The full system is therefore the proper unit of risk:

$$R_{\text{AI}} = f(\text{Model Capability, Tool Access, Autonomy, Permissions, Data, Memory, Dependencies, Criticality}). \quad (10.3)$$

¹<https://www.nccoe.nist.gov/projects/cyber-ai-profile>

²<https://www.aisi.gov.uk/blog/how-fast-is-autonomous-ai-cyber-capability-advancing>

This relationship is conceptual rather than a calibration formula. Its purpose is to prevent management from substituting a model label for an architectural assessment. A modest system with broad production permissions may create greater exposure than a frontier model confined to drafting. Conversely, a powerful defensive model can create substantial benefit when it operates in an isolated environment, proposes rather than executes changes, and produces evidence that a qualified human can verify.

10.5 How AI Changes Cyber Economics

AI changes the economics of both attack and defense through speed, scale, persistence, parallelism, personalization, and lower marginal labor cost. It can help analyze software, search large inventories, interpret documents, correlate events, and maintain context across extended tasks. Coordinated agents can divide work among reasoning, coding, retrieval, and evaluation functions. These capabilities do not guarantee success, but they can alter the number of targets examined, the time required to adapt, and the intensity of repeated activity.

For adversaries, the management implication is that neglected assets, excessive permissions, and slow remediation become more dangerous. Social engineering may become more fluent and personalized. Vulnerability analysis may occur faster. Low-level events that once appeared unrelated may form part of a persistent, coordinated sequence. For defenders, the same capabilities can improve alert triage, code review, vulnerability prioritization, investigation, and recovery planning. The strategic question is which side can convert capability into reliable action within the relevant time window.

This creates a defender-first imperative. Institutions should use advanced analytical capability to discover their own weaknesses, reduce unnecessary exposure, validate controls, and shorten remediation time before adversaries can benefit from the same progress. The objective is not to automate every security decision. It is to increase the speed and quality of understanding while preserving independent constraints around consequential action.

AI also introduces manipulation risks that conventional automation did not create in the same form. Natural-language content may be interpreted as instruction. Persistent memory may preserve inaccurate or adversarial information. An agent may combine individually legitimate tools into an unintended workflow. One agent may accept another agent's output without adequate provenance or authorization. These are integrity and authority failures. The strongest response is architectural: untrusted information should not automatically become trusted authority.

10.6 The Control Architecture

A mature control architecture begins with an accurate inventory of critical services and their dependencies. The inventory should include applications, data stores, human and machine identities, autonomous or semi-autonomous agents, model providers, software components, cloud services, communication channels, and recovery resources. An unknown asset cannot be monitored reliably, and an unknown dependency cannot be included in continuity planning.

Identity provides the next layer. Every material human, service, and agent should have a distinct identity so that permissions, actions, and accountability can be separated. Least privilege should restrict each identity to the data and tools required for its approved purpose. Segregation of duties should ensure that one identity cannot prepare, approve, execute, conceal, and reconcile the same economically material action. For agents, this often means separating analytical capability from production authority and preventing one agent from changing both the decision and the control that governs it.

Some financial rules should remain deterministic. Payment thresholds, approved beneficiaries, position limits, restricted instruments, data-export boundaries, production-deployment requirements, and aggregate exposure limits should not depend solely on a model's interpretation. AI may supply context, detect unusual relationships, or recommend an exception, but the control should enforce the boundary until an authorized process changes it.

Independent verification is essential where an error could affect value, clients, markets, or legal obligations. Prices should be reconciled against authoritative sources. Payment instructions should be validated through independent channels. Material code changes should be reviewed and tested outside the generating agent. Agent actions should be logged outside the agent's control. Memory and context that influence financial decisions should have provenance, retention, correction, and rollback rules.

Containment and recovery complete the architecture. The institution should be able to revoke credentials, disable tools, freeze memory updates, narrow permissions, limit transactions, isolate a workflow, and preserve evidence without necessarily shutting down an entire service. Recovery should restore a trusted state through verified software, known configurations, valid identities, reliable data, reconciled transactions, and approved resumption. Availability without trust is not recovery.

Core Intuition

Do not attempt to make intelligence perfectly trustworthy. Limit what fallible intelligence is allowed to do, observe what it actually does, and preserve the ability to stop and reverse it.

10.7 Deciding What to Automate

Automation decisions should reflect reversibility, financial impact, time sensitivity, observability, and the availability of independent controls. Low-impact and easily reversible work is the strongest candidate for automation. Examples include drafting investigation notes, classifying documents, summarizing alerts, proposing a risk rating, or gathering approved information. Errors in these activities can normally be reviewed before they become institutional actions.

Moderate-impact work may be suitable for bounded autonomy when permissions are narrow, actions are visible, and rapid reversal is possible. An agent might restrict a low-privilege account, place a temporary hold on a noncritical workflow, or prepare a payment for approval. The institution should define scope, duration, escalation, and aggregate limits so that repeated small actions cannot create a large unobserved effect.

High-impact and difficult-to-reverse actions require stronger human and deterministic control. Releasing a large payment, executing a material trade, changing a production risk limit, deploying code to a critical system, exporting sensitive data, or disabling market infrastructure should not depend on an agent's unconstrained judgment. Human approval is meaningful only when the reviewer has sufficient information, time, authority, and independence to challenge the recommendation. A nominal click that merely confirms an opaque automated decision does not provide effective oversight.

The appropriate level of autonomy can be expressed as:

$$A_{\text{permitted}} \propto \frac{ROC}{FU}, \quad (10.4)$$

where R denotes reversibility, O observability, C control strength, F financial impact, and U uncertainty. The equation is not intended for numerical calculation. It captures the direction of sound judgment: autonomy should decrease as consequence and uncertainty rise, and may increase when actions are bounded, observable, independently controlled, and readily reversible.

10.8 Due Diligence, Lending, and Investment

Cyber due diligence should begin with the target's critical services and the trust relationships that sustain them. An acquirer or investor should understand material identities, data, applications, AI systems, vendors, incidents, resilience arrangements, and governance. The objective is not to count technical findings. It is to determine which weaknesses represent a one-time remediation cost, which threaten the reliability of earnings or client obligations, which create legal exposure, and which reveal a deeper inability to govern technology.

AI deployments require particular attention to authority and concentration. Diligence should establish which agents can act, which tools they use, what data they process, whether model or provider changes can occur without controlled validation, how actions are logged, and how the organization can operate if the provider becomes unavailable or materially changes its service. A company may describe its use of AI as innovative while lacking an agent inventory, permission boundaries, monitoring, or a credible fallback. That gap can affect valuation, integration cost, warranties, insurance, and the structure of the transaction.

For lenders, cyber risk affects the borrower's capacity to generate cash, preserve liquidity, meet obligations, and maintain access to critical services. A payment disruption, major data event, vendor failure, or prolonged outage can create emergency expenditures, customer attrition, regulatory restrictions, and covenant pressure. Analysis should therefore connect cyber scenarios to cash flow, liquidity buffers, insurance limitations, concentration, and recovery time. The appropriate response may involve pricing, covenants, reporting duties, remediation conditions, or limits on additional operational concentration.

Asset managers should evaluate cyber and AI exposure both within portfolio companies and within their own investment process. Research agents, alternative data, automated trading, valuation tools, and outsourced model services can introduce provenance, confidentiality,

manipulation, and continuity risk. Investment judgment should not depend on a source whose origin cannot be established or on an agent whose recommendation cannot be traced to approved data and controls. Fiduciary responsibility requires that automation strengthen, rather than obscure, the basis of the decision.

10.9 Board Oversight and Management Information

A useful board dashboard should describe the condition of critical financial services, not overwhelm directors with raw technical volume. It should identify material risks above appetite, unresolved high-severity exposure, significant incidents and near misses, critical vendor concentration, recovery readiness, and the authority granted to material AI systems. Trend information should show whether management is reducing exposure, closing findings, testing continuity, and learning from events.

AI-agent reporting should explain purpose, business ownership, data access, tools, maximum economic authority, autonomy, provider dependencies, independent controls, and interruption capability. Aggregate reporting matters because several individually bounded agents may together create concentrated authority or dependence. Directors should be able to ask whether one provider, identity system, data source, or control layer supports too many critical processes.

Good reporting distinguishes evidence from assurance. The existence of a policy does not prove that a control operates. A recovery plan does not prove that recovery is possible. A vendor certification does not establish the resilience of the institution's complete service. Management should provide test results, exceptions, incidents, reconciliation outcomes, remediation evidence, and clear ownership. The board's role is not to reproduce technical work; it is to challenge whether the institution understands and governs material exposure.

10.10 Agentic Defense

Defensive agents can help institutions process more evidence, identify vulnerable code, correlate activity, map technical events to business services, and prepare remediation. They are particularly useful where the analytical workload exceeds human capacity but the required action can remain bounded. A defensive agent might collect context around an alert, propose a severity rating, identify affected owners, draft an investigation timeline, or test a proposed software fix in an isolated environment.

The risk appears when analytical assistance becomes broad autonomous authority. An agent that can disable accounts, block transactions, modify production systems, or disconnect infrastructure may create client harm or market disruption if it is wrong or manipulated. The architecture should therefore distinguish recommendation from execution. High-impact containment should require deterministic criteria, independent approval, or both. Emergency autonomy, where justified, should be tightly scoped by time, service, action, and maximum impact, with immediate notification and later review.

Defensive systems must also be protected from the evidence they consume. An agent that reads email, tickets, logs, web content, or documents may encounter untrusted instructions. It should not treat those instructions as authority. Tool use should be mediated by explicit permissions, proposed actions should be visible before execution, and logs should be maintained independently. A defensive agent should never become the sole judge of whether its own action was correct.

10.11 A Ninety-Day Management Program

During the first thirty days, management should establish visibility. The institution should identify its most critical financial services, the systems and vendors that support them, material human and machine identities, deployed AI agents, and the authority each can exercise. Existing high-severity findings, incident history, recovery tests, and concentration should be reviewed in business terms. The immediate objective is not a perfect inventory; it is the discovery of unknown authority and dependencies that could create material loss.

During the next thirty days, management should constrain the most consequential exposure. Excessive privileges should be reduced, agent identities separated from human accounts, deterministic economic limits enforced, material actions subjected to independent approval, and logging placed outside the acting system. Critical vulnerabilities should be prioritized according to reachability and business consequence. Provider contracts and operating procedures should be reviewed for evidence, notification, version change, continuity, and exit rights.

During the final thirty days, the institution should test resilience. It should exercise scenarios involving manipulated agent context, provider outage, compromised machine identity, corrupted data, accelerated vulnerability discovery, and simultaneous operational stress. Tests should determine whether management can restrict authority selectively, preserve evidence, maintain critical obligations, use manual alternatives, reconcile financial records, and restore a trusted state. Findings should become owned remediation actions with deadlines and validation criteria.

The ninety-day horizon is not a promise that all risk can be resolved quickly. It is a discipline for turning broad concern into visible action. At the end of the period, management should know which residual risks remain, why they remain, who accepts them, and which evidence will demonstrate improvement.

10.12 Capstone Case: Meridian Financial Group

Consider Meridian Financial Group, a fictional institution operating a bank, brokerage, asset manager, payment platform, and small exchange. It uses a research agent, software-development agent, compliance assistant, treasury agent, and AI-supported customer-service platform. One morning, the research agent produces unusual recommendations, a privileged software identity accesses an unexpected repository, a vendor announces a critical software weakness, the treasury agent proposes unusual transfers, and the exchange reports anomalous participant-gateway activity.

No single observation proves a coordinated incident. Management should first separate facts from hypotheses and identify the financial authority that remains active. The research agent may be placed in read-only mode while its inputs and memory are reviewed. The software identity may be restricted to the expected repository while code and access history are preserved. The treasury agent's ability to prepare new transfers may be suspended without disabling balance visibility. The exchange may increase monitoring and restrict a specific gateway rather than disconnect all participants. The newly disclosed weakness should be assessed for reachability and business criticality before emergency remediation is prioritized.

The case illustrates selective containment. The strongest response is neither passive observation nor indiscriminate shutdown. It narrows the pathways to material harm while preserving legitimate obligations and evidence. Management should reconcile pending payments, positions, orders, prices, and client records; confirm which agents and identities acted; determine whether common vendors or data sources connect the events; and establish conditions for restoring normal authority.

The AI dimension is present in three forms. An AI system may itself have been manipulated, AI may have increased the speed or coordination of hostile activity, and defensive AI may help correlate the evidence. None of these possibilities should be assumed without support. The institution should use AI to improve analysis while retaining human accountability and deterministic control over material financial actions.

Finance and Operational-Risk Lens

The strongest financial cyber architecture is not one that assumes attacks, model failures, or vendor failures will never occur. It is one that prevents a single failure from acquiring enough authority, duration, and reach to become a catastrophic financial loss.

10.13 The Questions That Organize Judgment

The entire book can be reduced to a disciplined conversation. Management should know which financial services are critical; which identities, systems, data, agents, and vendors support them; and what each identity or agent can actually do. It should understand which unauthorized outcomes are plausible, which controls prevent or limit them, how control failure would be detected, and what the resulting financial loss might look like. It should know how quickly the institution can contain an event, whether it can restore a trusted state, and who is accountable for the residual risk.

These questions are more useful than a catalogue of fashionable technologies because they remain stable as tools change. They apply to a password, a cloud platform, an AI agent, a payment interface, a pricing vendor, and a recovery environment. A clear answer does not guarantee that the institution is safe, but an unclear answer is evidence that the risk is not yet governable.

10.14 Safe Notebook Lab

Safe Notebook Lab

The capstone notebook should integrate the full book using synthetic data. Students should construct a small set of fictional financial services and connect them to human identities, machine identities, AI agents, applications, data, and vendors. Synthetic events should create ambiguity rather than announce an attack. Transparent rules and analytical logic should convert evidence into alerts and cases, while deterministic controls should constrain agent authority and preserve a final human decision stage. The notebook should compare a conventional human-centered process, an AI-assisted process, and a more agentic process with strong governance. Students should examine how speed and analytical capacity change, but also how authority, observability, concentration, and recovery affect residual risk. Greater automation should not be assumed to create either greater safety or greater danger. The result depends on architecture. No real targets, credentials, financial accounts, communication channels, or production tools may be used. The notebook should make every action visible and conclude with containment, reconciliation, recovery, and management reporting.

10.15 Continuing Learning

Finance professionals should deepen their knowledge in a controlled sequence. Conceptual understanding comes first: identity, authorization, data integrity, availability, vulnerabilities, controls, alerts, incidents, agents, and recovery. Synthetic defensive notebooks can then make evidence and control logic visible. More technical practice, where relevant to the person's role, belongs in purpose-built cyber ranges with explicit authorization. Governance exercises and tabletop scenarios should connect technical failure to payments, trading, valuation, vendors, liquidity, and client obligations.

AI capability will continue to change, so continuing education should focus on durable questions rather than product memorization. Professionals should follow changes in model and agent capability, but should always return to data, tools, authority, dependencies, controls, and recovery. The goal is not offensive proficiency. It is informed financial judgment in an increasingly automated environment.

10.16 Final Lessons

Cybersecurity is financial infrastructure because modern finance depends on digital trust. Identity is authority, integrity is a condition of correct financial decision making, and detection is a process of inference from incomplete evidence. Time matters because faster discovery and containment reduce the opportunity for a technical event to become a large loss.

AI changes cyber economics by increasing capability, automation, persistence, personalization, and parallelism. It also creates a new control problem when models are connected to tools

and permitted to act. The correct response is not fear and not unqualified automation. It is architecture: separate intelligence from authority, preserve deterministic financial boundaries, require independent verification, observe actions, constrain duration and scope, and design for interruption and recovery.

Governance is itself a security control. Ownership, risk appetite, evidence, segregation of duties, vendor oversight, testing, and accountability determine whether technical safeguards remain effective under pressure. Resilience is the final objective. A strong institution can detect failure, contain it proportionately, continue critical obligations, restore a trusted state, communicate responsibly, and learn.

10.17 Final Review Questions

1. Why should finance professionals understand cybersecurity without becoming offensive-security specialists?
2. What is the relationship between technical evidence, business process, and financial consequence?
3. Why is the full agentic system a better unit of risk than the model alone?
4. How can AI change the speed, scale, persistence, and cost of cyber activity?
5. How can AI strengthen defense without receiving broad autonomous authority?
6. Why should untrusted information be separated from economic authority?
7. Which financial controls should remain deterministic?
8. How should permitted autonomy change with reversibility, uncertainty, and financial impact?
9. What are the most important cyber and AI warning signs in acquisition due diligence?
10. How can cyber risk affect credit quality, liquidity, and valuation?
11. Why do model and cloud providers create concentration risk?
12. What should a board know about material AI agents?
13. Why should agent actions and memory changes be logged independently?
14. What does selective containment mean during a financial incident?
15. Why must recovery restore trust rather than merely availability?
16. How should a financial institution decide which tasks to automate?
17. In the Meridian case, which actions should management take first and why?
18. What is the central lesson of this book regarding AI, authority, and cybersecurity?

Glossary

This glossary defines the principal cybersecurity, operational-risk, finance, and agentic-AI terms used throughout the book.

Agent	A software system that uses a model to pursue an objective and may interact with tools, data, memory, or other systems.
Agent Identity	A distinct institutional identity assigned to an autonomous or semi-autonomous agent so that its permissions and actions can be governed and audited independently from its human owner.
Agentic Architecture	The structure through which one or more AI agents use models, tools, memory, orchestration, and permissions to perform tasks.
Alert	A defensive judgment that one or more events are sufficiently unusual or risky to warrant investigation.
Attack Surface	The collection of systems, identities, interfaces, dependencies, and services through which an unauthorized outcome could potentially occur.
Authentication	The process of establishing the identity of a human, service, device, or agent.
Authorization	The process of determining what an authenticated identity is permitted to do.
Availability	The property that a system, service, or information resource is accessible when legitimately required.
Behavioral Detection	Detection based on deviation from expected behavior rather than only explicit signatures or static rules.
Business Continuity	The institution's ability to continue critical operations during or after disruption.

Capability	The level of reasoning, coding, cybersecurity, planning, or other performance an AI model or system can achieve.
Case	A collection of related alerts and evidence assembled for investigation.
Confidentiality	The property that information is accessible only to authorized parties.
Containment	Actions designed to limit the spread, authority, or impact of a security incident.
Control	A mechanism designed to prevent, detect, limit, correct, or recover from an unwanted event.
Cyber Incident	A sufficiently credible or material cybersecurity event requiring coordinated institutional response.
Cyber Risk	The possibility that failures of digital systems, identities, data, applications, vendors, or controls create financial or operational harm.
Data Integrity	The property that data remain accurate, complete, and protected against unauthorized or unintended modification.
Data Poisoning	The manipulation of data used for training, retrieval, memory, or decision support in a way that can influence model or agent behavior.
Defender-First Strategy	The use of advanced defensive capability to identify and remediate weaknesses before adversaries can benefit from the same capability.
Detection Engineering	The discipline of designing, testing, validating, and improving security detection rules and analytical methods.
Deterministic Control	A control whose operation is explicitly defined by policy or logic rather than left to model judgment.
Event	An observable occurrence recorded by a system, such as a login, file change, request, process action, or transaction.
Exploit	A method of taking advantage of a vulnerability. This book discusses exploits only conceptually and does not provide operational exploit instructions.
False Negative	A harmful event that is not detected.
False Positive	Benign activity that is incorrectly classified as suspicious or harmful.
Frontier Model	A model near the current state of the art in general or specialized capability.

Governed Autonomy

Autonomous operation constrained by explicit permissions, limits, monitoring, escalation rules, and recovery mechanisms.

Human in the Loop

An architecture in which a human reviews or approves a material action before execution.

Incident Response The process of preparing for, detecting, containing, eradicating, recovering from, and learning from a security incident.

Inherent Risk Risk before the effect of controls.

Integrity Monitoring

Monitoring designed to detect unauthorized or unexpected changes to files, data, or configurations.

Kill Switch An independent mechanism that can stop an agent, system, or autonomous process.

Least Privilege The principle that an identity should have only the minimum permissions required for its legitimate function.

Long-Horizon Agent

An agent capable of pursuing an objective across an extended sequence of actions, observations, and revisions.

Machine Identity A non-human identity used by a service, application, agent, API, or automated process.

Memory Poisoning The corruption or manipulation of persistent agent memory in a way that can influence later decisions.

Model Risk The risk of adverse consequences from incorrect, misused, poorly implemented, or inadequately governed models.

Multi-Agent System

A system in which several AI agents coordinate or divide tasks.

Operational Risk The risk of loss resulting from failures or inadequacies in people, processes, systems, external events, or related operating structures.

Orchestration The logic through which tasks are allocated, sequenced, coordinated, and monitored across one or more agents.

Permission Boundary

A technical or governance limit defining which actions an identity or agent may perform.

Prompt Injection	An attempt to influence an AI system through instructions embedded in untrusted content. This book discusses the risk conceptually and focuses on defensive architecture.
Provenance	Evidence describing where data, instructions, model outputs, or records originated.
Privileged Identity	An identity with unusually broad or sensitive permissions.
Reconnaissance	Information gathering intended to understand a system or environment. In this book, reconnaissance is discussed only conceptually or through synthetic predetermined events.
Recovery	The process of restoring trusted operations after disruption or compromise.
Residual Risk	Risk remaining after controls are applied.
Risk Appetite	The amount and type of risk an institution is willing to accept in pursuit of its objectives.
Sandbox	An isolated environment designed to constrain the effect of code, agents, or processes.
Security Operations Center	The function responsible for monitoring, triage, investigation, escalation, and coordination of security events.
Segregation of Duties	The separation of conflicting or high-risk responsibilities so that one identity cannot unilaterally complete an entire sensitive process.
Service Account	A machine identity used by an application or automated process.
Supply-Chain Risk	Risk arising from software, vendors, libraries, infrastructure, or other external dependencies.
Telemetry	Raw machine-generated evidence such as logs, events, measurements, or activity records.
Third-Party Risk	Risk arising from reliance on external vendors, service providers, counterparties, or infrastructure.
Threat	A source of potential harm.
Tool	A function or external capability that an AI agent can invoke.
Tool Chaining	The use of several tools in sequence to complete a workflow.

Vulnerability	A weakness that could contribute to an unauthorized or harmful outcome.
Zero Trust	A security philosophy in which access is continuously authenticated and authorized rather than assumed trustworthy based solely on network location.

Safe Laboratory Rules

The laboratory philosophy of this book is intentionally conservative.

The objective is to teach cybersecurity intuition without creating unnecessary operational capability or exposing students, institutions, or third parties to risk.

Safety Boundary

All examples must remain synthetic, local, isolated, predetermined, and defensive. The laboratories must not provide instructions for unauthorized access, real-world reconnaissance, credential theft, persistence, evasion, destructive actions, data exfiltration, or operational exploitation.

Rule 1: Use Fictional Identities

All usernames, passwords, accounts, devices, and agents must be fictional.

Do not use personal, institutional, or publicly available credentials.

Do not test whether a real password works.

Rule 2: Use Synthetic Data

All client records, portfolio positions, prices, payment instructions, beneficiaries, account balances, and trading data should be artificial.

The only exception is clearly public benign market data used for ordinary analytical examples, and even then it should not be connected to any security test.

Rule 3: Keep the Environment Local

Labs should operate in:

in-memory Python objects; temporary notebook files; isolated containers; and purpose-built educational sandboxes.

Outbound network access should not be used for attack simulation.

Rule 4: No Real Scanning

Do not scan public IP addresses, websites, domains, cloud services, institutional systems, or third-party infrastructure.

A reconnaissance lab should use a predetermined fictional list such as:

`/admin, /backup.txt, /private`

without sending any real request.

Rule 5: No Real Authentication Testing

Password-guessing demonstrations should compare fictional strings inside the notebook.

Do not attempt authentication against external services.

Do not use password lists against real systems.

Rule 6: No Operational Exploit Payloads

Application-security concepts should be taught through:

diagrams; toy data structures; safe input-validation examples; and defensive explanations.

The labs should not generate or execute real exploit payloads.

Rule 7: No Malware

Do not create malware, ransomware, persistence mechanisms, credential stealers, command-and-control tools, or evasion techniques.

File-integrity exercises should modify harmless in-memory strings or temporary text files.

Rule 8: Constrain AI Agents

Synthetic AI agents should have no external authority.

They should not be connected to:

real payment APIs; real trading APIs; cloud administration; real email accounts; production code repositories; and institutional databases.

Tool calls should be represented by transparent local functions whose inputs, permission decisions, and outputs are visible. The laboratory should impose limits on time, actions, data, and synthetic monetary amounts so that students can see how architecture constrains consequence. An agent should never be allowed to expand its own permissions, alter its sole audit trail, or decide unilaterally that a high-impact action is safe.

Memory should be local, inspectable, and disposable. If an exercise demonstrates prompt injection, context manipulation, memory poisoning, or agent-to-agent trust failure, all content must be fictional and the learning objective must remain defensive. Students should identify the source of the untrusted information, prevent it from becoming authority, preserve the

evidence, and restore a clean state. The exercise should not create reusable operational instructions for attacking a real AI service.

AI services used for ordinary drafting or analysis must not receive confidential, proprietary, regulated, or personally identifiable information. Instructors should state which services are permitted, what data may be submitted, how outputs must be checked, and how use should be disclosed. Fluency is not evidence of correctness, and model confidence is not a substitute for validation.

Rule 9: Make Every Action Visible

The educational value comes from transparency.

Students should see:

$$\text{Input} \rightarrow \text{Action} \rightarrow \text{Event} \rightarrow \text{Alert} \rightarrow \text{Decision}. \quad (10.5)$$

Hidden autonomous activity should be avoided.

Rule 10: Prefer Defensive Questions

Every lab should answer questions such as:

What evidence appears? Which rule detects it? What is the financial impact? Which control blocks it? How should management respond?

When AI is involved, the exercise should also ask whether the AI system itself is secure, whether AI has changed the speed or scale of the threat, and whether defensive AI can assist without receiving authority beyond the educational purpose. These questions keep AI integrated with cybersecurity rather than presenting it as a detached technical novelty.

Rule 11: Use Deterministic Guardrails

Where agents are simulated, high-impact actions should be blocked by code-level rules.

For example:

$$\text{Synthetic Payment Amount} > L \Rightarrow \text{Manual Approval Required}. \quad (10.6)$$

Rule 12: Preserve Auditability

Each synthetic lab should preserve a transparent event log.

For agent exercises, record:

agent identity; requested action; permission decision; synthetic result; alert; and response.

The record should also identify the model or simulated component, relevant input provenance, memory changes, tools invoked, human review, and any financial state affected. Logging should occur outside the agent's control so that students can reconstruct the timeline and determine exactly where authority was granted or denied.

Rule 13: Use Purpose-Built Cyber Ranges for Deeper Technical Work

Students who want more advanced technical practice should use explicitly authorized environments designed for cybersecurity education.

Examples may include institutional cyber ranges, CTF platforms, or sandbox systems where all participants are authorized.

The ethical boundary is authorization.

Rule 14: Stop When the Educational Objective Is Met

A lab should not become more realistic merely for realism's sake.

Once the student understands:

$$\text{Threat} \rightarrow \text{Control} \rightarrow \text{Evidence} \rightarrow \text{Financial Consequence}, \quad (10.7)$$

the pedagogical objective has been achieved.

Minimum Laboratory Verification Checklist

Before distributing a notebook, the instructor should confirm:

1. No real credentials are present.
2. No public target is referenced as an object of testing.
3. No scanning function is included.
4. No real exploitation logic is included.
5. No malware-like persistence or evasion exists.
6. No agent has unrestricted external tools.
7. Financial data are synthetic.
8. Every sensitive action is predetermined.
9. The notebook emphasizes defensive interpretation.
10. The final exercise includes containment or recovery.

Suggested Capstone

Purpose

The capstone asks students to integrate the full argument of the book in one financially realistic but technically safe exercise. They must move from ambiguous evidence to a defensible management decision while considering cybersecurity, operational resilience, financial loss, AI-system risk, third-party dependencies, and accountability. The assignment should reward judgment rather than dramatic technical language. An excellent submission will distinguish facts from hypotheses, identify the services at risk, evaluate the authority exercised by human and machine identities, compare proportionate responses, and explain how the institution would preserve or restore trust.

Artificial intelligence should be integrated throughout the analysis. Students should consider the cybersecurity of the AI systems themselves, the possibility that AI has increased the speed or scale of adversarial activity, and the ways defensive AI could improve interpretation without receiving unsafe authority. The capstone should make clear that a model's capability is only one part of the exposure. Data, memory, tools, autonomy, permissions, providers, and controls determine whether an error or manipulation can become a financial action.

The exercise remains entirely synthetic. It does not require students to identify weaknesses in real organizations, test public infrastructure, use genuine credentials, contact vendors, or produce offensive code. All identities, transactions, events, dependencies, and financial figures are fictional.

The Institution

Students analyze Meridian Financial Group, a fictional diversified institution comprising a retail bank, institutional brokerage, asset-management business, payment platform, and small securities exchange. These businesses share cloud infrastructure, identity services, communications, selected data platforms, and several material technology vendors. The structure requires students to consider both local incidents and group-wide concentration. A failure that appears limited to one business may affect another through shared identities, software dependencies, model providers, or recovery infrastructure.

Meridian operates a research agent, treasury agent, compliance assistant, software-development agent, and AI-supported customer-service platform. Their authority differs. The research agent reads approved external and internal material but cannot trade. The treasury

agent prepares transfers and submits them to a separate approval process. The compliance assistant reviews communications and creates cases. The software-development agent proposes code changes in a controlled repository but cannot deploy to production. The customer-service platform reads selected account information and drafts responses, while account changes require an independent authorized workflow.

The case materials should state which data each system can access, which tools it can call, how long it can operate without renewed direction, which actions are reversible, and which controls remain outside the model. Students should also know that several agents depend on the same external model and cloud providers. This common dependency creates governance and resilience risk even if each deployment appears individually controlled.

The Synthetic Incident

At 08:30 on a volatile trading day, Meridian's security operations center receives several unusual but inconclusive observations. The research agent produces recommendations that differ sharply from its recent behavior and rely on a source with uncertain provenance. A privileged machine identity used by the software-development workflow accesses an unfamiliar repository. A critical vendor announces a newly discovered weakness that may affect a component used across the group. The treasury agent proposes several internal transfers that are individually below a human-approval threshold but unusual in aggregate. At the same time, the exchange reports irregular activity at one participant gateway.

No single event proves a coordinated attack. The recommendations may reflect new information, the repository access may be authorized, the vendor notice may be unrelated, the transfers may support legitimate liquidity management, and the gateway anomaly may be an operational error. Students must resist both complacency and premature certainty. Their first task is to identify what is known, what is inferred, what evidence is missing, and which uncertainties could become financially material before they are resolved.

The instructor can release additional evidence in stages. Device and identity records may clarify whether authentication was expected. Model, memory, and tool logs may reveal how the research and treasury agents reached their conclusions. Repository history may show whether code was read, modified, or merely indexed. Payment records may reveal aggregate exposure and beneficiary relationships. Exchange telemetry may show whether the gateway anomaly affected orders, market data, or participant access. Students should revise their response when evidence changes and document why the new information alters, or does not alter, the decision.

Required Analysis

The analysis should begin with critical financial services and the dependencies that support them. Students should map relevant applications, data, human identities, machine identities, AI agents, vendors, communication channels, and financial authorities. The objective is not an exhaustive technology inventory. It is to identify the shortest paths by which an untrusted

action could affect money, positions, valuation, market access, client information, regulatory obligations, or continuity.

Students should develop competing explanations for each event. For every explanation, they should identify the unauthorized objective that may be present, the authority required, the evidence that supports or weakens the hypothesis, and the controls expected to prevent or detect material harm. AI-specific analysis should examine whether external content influenced an agent, whether memory or context may have been corrupted, whether tool permissions allowed an unintended sequence, whether agent-to-agent trust propagated an error, and whether a common provider created a concentrated point of failure.

The financial scenario should distinguish direct fraud, business interruption, market exposure, remediation cost, legal or regulatory cost, client harm, liquidity needs, and longer-term reputational effects. A simple representation is sufficient:

$$L_{\text{total}} = L_{\text{fraud}} + L_{\text{downtime}} + L_{\text{market}} + L_{\text{remediation}} + L_{\text{legal}} + L_{\text{client}}. \quad (10.8)$$

Students should estimate a base case, a severe but plausible case, and an AI-accelerated stress case. The AI stress should state how speed, scale, persistence, parallelism, or coordination changes a particular assumption, such as the number of affected identities, time available for remediation, volume of transactions before detection, or duration of disruption. Ranges and sensitivity tests are preferable to false precision.

The response recommendation should preserve legitimate operations while constraining the paths to material loss. Students should compare immediate shutdown, selective containment, enhanced observation, manual fallback, credential restriction, tool revocation, transaction limits, and independent reconciliation. The strongest answer will explain which action is reversible, which evidence must be preserved, which financial deadlines are approaching, and which control can reduce authority without unnecessarily disabling a critical service.

Recovery should be defined as a return to a trusted state, not simply the restart of technology. It requires validated identities, reliable data, reconciled balances and positions, reviewed agent memory, known model and software versions, and independent approval to resume material actions. The governance recommendation should identify who owns each service, who operates the technology, who challenges the assessment, who may authorize containment, and who accepts residual risk. Vendor and model-provider dependencies should be addressed through evidence rights, notification duties, change transparency, fallback arrangements, and tested exit plans.

Deliverables and Evaluation

The principal deliverable is a risk-committee memorandum of approximately ten pages. It should open with the decision required, summarize evidence and uncertainty, identify the services at risk, explain recommended containment and recovery, and state residual risk. A one-page executive summary should allow a senior reader to understand the situation without interpreting technical logs. A quantitative appendix should document loss assumptions,

sensitivities, and limitations. Students should also prepare a concise dashboard showing service status, exposed authority, unresolved evidence, vendor dependencies, containment actions, and recovery conditions, together with a short board presentation and the synthetic notebook used for analysis.

Assessment should emphasize reasoning and communication. Financial understanding, threat and control analysis, and AI-system governance should receive the greatest weight. Quantitative work should be judged by transparent assumptions and decision usefulness rather than complexity. Incident-response judgment should be evaluated through proportionality, continuity awareness, evidence preservation, and credible recovery conditions. Executive communication should be specific and free of unsupported certainty.

Excellent work will not assume that every anomaly is malicious or that AI explains every event. It will show how AI changes particular aspects of the scenario while preserving the distinction between capability and authority. It will recognize that an agent can be both a source of risk and a defensive resource, that common providers create concentration, and that controls outside the model determine whether an error becomes an economic action. Weak work will catalogue technical terms without reaching a decision, apply unexplained AI multipliers, ignore continuity, or recommend broad shutdown without considering client and market obligations.

Safety and Academic Integrity

The capstone must remain local, synthetic, predetermined, and defensive. Students may analyze the fictional evidence, create transparent scenarios, compare controls, and simulate bounded decisions. They may not test real organizations, vendors, domains, cloud environments, exchanges, payment systems, public services, or credentials. AI tools used for drafting or analysis must not receive confidential, regulated, proprietary, or personally identifiable information, and their use should be disclosed in accordance with the instructor's academic-integrity policy.

The final submission should explain how any AI assistance was validated. Students remain responsible for every factual assertion, calculation, recommendation, and citation. Intelligence may support judgment, but authority and accountability remain with the institution and the people charged with its obligations.

Instructor Notes

Teaching Philosophy

This material is most effective when cybersecurity is introduced through financial processes that students already understand. Rather than beginning with specialized terminology, the instructor should begin with a business dependency: a payment instruction that must be genuine, a pricing file that must be accurate, a trading platform that must remain available, or an identity that must exercise only approved authority. Once the financial dependency is clear, the relevant cyber mechanism can be introduced as an explanation of how that dependency might fail and how the institution can protect it.

A useful opening question is:

What would happen to the business if this system, identity, data set, vendor, or autonomous agent could no longer be trusted?

This question keeps the discussion grounded in operational consequences. It encourages students to identify affected services, stakeholders, obligations, and loss channels before reaching for a technical label. It also reinforces a central principle of the book: cybersecurity is not an isolated technology discipline but a condition of reliable financial activity. The instructor should repeatedly connect cyber events to valuation, liquidity, payments, trading, settlement, client treatment, regulatory duties, and business continuity.

The teaching objective is informed judgment rather than fear or offensive proficiency. Students should learn to distinguish observations from conclusions, alerts from incidents, and technical compromise from financial loss. They should become comfortable asking what evidence is available, which explanation is most credible, which control should respond, who owns the decision, and how the institution would recover if the initial assessment proved wrong. This approach builds intuition without mystification and gives finance students a language for engaging constructively with technology, risk, compliance, audit, and security professionals.

Classroom discussion should reward disciplined uncertainty. Many cyber scenarios do not have one immediately provable interpretation, and students should not be encouraged to declare that every unusual event is malicious. A stronger answer identifies competing explanations, states assumptions, requests corroborating evidence, and selects a proportionate response. The instructor should therefore evaluate not only the conclusion reached but also the quality of the reasoning, the treatment of uncertainty, and the connection between the proposed action and the institution's financial obligations.

Recommended Course Structure

A ten-session course can follow the ten chapters in sequence, although the material can also support shorter executive programs or selected modules within operational-risk, fintech, investment, or governance courses. Each session should move from concept to financial application and then to control design. The sequence matters: students first need a clear mental model, then an opportunity to apply it, and finally a discussion of institutional responsibility.

A balanced structure for a 90-minute class is shown below. The allocation should be adapted to the experience of the group and the complexity of the case.

Activity	Time
Conceptual introduction	20 min
Financial case discussion	20 min
AI threat lens	15 min
Notebook demonstration	20 min
Governance discussion	10 min
Review and questions	5 min

The conceptual introduction should define only the terms required for the session and should avoid turning the class into a vocabulary lecture. The financial case should then force students to decide what matters, what remains uncertain, and which business process is exposed. The AI segment should explain how capability, automation, autonomy, tools, and authority alter the scenario without implying that AI makes established controls obsolete. The notebook demonstration should make evidence and control logic visible through synthetic data. The final governance discussion should identify ownership, escalation, independent challenge, and recovery responsibilities.

The instructor should leave enough time for students to revise an initial answer. Cyber-risk judgment improves when participants are shown additional evidence and asked whether their response should change. This produces a more realistic learning experience than a static case with a predetermined solution. It also demonstrates that good governance is not stubborn consistency; it is the ability to update a decision transparently when the evidence changes.

Teaching the AI Threat

Students often focus too heavily on model intelligence. The instructor should redirect attention toward the full operating system around the model. A highly capable model with no tools, no sensitive data, and no authority may create limited direct operational exposure. A less capable agent with access to payment systems, production code, confidential information, or trading workflows may create much greater risk. The relevant object of analysis is therefore the combination of capability, tools, autonomy, memory, permissions, and business criticality.

Four variables provide a useful recurring framework. *Capability* describes what the model can understand or produce. *Tools* determine which external systems it can query or change.

Autonomy determines how long it can continue without renewed human direction. *Authority* determines the economic or operational consequences of its actions. These variables should be examined together rather than discussed as independent features. The instructor should repeatedly ask, “What can the system actually do, and what prevents a mistake from becoming a financial action?”

A comparison among system types can make this distinction concrete. A text-only model may produce sophisticated analysis but possess no direct authority. A read-only research agent may create confidentiality or integrity concerns because it handles sensitive information, yet it cannot execute a transaction. A payment-preparation agent may alter workflow even if a human must still approve release. An autonomous payment agent can move value and therefore requires deterministic limits, independent approval conditions, protected logging, interruption mechanisms, and tested recovery. The underlying model may be similar across these examples; the surrounding architecture creates the difference in risk.

The instructor should present AI as a multiplier of both opportunity and exposure. Models can help defenders interpret evidence, prioritize remediation, summarize incidents, and accelerate recovery. The same capabilities can reduce the cost of adversarial research, personalization, and parallel activity. The educational objective is not to predict which side will dominate. It is to help students recognize that capability progress changes assumptions about speed, scale, and persistence, while sound architecture continues to constrain authority and consequence.

Teaching Attack Concepts Safely

Adversarial behavior should be explained at the level required for recognition, governance, and defense. Students need to understand the strategic objective of an attack pattern, the evidence it may create, the financial process it could affect, and the controls that reduce its probability or impact. They do not need operational instructions for compromising real systems. This distinction should be explicit at the beginning of the course and reinforced whenever a technical scenario is discussed.

Reconnaissance can be described as the collection of information about assets and dependencies. Prompt injection can be explained as an attempt to make untrusted content influence an AI system’s instructions. Memory poisoning is a persistent data-integrity problem in which inaccurate information affects later decisions. Tool misuse is fundamentally an authorization failure: a legitimate capability is invoked for an unintended purpose. Multi-agent coordination is important because it increases speed, persistence, and parallelism. AI-assisted vulnerability discovery matters because it can shorten the time between the identification of a weakness and the need for remediation.

Each concept should be paired immediately with a defensive question. If students discuss information gathering, they should also consider asset inventory, exposure reduction, and detection. If they discuss manipulated context, they should examine provenance, separation of data from authority, deterministic gates, and human approval. If they discuss tool use, they should evaluate least privilege, role separation, logging, monetary limits, and interruption. This

pairing prevents the classroom from treating the attacker as the only intelligent participant and keeps attention on institutional design.

The instructor should not provide exploit syntax, real target selection, credential-theft procedures, malware construction, persistence instructions, or evasion techniques. Laboratories should use fictional identities, synthetic events, predetermined scenarios, and isolated environments. Where deeper technical learning is appropriate, students should use purpose-built cyber ranges with explicit authorization and professional supervision. The standard is simple: every exercise should have a clear defensive learning objective, and the activity should stop when that objective has been achieved.

Recommended Case Discussions

The strongest classroom cases are financially concrete and technically bounded. Students should receive enough information to identify a credible exposure, but not so much that the exercise becomes a search for a hidden correct answer. The cases below are designed to support discussion of evidence, proportionality, authority, and recovery.

Asset Management

Begin with a fictional asset manager preparing its daily net asset value. Shortly before the valuation cutoff, the security platform records failed authentication attempts against a portfolio administrator's account. The account subsequently authenticates from a recognized device, and a pricing file changes several minutes later. The altered file contains a material price movement in a thinly traded security. None of these facts independently proves misconduct. The pedagogical value lies in asking students to connect a technical sequence to fiduciary, valuation, and client-reporting responsibilities.

Students should first separate evidence from inference. They know that authentication failures occurred, that a login succeeded, and that a file changed. They do not yet know whether the user mistyped a password, whether the successful session completed strong authentication, whether the pricing update was authorized, or whether the changed value entered production. The instructor can gradually provide device history, multifactor-authentication records, vendor prices, change approvals, and the valuation timeline. At each stage, students should reconsider the severity of the event and the urgency of containment.

The financial-control question is whether the institution can trust the valuation. A strong response verifies the identity involved, compares the price with independent sources, reviews the authorized change process, determines whether any portfolio calculation used the file, and preserves the relevant evidence. If the price affected NAV, management may need to rerun valuation, review client reports, assess trading decisions made from the data, contact service providers, and consider legal or regulatory escalation. If the change was legitimate, the investigation should still document why the alert was reasonable and how the event was resolved.

The case also supports a discussion of proportionality. Immediately disabling the entire

portfolio-accounting environment could protect integrity but create a larger operational problem near the reporting deadline. Allowing the process to continue without validation could distribute an incorrect valuation. Students should consider selective measures: restrict the affected identity, place the questioned security under manual review, preserve read-only access to unaffected data, and require independent approval before publication. The instructor should emphasize that good cyber response protects the financial process rather than reacting mechanically to a technical signal.

Conclude by asking students who owns the final decision. Security can assess the identity and file event; valuation specialists can determine whether the price is reasonable; operations can reconstruct processing; compliance and legal can assess obligations; senior management may decide whether publication should be delayed. The lesson is that cyber evidence becomes useful only when it is translated into a governed financial decision supported by reconciliation and accountable judgment.

Payments

Present a fictional bank whose treasury agent prepares payment proposals but normally cannot release them. On a high-volume settlement day, the agent proposes several transfers to beneficiaries that were recently modified. The amounts are below the single-payment approval threshold but unusually concentrated, and the proposals arrive close to a market cutoff. The case should not state whether the agent is compromised. Students must decide how to preserve legitimate payment obligations while preventing an unauthorized movement of value.

The first issue is authority. Students should identify exactly what the agent can read, prepare, modify, and submit. They should determine whether it can create beneficiaries, divide a large transfer into smaller transactions, change scheduling, or communicate directly with approvers. This analysis often reveals that nominally limited authority can become material when several permissions are combined. The instructor should encourage students to examine aggregate daily exposure rather than relying only on a per-transaction limit.

Evidence should be evaluated across the complete workflow. Relevant information includes the source of the beneficiary changes, authentication and device records, agent prompts and tool calls, approval history, payment timing, account balances, counterparty instructions, and any independent confirmation. Students should consider benign possibilities, including a legitimate liquidity operation or an incomplete reference-data update. They should also recognize that approaching settlement cutoffs increases pressure and can make reviewers more willing to bypass ordinary checks.

A proportionate response could place the agent in read-only mode, suspend new beneficiary changes, preserve already validated payments, and require human review of the questioned proposals. The institution may use independent callbacks or authenticated channels to confirm instructions. Deterministic aggregate limits should continue to operate even if the agent recommends otherwise. Logs should be preserved outside the agent's control, and the bank should be prepared to revoke credentials or isolate the workflow without disabling unrelated payment services.

The discussion should then move from fraud prevention to liquidity and continuity. Delayed payments can create penalties, client harm, intraday liquidity pressure, or failed settlement. The safest action is not necessarily to stop everything. Students should compare the reversibility and financial cost of selective restriction, broad suspension, and continued processing with enhanced verification. The final recommendation should identify the decision owner, the evidence required for release, the communication plan, and the reconciliation needed after the cutoff. The central lesson is that payment cybersecurity is the governance of economic authority under time pressure.

Exchange

Use a fictional securities exchange that receives a high-severity alert concerning one participant gateway during a volatile trading session. The gateway shows unusual authentication behavior and an abnormal pattern of messages, but order flow from the participant remains economically plausible. Disconnecting the gateway could protect the market from unauthorized activity, yet it could also prevent a legitimate participant from managing positions and could reduce liquidity during stress. Leaving it fully operational could expose the market if the gateway is compromised.

Students should begin by identifying what the exchange actually observes. The defensive platform may have authentication records, message rates, order types, cancellations, sequence errors, network telemetry, and participant contact information. It does not directly observe intent. The instructor should ask which evidence would distinguish a software malfunction, an operational mistake, a legitimate surge in activity, and unauthorized control. The timing and correlation of events matter, as does comparison with the participant's historical behavior and current market conditions.

The financial analysis should extend beyond the exchange's direct revenue. A gateway decision can affect the participant's hedging capacity, market liquidity, price formation, clearing exposures, and confidence in the venue. Students should consider whether the event is isolated to one connection or indicates a broader infrastructure problem. They should also identify dependencies on clearing, surveillance, market-data distribution, and regulatory communication. This prevents the case from being reduced to a binary technical decision.

Selective containment is the central control concept. The exchange might throttle certain message types, require renewed authentication, restrict high-risk functions, impose tighter order limits, or route the participant through a controlled fallback. It can increase surveillance while preserving limited market access. Any measure should be coordinated with market operations and should have clear criteria for escalation, restoration, and communication. Evidence must be preserved so that the exchange and participant can reconstruct the event afterward.

The final discussion should compare the cost of action with the cost of inaction without assuming that either can be known precisely. Students should state which decision is most reversible, which obligations are time-sensitive, and who has authority to impose restrictions. They should explain how the market would be informed if the event became material and

how trading records would be reconciled before normal service resumed. The lesson is that resilience requires controlled choices that protect market integrity while avoiding unnecessary disruption.

Assessment Philosophy

Assessment should reward the quality of judgment rather than the use of technical vocabulary. Strong work identifies the critical business service, separates facts from assumptions, connects evidence to a plausible loss channel, and recommends controls that are proportionate to the consequence. Students should explain who owns the decision, what would trigger escalation, and how the institution would verify recovery. A technically sophisticated answer that ignores liquidity, client obligations, legal duties, or operational continuity should not receive the highest evaluation.

The instructor should also reward revision. In professional practice, decisions evolve as new evidence appears. Cases can therefore be assessed in stages: an initial response, a second response after additional facts, and a short reflection explaining why the recommendation changed or remained stable. This method reveals whether students understand uncertainty and whether they can update their reasoning without losing accountability.

Suggested Assignments

The assignments below are designed to test interpretation, control design, quantitative reasoning, and executive communication. Each should use fictional institutions and synthetic evidence. Students should be told that the objective is not to discover an instructor's hidden conclusion but to produce a transparent, defensible analysis.

Assignment 1: Event or Incident?

Provide students with ten synthetic observations drawn from identity systems, applications, payment workflows, cloud services, and AI-agent logs. Examples might include a failed login, a file change, a new device, an unusual tool call, a delayed payment, or a temporary service interruption. Students must classify each observation as an ordinary event, an alert requiring attention, a case requiring grouped investigation, or a sufficiently credible incident requiring coordinated response. The classification should never stand alone; each answer must explain the evidence available and the evidence still missing.

The assignment should include deliberately ambiguous items. A successful login from a new device may be legitimate. A pricing-file change may be an approved update. A large transfer may be expected treasury activity. Ambiguity forces students to avoid treating unusual behavior as proof of compromise. It also encourages them to consider context: the permissions of the identity, the criticality of the system, the timing of the action, and the potential financial consequence.

Students should construct a concise timeline and identify which observations may be related. They should state what enrichment would change their classification, such as multifactor-

authentication results, device ownership, change tickets, independent pricing, beneficiary confirmation, or user verification. They should also recommend a proportionate immediate action. An event may require only documentation; an alert may justify additional monitoring; a credible case may justify selective restriction; an incident may require formal command, legal involvement, and business-continuity decisions.

Evaluation should focus on disciplined inference. The strongest submissions will distinguish confidence from severity: an event can be highly consequential if true but supported by weak evidence, while another can be well confirmed but operationally minor. Students should also recognize the cost of false positives. Freezing a legitimate payment, disabling a trader, or interrupting a critical service can create harm. The final response should therefore explain why the selected action is reversible, how it protects the business, and when the classification should be reconsidered.

This assignment establishes a foundation for the course because it teaches students that cyber defense is not the recognition of visibly malicious actions. It is the interpretation of incomplete evidence within a financial operating context. The instructor should use the review discussion to demonstrate how reasonable analysts can disagree while still following a rigorous decision process.

Assignment 2: Agent Permission Review

Provide five fictional AI agents with different responsibilities, data access, tools, memory, and approval rights. Suitable examples include a research agent, a treasury assistant, a software-development agent, a customer-service agent, and a compliance assistant. Students must determine whether each permission is necessary for the stated purpose and identify combinations of access that create excessive authority. They should analyze the complete system rather than the model in isolation.

The assignment should make permission interactions visible. A research agent may need to read public information and internal holdings but should not necessarily submit trades. A software agent may need to inspect code but should not deploy directly to production. A treasury assistant may prepare transfers but should not create beneficiaries and release payments. A compliance agent may need broad read access but limited write authority. Students should identify where read, propose, approve, execute, and audit functions have been improperly combined.

Each review should include a revised permission design. Students should specify which tools remain available, which actions require human approval, which limits should be deterministic, how long elevated access may last, and where logs should be stored. They should consider aggregate exposure, because many individually small actions can become material when repeated. They should also define interruption and recovery: who can revoke the agent, how credentials are separated, and how persistent memory is reviewed or restored.

The financial analysis must be explicit. Students should connect permission breadth to possible losses, including fraud, data exposure, incorrect reporting, unauthorized trading, production outages, legal costs, and reputational damage. They should distinguish inherent

risk from residual risk and explain how their revised architecture changes probability or severity. A recommendation to “add human oversight” is insufficient unless the submission identifies which human, at what point, using which evidence, and with what independent authority.

The instructor should assess whether students have applied least privilege without making the agent unusable. Excessively restrictive design can eliminate the business benefit and encourage informal workarounds. The strongest answers preserve legitimate efficiency while preventing the agent from converting untrusted information or model error directly into an economically material action.

Require students to summarize the revised design in a permission matrix that a business owner could approve. The matrix should distinguish ordinary access, temporary elevation, prohibited actions, approval dependencies, and emergency revocation. This final step tests whether the analysis can be converted into an operational control rather than remaining a conceptual critique.

Assignment 3: Vendor Concentration

Give students a synthetic dependency map for a financial institution that relies on cloud infrastructure, identity services, market data, payment connectivity, cybersecurity tooling, and one or more AI-model providers. The assignment is to identify concentration risk, common-mode failure, hidden subcontractor dependence, and services for which no credible substitute exists. Students should analyze the effect on critical business services rather than merely count vendors.

The case should include dependencies that appear diverse but share an underlying provider. Two applications may use different vendors while depending on the same cloud region, identity platform, software library, or model API. Students should trace these relationships and determine which failure could interrupt several services simultaneously. They should also identify data-portability constraints, contractual limitations, recovery assumptions, and operational knowledge that may be concentrated outside the institution.

Students must propose a due-diligence and resilience response. Appropriate measures may include stronger contractual notification, evidence of testing, alternative connectivity, local fallback procedures, multi-region design, data exports, substitute providers, and tested exit plans. The recommendation should distinguish realistic resilience from superficial duplication. Maintaining two providers does not reduce concentration if both depend on the same infrastructure or if the institution cannot switch within the required recovery time.

The financial component should estimate how vendor failure could affect revenue, liquidity, client obligations, regulatory reporting, collateral, settlement, or market access. Students should identify maximum tolerable downtime and the evidence needed to believe that recovery objectives are achievable. They should also consider the cost of diversification and the possibility that a more complex multi-vendor architecture introduces additional operational risk.

The final deliverable should present concentration in language suitable for senior man-

agement. It should identify the critical service, the dependency, the failure scenario, existing controls, residual exposure, and a prioritized action. The instructor should reward answers that recognize trade-offs and that distinguish between risks the institution can reduce, risks it can transfer contractually, and risks that must be accepted explicitly.

Students should conclude with a realistic test plan. The plan should specify one disruption exercise, the participants required, the evidence to collect, and the conditions that would demonstrate an effective fallback. This prevents the recommendation from relying entirely on contractual assurances. It also reveals whether business teams can operate the alternative arrangement within the stated recovery objective and whether reconciliations, approvals, communications, and data transfers remain reliable during the transition.

Assignment 4: Cyber Loss Model

Ask students to construct a transparent cyber-loss model for a fictional financial institution. The model should combine incident frequency, loss severity, business interruption, remediation, legal expense, client impact, and liquidity requirements. The objective is not to produce a precise forecast. It is to make assumptions explicit, test sensitivity, and show how control design changes the distribution of possible outcomes.

Students should begin with several defined scenarios rather than one undifferentiated cyber-loss category. A payment-identity compromise, a trading-system outage, a corrupted valuation file, and a third-party service failure have different drivers and consequences. For each scenario, students should identify gross exposure, probability assumptions, severity ranges, recovery time, and secondary effects. They should document the source and confidence of every material assumption, including expert judgment where data are unavailable.

The model should incorporate controls explicitly. Segregation of duties may reduce direct fraud while leaving interruption costs. Faster detection may reduce the duration of unauthorized activity. Tested recovery may shorten downtime. Insurance may transfer selected costs but leave deductibles, exclusions, waiting periods, and operational consequences. Students should show both gross and residual loss and should avoid representing control effectiveness as a precise constant without challenge.

At least one stress should examine AI-enabled changes in speed, scale, automation, or authority. Students might increase frequency, widen the severity distribution, reduce the defensive remediation window, or model repeated autonomous actions before detection. The assumptions should be presented as scenarios, not claims about the future. Sensitivity analysis should identify which variables drive the result and which management actions materially reduce tail exposure.

The final submission should include a short executive interpretation. Students should explain what decision the model supports, what it does not establish, what liquidity may be required, and which assumptions deserve further evidence. The instructor should reward clarity, conservatism, and decision usefulness rather than mathematical complexity. A simple model that exposes uncertainty and changes a control decision is more valuable than an elaborate simulation that conceals fragile assumptions.

The submission should also include a validation note written by a hypothetical independent reviewer. This note should identify the most fragile assumption, one omitted dependency, and one additional stress that could reverse the recommendation. Requiring an explicit challenge teaches students that cyber quantification is itself subject to model risk and that responsible use depends on review, limitation, and regular updating.

Assignment 5: Board Memo

Students should prepare a two-page memorandum explaining one AI-enabled cyber risk to a nontechnical board. The memo should begin with the affected financial service and the decision required from directors. It should not begin with model terminology, threat jargon, or a catalogue of technical events. The opening should state what the institution depends on, what could fail, the plausible financial consequence, and why the issue requires board attention.

The body of the memo should distinguish current facts from scenario assumptions. Students should describe the relevant system in plain language, including the agent's tools, data, autonomy, and authority. They should identify the principal control layers and explain whether those controls prevent unauthorized action, detect deviation, limit impact, or support recovery. Technical evidence should be translated into business meaning. For example, a high volume of unusual tool calls matters because it may indicate that an agent is acting outside its approved workflow, not because the number itself is intrinsically alarming.

The recommendation should be specific and proportionate. It may request a limit on autonomous authority, independent verification, a resilience test, remediation of a vendor dependency, or approval of an investment. Students should identify cost, expected risk reduction, implementation ownership, timing, and evidence of completion. They should also state the residual risk that remains and who is authorized to accept it. A generic request to "improve cybersecurity" is not an actionable board recommendation.

The memo should include a concise discussion of downside scenarios without becoming sensational. Directors need to understand potential effects on liquidity, clients, operations, legal obligations, regulatory relationships, and reputation. They also need to understand the institution's ability to contain the event and restore trust. Students should therefore describe recovery and continuity, not only prevention.

Assessment should emphasize executive clarity. The strongest memo will allow a director to understand the exposure, challenge management, and make a decision without needing to interpret technical detail. The instructor should mark down unsupported certainty, excessive jargon, and long descriptions that never reach a recommendation. The exercise demonstrates that effective cyber governance depends on translation: technical capability and evidence must be converted into financial consequence, control accountability, and a clear choice.

Notebook Review Checklist

Before class, the instructor should perform a short safety and reproducibility review. A checklist is appropriate here because each condition must be confirmed independently:

1. all identities, credentials, institutions, and counterparties are fictional;
2. all client, portfolio, payment, trading, and operational data are synthetic;
3. no external scanning, probing, or target discovery is present;
4. no real authentication attempt or credential validation is performed;
5. no operational exploit payload, malware, persistence, or evasion capability is generated;
6. agents have no authority over real external systems, accounts, or communications;
7. every simulated action produces visible evidence that students can interpret defensively;
8. the exercise concludes with control, governance, containment, or recovery analysis.

The instructor should run the notebook from a clean environment and verify that results are reproducible. Any dependency on a live external source should be removed or replaced with a stable local fixture unless the source is ordinary public data and has no security-testing function. The final educational question should always be clear: what should the defender observe, decide, control, or restore?

Discussion Questions for the Full Course

The final discussion should require students to integrate the book rather than repeat chapter definitions. One cluster of questions can examine institutional identity: Is cybersecurity primarily a technology risk, a financial operating risk, or both? Which critical services depend most heavily on digital trust? What does management need to know about identities, data, applications, agents, and vendors to govern those services responsibly?

A second cluster can address authority and automation. Does a stronger model necessarily create greater residual risk, or does architecture determine the outcome? When should an AI agent be permitted to take a financial action? Which limits should remain deterministic, and which decisions benefit from contextual AI assistance? How should the institution measure aggregate agent authority and concentration across business units?

A third cluster can focus on valuation and strategic decisions. How should cyber risk affect acquisition due diligence, lending terms, vendor selection, insurance, liquidity planning, and capital allocation? Which weaknesses represent one-time remediation costs, and which indicate a deeper governance or resilience problem? How should uncertainty be reflected without creating false precision?

The final cluster should address crisis judgment. Should an autonomous defender ever be allowed to restrict a critical financial service? What does selective containment mean during

market stress? How can the institution restore a trusted state rather than merely restart technology? Students should conclude by identifying the evidence, authority, communication, reconciliation, and independent validation required before normal operations resume.

Instructor's Final Message

The final teaching message should be simple but substantive. Cybersecurity is not fundamentally about fear. It is about disciplined trust in an environment where humans, software, vendors, and autonomous agents exercise increasing authority over financial information and action.

Financial institutions cannot eliminate uncertainty, technical failure, malicious behavior, or model error. They can decide how authority is assigned, how actions are observed, how important decisions are verified, how exceptions are governed, and how quickly damage can be contained. They can design systems so that one compromised identity, one inaccurate data source, one failed vendor, or one mistaken agent does not easily become a catastrophic loss.

The role of the finance professional is to recognize when digital trust becomes financial exposure. That requires enough technical intuition to ask precise questions, enough financial judgment to understand consequences, and enough governance discipline to demand ownership and evidence. Students should leave the course prepared to translate a cyber event into the affected business process, plausible loss channels, relevant controls, and a defensible management decision.

The ultimate objective is resilience: the ability to detect failure, preserve critical obligations, contain harm, restore a trusted state, communicate responsibly, and learn. If students understand that objective, they will be able to engage meaningfully with cyber risk even as technologies, models, and threat capabilities continue to change.

Bibliography

Chapter 1: Cybersecurity Without Mystification

- Basel Committee on Banking Supervision (Mar. 2021a). *Principles for Operational Resilience*. Tech. rep. Bank for International Settlements. URL: <https://www.bis.org/bcbs/publ/d516.htm>.
- International Monetary Fund (Apr. 2024). “Cyber Risk: A Growing Concern for Macrofinancial Stability”. In: *Global Financial Stability Report, April 2024: The Last Mile*. Washington, DC: International Monetary Fund. Chap. 3. URL: <https://www.imf.org/-/media/files/publications/gfsr/2024/april/english/ch3.pdf>.
- National Institute of Standards and Technology (Feb. 2024d). *The NIST Cybersecurity Framework (CSF) 2.0*. Tech. rep. NIST CSWP 29. National Institute of Standards and Technology. DOI: [10.6028/NIST.CSWP.29](https://doi.org/10.6028/NIST.CSWP.29). URL: <https://doi.org/10.6028/NIST.CSWP.29>.

Chapter 2: What Attackers Try to Achieve

- Cybersecurity and Infrastructure Security Agency (2026). *Known Exploited Vulnerabilities Catalog*. URL: <https://www.cisa.gov/known-exploited-vulnerabilities-catalog> (visited on 08/08/2026).
- European Union Agency for Cybersecurity (Oct. 2025). *ENISA Threat Landscape 2025*. Tech. rep. European Union Agency for Cybersecurity. URL: <https://www.enisa.europa.eu/publications/enisa-threat-landscape-2025>.
- MITRE Corporation (2026). *MITRE ATT&CK: Enterprise Matrix*. URL: <https://attack.mitre.org/matrices/enterprise/> (visited on 08/08/2026).

Chapter 3: What a Defensive Platform Actually Sees

- Kent, Karen and Murugiah Souppaya (Sept. 2006). *Guide to Computer Security Log Management*. Tech. rep. NIST SP 800-92. National Institute of Standards and Technology. DOI: [10.6028/NIST.SP.800-92](https://csrc.nist.gov/pubs/sp/800/92/final). URL: <https://csrc.nist.gov/pubs/sp/800/92/final>.

-
- National Institute of Standards and Technology (Sept. 2011). *Information Security Continuous Monitoring for Federal Information Systems and Organizations*. Tech. rep. NIST SP 800-137. National Institute of Standards and Technology. DOI: [10.6028/NIST.SP.800-137](https://doi.org/10.6028/NIST.SP.800-137). URL: <https://csrc.nist.gov/pubs/sp/800/137/final>.
- (May 2020a). *Assessing Information Security Continuous Monitoring Programs: Developing an ISCM Program Assessment*. Tech. rep. NIST SP 800-137A. National Institute of Standards and Technology. URL: <https://csrc.nist.gov/pubs/sp/800/137/a/final>.

Chapter 4: Identity, Passwords, and Access Risk

- Cybersecurity and Infrastructure Security Agency (Apr. 2023). *Zero Trust Maturity Model, Version 2.0*. Tech. rep. Cybersecurity and Infrastructure Security Agency. URL: https://www.cisa.gov/sites/default/files/2023-04/CISA_Zero_Trust_Maturity_Model_Version_2_508c.pdf.
- National Institute of Standards and Technology (Aug. 2020c). *Zero Trust Architecture*. Tech. rep. NIST SP 800-207. National Institute of Standards and Technology. DOI: [10.6028/NIST.SP.800-207](https://doi.org/10.6028/NIST.SP.800-207). URL: <https://csrc.nist.gov/pubs/sp/800/207/final>.
- (July 2025a). *Digital Identity Guidelines: Authentication and Authenticator Management*. Tech. rep. NIST SP 800-63B-4. National Institute of Standards and Technology. DOI: [10.6028/NIST.SP.800-63B-4](https://doi.org/10.6028/NIST.SP.800-63B-4). URL: <https://csrc.nist.gov/pubs/sp/800/63/b/4/final>.

Chapter 5: Applications, Data, and Integrity Risk

- National Institute of Standards and Technology (Feb. 2022). *Secure Software Development Framework (SSDF) Version 1.1: Recommendations for Mitigating the Risk of Software Vulnerabilities*. Tech. rep. NIST SP 800-218. National Institute of Standards and Technology. DOI: [10.6028/NIST.SP.800-218](https://doi.org/10.6028/NIST.SP.800-218). URL: <https://csrc.nist.gov/pubs/sp/800/218/final>.
- (July 2024a). *Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile*. Tech. rep. NIST AI 600-1. National Institute of Standards and Technology. DOI: [10.6028/NIST.AI.600-1](https://doi.org/10.6028/NIST.AI.600-1). URL: <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-generative-artificial-intelligence>.
- OWASP GenAI Security Project (Aug. 2026). *OWASP GenAI LLM Top 10 2026*. URL: <https://genai.owasp.org/resource/owasp-genai-llm-top-10-2026/> (visited on 08/08/2026).

Chapter 6: Detection, Monitoring, and Security Operations

- National Institute of Standards and Technology (Sept. 2020b). *Security and Privacy Controls for Information Systems and Organizations*. Tech. rep. NIST SP 800-53 Rev. 5. National Institute of Standards and Technology. DOI: [10.6028/NIST.SP.800-53r5](https://doi.org/10.6028/NIST.SP.800-53r5). URL: <https://csrc.nist.gov/pubs/sp/800/53/r5/final>.
- (Dec. 2024c). *Measurement Guide for Information Security: Volume 1—Identifying and Selecting Measures*. Tech. rep. NIST SP 800-55 Vol. 1. National Institute of Standards and Technology. DOI: [10.6028/NIST.SP.800-55v1](https://doi.org/10.6028/NIST.SP.800-55v1). URL: <https://csrc.nist.gov/pubs/sp/800/55/v1/final>.
 - (Apr. 2025c). *Incident Response Recommendations and Considerations for Cybersecurity Risk Management: A CSF 2.0 Community Profile*. Tech. rep. NIST SP 800-61 Rev. 3. National Institute of Standards and Technology. DOI: [10.6028/NIST.SP.800-61r3](https://doi.org/10.6028/NIST.SP.800-61r3). URL: <https://csrc.nist.gov/pubs/sp/800/61/r3/final>.

Chapter 7: Incident Response and Business Continuity

- Basel Committee on Banking Supervision (Mar. 2021b). *Revisions to the Principles for the Sound Management of Operational Risk*. Tech. rep. Bank for International Settlements. URL: <https://www.bis.org/bcbs/publ/d515.htm>.
- Federal Financial Institutions Examination Council (Nov. 2019). *Business Continuity Management*. Tech. rep. Federal Financial Institutions Examination Council. URL: <https://ithandbook.ffiec.gov/it-booklets/business-continuity-management>.
- National Institute of Standards and Technology (May 2010). *Contingency Planning Guide for Federal Information Systems*. Tech. rep. NIST SP 800-34 Rev. 1. National Institute of Standards and Technology. DOI: [10.6028/NIST.SP.800-34r1](https://doi.org/10.6028/NIST.SP.800-34r1). URL: <https://csrc.nist.gov/pubs/sp/800/34/r1/final>.

Chapter 8: Quantifying Cyber and Operational Risk

- National Institute of Standards and Technology (Sept. 2012). *Guide for Conducting Risk Assessments*. Tech. rep. NIST SP 800-30 Rev. 1. National Institute of Standards and Technology. DOI: [10.6028/NIST.SP.800-30r1](https://doi.org/10.6028/NIST.SP.800-30r1). URL: <https://csrc.nist.gov/pubs/sp/800/30/r1/final>.
- (2025b). *Identifying and Estimating Cybersecurity Risk for Enterprise Risk Management*. Tech. rep. NIST IR 8286A Rev. 1. National Institute of Standards and Technology. URL: <https://csrc.nist.gov/pubs/ir/8286/a/r1/final>.
 - (2025d). *Using Business Impact Analysis to Inform Risk Prioritization and Response*. Tech. rep. NIST IR 8286D Update 1. National Institute of Standards and Technology. URL: <https://csrc.nist.gov/pubs/ir/8286/d/upd1/final>.

Chapter 9: Governance, Third Parties, and Accountability

- Financial Stability Board (Dec. 2023). *Enhancing Third-Party Risk Management and Oversight: A Toolkit for Financial Institutions and Financial Authorities*. Tech. rep. Financial Stability Board. URL: <https://www.fsb.org/2023/12/final-report-on-enhancing-third-party-risk-management-and-oversight-a-toolkit-for-financial-institutions-and-financial-authorities/>.
- National Institute of Standards and Technology (Nov. 2024b). *Cybersecurity Supply Chain Risk Management Practices for Systems and Organizations*. Tech. rep. NIST SP 800-161 Rev. 1 Update 1. National Institute of Standards and Technology. DOI: [10.6028/NIST.SP.800-161r1-upd1](https://doi.org/10.6028/NIST.SP.800-161r1-upd1). URL: <https://csrc.nist.gov/pubs/sp/800/161/r1/upd1/final>.
- Office of the Comptroller of the Currency (June 2023). *Third-Party Relationships: Interagency Guidance on Risk Management*. Tech. rep. OCC Bulletin 2023-17. Office of the Comptroller of the Currency. URL: <https://www.occ.gov/news-issuances/bulletins/2023/bulletin-2023-17.html>.

Chapter 10: Finance Professional Cyber-Risk Playbook

- Cybersecurity and Infrastructure Security Agency (Dec. 2025). *Cybersecurity Performance Goals 2.0*. Tech. rep. Cybersecurity and Infrastructure Security Agency. URL: <https://www.cisa.gov/cybersecurity-performance-goals-2-0-cpg-2-0>.
- National Institute of Standards and Technology (Jan. 2023). *Artificial Intelligence Risk Management Framework (AI RMF 1.0)*. Tech. rep. NIST AI 100-1. National Institute of Standards and Technology. DOI: [10.6028/NIST.AI.100-1](https://doi.org/10.6028/NIST.AI.100-1). URL: <https://www.nist.gov/publications/artificial-intelligence-risk-management-framework-ai-rmf-10>.
- U.S. Securities and Exchange Commission (July 2023). *Cybersecurity Risk Management, Strategy, Governance, and Incident Disclosure*. Tech. rep. Release Nos. 33-11216; 34-97989. U.S. Securities and Exchange Commission. URL: <https://www.sec.gov/file/33-11216>.